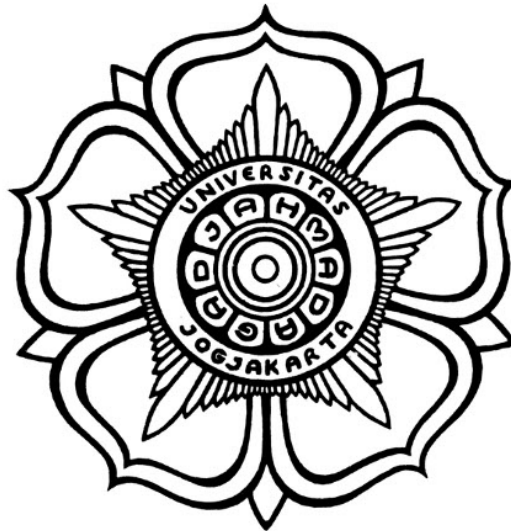


**MANAJEMEN PERANGKAT LUNAK STANDAR ISO27001/2022
SECURE CODING UNTUK PENINGKATAN DAN KONVERSI
VERSI WEB APP DENGAN MEMANFAATKAN AI DAN
PERANGKAT OPENSOURCE.**

SKRIPSI



THE SUSTAINABLE DEVELOPMENT GOALS
Industry, Innovation and Infrastructure
Affordable and Clean Energy
Climate Action

Disusun oleh:

Muhammad Farrel Akbar
22/492806/TK/53947

**PROGRAM SARJANA PROGRAM STUDI TEKNOLOGI INFORMASI
DEPARTEMEN TEKNIK ELEKTRO DAN TEKNOLOGI INFORMASI
FAKULTAS TEKNIK UNIVERSITAS GADJAH MADA
YOGYAKARTA
«TAHUN PENDADARAN»**

HALAMAN PENGESAHAN

MANAJEMEN PERANGKAT LUNAK STANDAR ISO27001/2022 SECURE CODING UNTUK PENINGKATAN DAN KONVERSI VERSI WEB APP DENGAN MEMANFAATKAN AI DAN PERANGKAT OPENSOURCE.

SKRIPSI

Diajukan Sebagai Salah Satu Syarat untuk Memperoleh
Gelar Sarjana Teknik
pada Departemen Teknik Elektro dan Teknologi Informasi
Fakultas Teknik
Universitas Gadjah Mada

Disusun oleh:

Muhammad Farrel Akbar
22/492806/TK/53947

Telah disetujui dan disahkan

Pada tanggal

Dosen Pembimbing I

Dosen Pembimbing II

Dani Adhipta, S.Si., M.T.
«NIP xxxxxx»

Addin Suwastono, Ir., S.T., M.Eng., IPM.
«NIP xxxxxx»

PERNYATAAN BEBAS PLAGIASI

Saya yang bertanda tangan di bawah ini :

Nama : Muhammad Farrel Akbar
NIM : 22/492806/TK/53947
Tahun terdaftar : 2022
Program : Sarjana
Program Studi : Teknologi Informasi
Fakultas : Teknik Universitas Gadjah Mada

Menyatakan bahwa dalam dokumen ilmiah Skripsi ini tidak terdapat bagian dari karya ilmiah lain yang telah diajukan untuk memperoleh gelar akademik di suatu lembaga Pendidikan Tinggi, dan juga tidak terdapat karya atau pendapat yang pernah ditulis atau diterbitkan oleh orang/lembaga lain, kecuali yang secara tertulis disitasi dalam dokumen ini dan disebutkan sumbernya secara lengkap dalam daftar pustaka.

Dengan demikian saya menyatakan bahwa dokumen ilmiah ini bebas dari unsur-unsur plagiasi dan apabila dokumen ilmiah Skripsi ini di kemudian hari terbukti merupakan plagiasi dari hasil karya penulis lain dan/atau dengan sengaja mengajukan karya atau pendapat yang merupakan hasil karya penulis lain, maka penulis bersedia menerima sanksi akademik dan/atau sanksi hukum yang berlaku.

Yogyakarta, tanggal-bulan-tahun

Materai Rp10.000

(Tanda tangan)

Muhammad Farrel Akbar
22/492806/TK/53947

HALAMAN PERSEMBAHAN

Tugas akhir ini saya persembahkan kepada kedua orang tua saya yang telah mendukung dan mendoakan saya hingga titik ini. Saya persembahkan pula kepada keluarga dan teman-teman semua, serta untuk bangsa, negara, dan agamaku.

KATA PENGANTAR

Puji syukur ke hadirat Allah SWT atas limpahan rahmat, karunia, serta petunjuk-Nya sehingga tugas akhir berupa penyusunan skripsi ini telah terselesaikan dengan baik. Dalam hal penyusunan tugas akhir ini penulis telah banyak mendapatkan arahan, bantuan, serta dukungan dari berbagai pihak. Oleh karena itu pada kesempatan ini penulis mengucapkan terima kasih kepada:

1. Dani Adhipta, S.Si., M.T. yang telah membimbing dan memberikan arahan serta ilmu yang sangat berharga selama penyusunan skripsi ini.
2. Addin Suwastono, Ir., S.T., M.Eng., IPM. yang telah membimbing dan memberikan arahan serta ilmu yang sangat berharga selama penyusunan skripsi ini.
3. Orang tua saya, Bapak Andrian Nugroho dan Ibu Retny Anggeriana yang telah memberikan dukungan moril dan materiil serta doa yang tiada henti sehingga saya dapat menyelesaikan studi ini.

Saya sebagai penulis menyadari bahwa dalam penyusunan skripsi ini masih jauh dari kesempurnaan. Oleh karena itu, kritik dan saran yang membangun sangat penulis harapkan demi kesempurnaan skripsi ini. Semoga skripsi ini dapat bermanfaat bagi pembaca pada umumnya dan bagi penulis pada khususnya. Amin.

Yogyakarta, 13 Mei 2026

Muhammad Farrel Akbar
22/492806/TK/53947

DAFTAR ISI

HALAMAN PENGESAHAN	ii
PERNYATAAN BEBAS PLAGIASI	iii
HALAMAN PERSEMBAHAN	iv
KATA PENGANTAR	v
DAFTAR ISI	vi
DAFTAR TABEL	x
DAFTAR GAMBAR	xi
DAFTAR SINGKATAN.....	xiii
INTISARI.....	xiv
ABSTRACT	xv
BAB I Pendahuluan	1
1.1 Latar Belakang	1
1.2 Rumusan Masalah	4
1.3 Tujuan Penelitian	4
1.4 Batasan Penelitian	5
1.5 Keamanan dan Privasi Data	6
1.6 Manfaat Penelitian	6
1.6.1 Manfaat Akademis	6
1.6.2 Manfaat Praktis.....	6
1.7 Sistematika Penulisan.....	7
BAB II Tinjauan Pustaka dan Dasar Teori	8
2.1 Tinjauan Literatur	8
2.1.1 Perlindungan Otomatis Aplikasi PHP dari Injeksi SQL.....	8
2.1.2 Menggunakan LLM untuk Menemukan dan Memantau Kerentanan	8
2.1.3 Transformasi Kode dengan Bantuan LLM	9
2.1.4 Pendekatan Neuro-Simbolik untuk Deteksi Kerentanan Keamanan	9
2.1.5 Dampak Jangka Panjang Transformasi Kode Otomatis	10
2.1.6 Transformasi Kode Berbasis Pola untuk Migrasi Aplikasi.....	10
2.1.7 Migrasi Kode Berbasis AST pada Skala Industri	11
2.1.8 Ringkasan Perbandingan.....	12
2.2 Dasar Teori	13
2.2.1 PHP dan Perubahan Antar Versi	13
2.2.2 ISO/IEC 27001:2022 dan <i>Secure Coding</i>	14
2.2.3 OWASP Top 10 dan Kerentanan Aplikasi Web PHP	15
2.2.4 DevSecOps dan Integrasi Keamanan dalam <i>Pipeline</i> Pengembangan	15
2.2.5 Metodologi <i>Research and Development</i> dengan Model Prototipe ..	16

2.2.6	<i>Abstract Syntax Trees</i> dan <i>Static Analysis</i>	16
2.2.7	Rector: Alat Transformasi Kode Berbasis AST	16
2.2.8	PHPStan: Alat Analisis Statis untuk PHP	17
2.2.9	Semgrep: Alat Analisis Statis Ringan untuk Keamanan	17
2.2.10	Model-Model LLM untuk Analisis Kode	17
2.2.11	Metrik Evaluasi Kualitas Keluaran LLM	18
2.2.12	Ollama: Menerapkan LLM Secara Lokal	20
BAB III Metodologi Penelitian		21
3.1	Alat dan Bahan Penelitian	21
3.1.1	Perangkat Keras	21
3.1.2	Perangkat Lunak	21
3.1.3	Model LLM yang Dievaluasi	22
3.1.4	Bahan Penelitian	22
3.2	Metode Penelitian	23
3.3	Arsitektur Sistem	24
3.3.1	Scanner (scanner.py)	25
3.3.2	Converter (converter.py)	25
3.3.3	Analyzer (analyzer.py)	26
3.3.4	AI Engine (ai_engine.py)	26
3.3.5	ISO Mapper (iso_mapper.py)	27
3.3.6	Main (main.py)	27
3.3.7	Composer Analyzer (composer_analyzer.py)	28
3.4	Alur Data Pipeline	28
3.5	Desain Prompt LLM	29
3.5.1	Struktur Prompt	29
3.5.2	Keputusan Desain Prompt	32
3.6	Desain Pemetaan ISO/IEC 27001:2022	33
3.6.1	Mekanisme Klasifikasi Temuan	34
3.7	Rancangan Eksperimen Komparasi Model LLM	35
3.7.1	Kondisi Eksperimen	35
3.7.2	Metrik Evaluasi	36
3.7.3	Interpretasi <i>Trade-off</i> Antar Metrik	36
3.8	Metode Pengujian dan Evaluasi	36
BAB IV Hasil dan Diskusi		38
4.1	Studi Kasus 1: FT UGM (Dashboard TCK)	38
4.1.1	Deskripsi Dataset	38
4.1.2	Hasil Konversi Rector	38
4.1.2.1	Contoh Transformasi Rector	39
4.1.2.2	File yang Gagal Dikonversi	41

4.1.3	Hasil Pemindaian Keamanan Semgrep	42
4.1.3.1	Pre-Scan: Baseline Keamanan Kode Asli	42
4.1.3.2	Post-Scan: Perbandingan Setelah Konversi	42
4.1.4	Hasil Validasi PHPStan	43
4.1.5	Status Kepatuhan ISO/IEC 27001:2022	44
4.1.6	Hasil Komparasi Lima Model LLM (Kondisi A).....	45
4.1.6.1	Format Compliance Rate	45
4.1.6.2	Syntax Validity Rate	46
4.1.6.3	Statistik Ringkasan	46
4.1.6.4	Trade-off dan Implikasinya.....	49
4.1.7	Hasil Komparasi Lima Model LLM (Kondisi B).....	50
4.1.7.1	Format Compliance Rate	50
4.1.7.2	Syntax Validity Rate	51
4.1.7.3	Statistik Ringkasan	52
4.1.8	Perbandingan Kondisi A dan Kondisi B	53
4.1.9	Optimasi Parameter Qwen2.5-Coder (Kondisi C)	54
4.1.9.1	Pengaruh Temperature.....	54
4.1.9.2	Pengaruh Context Window	55
4.1.9.3	Implikasi Kondisi C	55
4.1.10	Analisis Dependensi Composer	55
4.1.11	Validasi Keakuratan Hasil Konversi.....	56
4.1.11.1	Metrik Pipeline-Level	56
4.1.11.2	Validasi Sampling 10%.....	57
4.1.12	Diskusi dan Keterbatasan	59
4.1.12.1	Keterbatasan Dataset	59
4.1.12.2	Keterbatasan Kompatibilitas PHP 8.4 dan PHP 8.5	59
4.1.12.3	Keterbatasan Teknis Pipeline.....	60
4.1.12.4	Interpretasi Confidence Score	60
4.2	Studi Kasus 2: Sistem CBT DTI UGM	61
4.2.1	Deskripsi Dataset.....	61
4.2.2	Hasil Konversi Rector	61
4.2.2.1	File yang Gagal Dikonversi	62
4.2.3	Hasil Pemindaian Keamanan Semgrep	62
4.2.3.1	Pre-Scan: Baseline Keamanan Kode Asli	62
4.2.3.2	Post-Scan dan AI Engine	63
4.2.4	Hasil Validasi PHPStan	64
4.2.5	Status Kepatuhan ISO/IEC 27001:2022	66
4.2.6	Analisis Dependensi Composer	66
4.3	Perbandingan Kedua Studi Kasus	67

4.3.1	Perbandingan Temuan Keamanan Semgrep	67
4.3.2	Perbandingan Tingkat Konversi Rector	67
4.3.3	Perbandingan Temuan PHPStan	68
4.3.4	Ringkasan Perbandingan dan Analisis Dependensi Composer	69
BAB V	Kesimpulan dan Saran	71
5.1	Kesimpulan	71
5.2	Saran	72
DAFTAR PUSTAKA		75
LAMPIRAN		L-1
L.1	Pseudocode Pipeline Migrasi PHP	L-5

DAFTAR TABEL

Tabel 2.1	Perbandingan Penelitian Terdahulu dan Karakteristik Penelitian	12
Tabel 2.2	Perbandingan Penelitian Terdahulu dan Aspek Metodologi.....	12
Tabel 3.1	Pemetaan argumen <code>-target-php</code> ke konfigurasi Rector	26
Tabel 3.2	Pemetaan sumber temuan ke kontrol ISO/IEC 27001:2022 Annex A	34
Tabel 3.3	Pemetaan kata kunci <code>rule_id</code> Semgrep ke jenis kerentanan dan kontrol ISO/IEC 27001:2022	35
Tabel 4.1	Status kepatuhan ISO/IEC 27001:2022 hasil <i>pipeline</i> pada dataset FT UGM	44
Tabel 4.2	Perbandingan metrik utama Kondisi A vs Kondisi B untuk kelima model LLM	53
Tabel 4.3	Status kompatibilitas PHP 8.x dependensi <i>composer</i> FT UGM.....	56
Tabel 4.4	Status kepatuhan ISO/IEC 27001:2022 hasil <i>pipeline</i> pada dataset CBT DTI UGM.....	66
Tabel 4.5	Ringkasan perbandingan metrik <i>pipeline</i> dan status dependensi <i>composer</i> kedua studi kasus	70

DAFTAR GAMBAR

Gambar 3.1	Alur penelitian dengan model prototipe	23
Gambar 3.2	Arsitektur sistem <i>pipeline</i> dengan enam modul fungsional dan satu orkestrator	25
Gambar 3.3	Alur data <i>pipeline</i> : tahap masukan: Scanner, Converter, dan Composer Analyzer	28
Gambar 3.4	Alur data <i>pipeline</i> : tahap keluaran: Analyzer, AI Engine, ISO Mapper, dan laporan akhir	29
Gambar 4.5	Ringkasan hasil konversi Rector terhadap 245 <i>file</i> PHP dataset FT UGM	39
Gambar 4.6	Distribusi temuan PHPStan berdasarkan kontrol ISO/IEC 27001:2022 Annex A	43
Gambar 4.7	<i>Format compliance rate</i> kelima model LLM pada Kondisi A (<i>zero-shot</i> , <i>prompt</i> identik)	45
Gambar 4.8	<i>Syntax validity rate</i> dan <i>code block extraction rate</i> kelima model LLM pada Kondisi A	46
Gambar 4.9	Statistik lengkap komparasi kelima model LLM pada Kondisi A .	47
Gambar 4.10	<i>Format compliance rate</i> kelima model LLM pada Kondisi B (<i>prompt</i> dioptimasi per model)	51
Gambar 4.11	<i>Syntax validity rate</i> dan <i>code block extraction rate</i> kelima model LLM pada Kondisi B	51
Gambar 4.12	Statistik lengkap komparasi kelima model LLM pada Kondisi B .	52
Gambar 4.13	Perbandingan metrik Qwen2.5-Coder pada variasi <i>temperature</i> dan <i>context window</i> (Kondisi C)	54
Gambar 4.14	Metrik akurasi konversi Rector dan durasi eksekusi <i>pipeline</i> pada dataset FT UGM	56
Gambar 4.15	Distribusi cakupan <i>file</i> sampel validasi 10% berdasarkan direktori asal	57
Gambar 4.16	Perbandingan metrik validasi antara keluaran Rector dan referensi LLM pada 12 <i>file</i> sampel dari <i>application/</i>	58
Gambar 4.17	Distribusi <i>similarity score</i> antara keluaran Rector dan referensi LLM pada 12 <i>file</i> sampel (<i>line-level SequenceMatcher</i>)	59
Gambar 4.18	Ringkasan hasil konversi Rector terhadap 326 <i>file</i> PHP dataset CBT DTI UGM	62
Gambar 4.19	Proporsi hasil konversi Rector dataset CBT DTI UGM (diagram lingkaran)	63
Gambar 4.20	Temuan Semgrep <i>pre-scan</i> vs <i>post-scan</i> berdasarkan tingkat keparahan pada dataset CBT DTI UGM	64
Gambar 4.21	Temuan Semgrep <i>pre-scan</i> vs <i>post-scan</i> berdasarkan jenis kerentanan pada dataset CBT DTI UGM	65
Gambar 4.22	Distribusi temuan PHPStan berdasarkan kontrol ISO/IEC 27001:2022 Annex A pada dataset CBT DTI UGM	65
Gambar 4.23	Perbandingan temuan Semgrep <i>pre-scan</i> berdasarkan jenis kerentanan pada kedua studi kasus	67
Gambar 4.24	Perbandingan hasil konversi Rector pada kedua studi kasus	68

Gambar 4.25 Perbandingan <i>error</i> PHPStan berdasarkan kontrol ISO/IEC 27001:2022 pada kedua studi kasus.....	69
--	----

DAFTAR SINGKATAN

CR	= <i>Conversion Rate</i> (tingkat konversi)
FCR	= <i>Format Compliance Rate</i>
SVR	= <i>Syntax Validity Rate</i>
ΔF	= <i>Security Finding Delta</i> (selisih temuan keamanan)
$\bar{C}_m$	= <i>Mean Confidence Score</i> model m
σ_m^2	= variansi <i>confidence score</i> model m
AI	= <i>Artificial Intelligence</i>
API	= <i>Application Programming Interface</i>
AST	= <i>Abstract Syntax Tree</i>
AWS	= <i>Amazon Web Services</i>
CBT	= <i>Computer-Based Test</i>
CI/CD	= <i>Continuous Integration/Continuous Delivery</i>
CLI	= <i>Command Line Interface</i>
CVE	= <i>Common Vulnerabilities and Exposures</i>
CWE	= <i>Common Weakness Enumeration</i>
GGUF	= <i>GGML Unified Format</i>
GPU	= <i>Graphics Processing Unit</i>
IDE	= <i>Integrated Development Environment</i>
IEC	= <i>International Electrotechnical Commission</i>
ISMS	= <i>Information Security Management System</i>
ISO	= <i>International Organization for Standardization</i>
JIT	= <i>Just-In-Time</i>
JSON	= <i>JavaScript Object Notation</i>
LLM	= <i>Large Language Model</i>
LoRA	= <i>Low-Rank Adaptation</i>
MVC	= <i>Model-View-Controller</i>
NIST	= <i>National Institute of Standards and Technology</i>
NVD	= <i>National Vulnerability Database</i>
OWASP	= <i>Open Web Application Security Project</i>
PDO	= <i>PHP Data Objects</i>

INTISARI

Sebagian besar situs web masih menjalankan aplikasi PHP pada versi 7.x atau lebih lama yang sudah tidak mendapatkan pembaruan keamanan resmi, sehingga sistem menghadapi akumulasi kerentanan yang terus bertambah tanpa kemungkinan diperbaiki. Migrasi manual pada ratusan *file* kode tidak realistis, dan alat transformasi yang tersedia saat ini tidak menyertakan pemeriksaan keamanan sebagai bagian terintegrasi dari alur migrasi. Organisasi yang beroperasi di bawah standar ISO/IEC 27001:2022 juga harus melakukan audit keamanan sebagai langkah terpisah setelah migrasi selesai, sehingga menambah beban operasional.

Penelitian ini membangun *platform* berbasis Python yang mengintegrasikan konversi otomatis aplikasi web PHP lama ke versi PHP target yang dapat dikonfigurasi dengan pemeriksaan kepatuhan *secure coding* berbasis ISO/IEC 27001:2022 dalam satu alur kerja *open source* yang dapat dijalankan secara lokal. *Platform* menggunakan Rector untuk transformasi kode berbasis AST, Semgrep untuk pemindaian keamanan, PHPStan untuk validasi pasca-konversi, serta lima model LLM *open source* yang dijalankan secara lokal melalui Ollama—DeepSeek Coder 6.7b, Qwen2.5-Coder 7b, CodeLlama 7b, Mistral 7b, dan Llama 3.1 8b—untuk analisis semantik dan saran perbaikan kerentanan. Studi kasus dilakukan pada kode PHP milik FT UGM (Dashboard TCK, 245 *file*) dan CBT DTI UGM (326 *file*).

Rector mencatat tingkat konversi 97,6% pada dataset FT UGM dan 91,7% pada dataset CBT DTI UGM, dengan tingkat validitas sintaks pasca-konversi 100% pada kedua studi kasus. Nilai $\Delta F = 0$ mengonfirmasi bahwa proses konversi tidak memperkenalkan kerentanan baru. Laporan JSON yang dihasilkan secara otomatis mencakup pemetaan per temuan ke kontrol ISO/IEC 27001:2022 Annex A yang relevan dan dapat langsung digunakan sebagai dokumentasi audit. Dari eksperimen komparasi lima model LLM, Qwen2.5-Coder 7b direkomendasikan untuk integrasi ke dalam sistem otomatis karena menghasilkan *Syntax Validity Rate* (SVR) 100% secara konsisten di semua kondisi eksperimen. *Platform* ini membuktikan bahwa integrasi antara konversi kode otomatis dan pemeriksaan kepatuhan ISO/IEC 27001:2022 dapat dijalankan sepenuhnya secara lokal tanpa mengirimkan kode sumber ke layanan eksternal.

Kata kunci : migrasi PHP, *secure coding*, ISO/IEC 27001:2022, *large language model*, transformasi kode AST

ABSTRACT

The majority of websites continue to run PHP web applications on end-of-life versions that no longer receive official security updates, leaving known vulnerabilities permanently unpatched. Manual migration of hundreds of source files is impractical, and existing transformation tools do not incorporate security compliance checks as an integrated part of the migration workflow. Organizations operating under ISO/IEC 27001:2022 are further burdened by having to conduct security audits as a separate step after migration is complete.

This research develops a Python-based platform that integrates automated conversion of legacy PHP web applications to a configurable target PHP version with ISO/IEC 27001:2022-aligned secure coding compliance checks in a single, fully local, open source workflow. The platform combines Rector for AST-based code transformation, Semgrep for security scanning, PHPStan for post-conversion type validation, and five locally executed open source large language models via Ollama—DeepSeek Coder 6.7b, Qwen2.5-Coder 7b, CodeLlama 7b, Mistral 7b, and Llama 3.1 8b—for semantic vulnerability analysis and remediation suggestions. Case studies were conducted on PHP codebases from FT UGM (Dashboard TCK, 245 files) and CBT DTI UGM (326 files).

Rector achieved a conversion rate of 97.6% on the FT UGM dataset and 91.7% on the CBT DTI UGM dataset, with 100% post-conversion syntax validity in both cases. A delta finding value of zero ($\Delta F = 0$) confirmed that the conversion process introduced no new security vulnerabilities. Automatically generated JSON reports include per-finding mappings to relevant ISO/IEC 27001:2022 Annex A controls and can be used directly as audit documentation. Among the five evaluated LLMs, Qwen2.5-Coder 7b is recommended for automated pipeline integration, consistently achieving 100% Syntax Validity Rate across all experimental conditions. The platform demonstrates that automated PHP version migration combined with ISO/IEC 27001:2022 compliance reporting can be executed entirely on-premises without transmitting source code to any external service.

Keywords : PHP migration, secure coding, ISO/IEC 27001:2022, large language model, AST code transformation

BAB I

PENDAHULUAN

1.1 Latar Belakang

PHP bukan bahasa yang didesain untuk menjadi bahasa pemrograman besar. Rasmus Lerdorf memperkenalkannya pada tahun 1995 sebagai kumpulan skrip sederhana untuk mengelola halaman web pribadinya [1]. Tapi dalam waktu beberapa tahun, PHP berkembang jauh melampaui tujuan awalnya, dan pada akhir 1990-an sudah menjadi pilihan dominan untuk pengembangan sisi *server* [1]. Kemudahan penggunaan, dukungan *hosting* yang luas, dan ekosistem pustaka yang terus bertumbuh menjadikannya pilihan yang wajar bagi banyak pengembang web, mulai dari individu hingga tim teknologi di institusi besar [1].

Data terbaru menegaskan dominasi ini. Menurut W3Techs per 8 April 2026, sebesar 71,7% dari seluruh situs web yang memiliki bahasa pemrograman sisi *server* yang diketahui menggunakan PHP [2]. Angka itu menempatkan PHP jauh di atas bahasa-bahasa lainnya. Namun di balik angka yang terlihat impresif tersebut ada kenyataan yang kurang nyaman: hanya 58,1% dari situs web berbasis PHP yang telah beralih ke versi 8. Sekitar 33,1% masih menggunakan PHP 7.x, dan 8,7% masih berjalan di PHP 5.x [2]. Artinya hampir separuh pengguna PHP di seluruh dunia masih menjalankan versi yang sudah tidak mendapatkan pembaruan keamanan resmi.

Ini bukan masalah kecil. Dukungan resmi untuk PHP 7.4, versi terakhir dalam seri 7.x, berakhir pada 28 November 2022 [3]. Setelah tanggal itu, tidak ada lagi pembaruan keamanan yang dirilis, termasuk untuk kerentanan baru yang terus ditemukan. Basis Data Kerentanan Nasional (NVD) yang dikelola NIST mencatat bahwa sistem yang berjalan di atas versi *end-of-life* secara efektif membiarkan celah keamanan yang sudah diketahui publik tetap terbuka tanpa kemungkinan diperbaiki [4]. Semakin lama sistem dibiarkan berjalan di versi lama, semakin besar akumulasi risiko yang ditanggung.

Jenis kerentanan yang paling umum ditemukan pada aplikasi PHP lama sudah terdokumentasi cukup baik. OWASP Top 10:2021 [5] mencantumkan injeksi sebagai salah satu ancaman paling serius pada aplikasi web. Pada kode PHP lama, injeksi SQL hampir selalu muncul dari penggunaan fungsi `mysql_query()` di mana *input* pengguna langsung digabungkan ke dalam pernyataan SQL tanpa parameterisasi. Kerentanan XSS (*cross-site scripting*) juga lazim karena banyak aplikasi PHP lama tidak menerapkan encode *output* secara konsisten. Selain itu masih ada masalah kriptografi lemah seperti penggunaan `md5()` untuk menyimpan kata sandi, penanganan sesi yang tidak aman, dan berbagai fungsi yang sudah dihapus dari PHP 8.x karena alasan keamanan [5]. Bahwa masalah-masalah ini sudah ada sejak lama bukan

berarti sudah terselesaikan; Merlo, Letarte, dan Antoniol [6] sudah mengangkat persoalan perlindungan otomatis aplikasi PHP dari injeksi SQL sejak 2007, dan solusi komprehensif masih belum tersedia hingga sekarang.

Situasi ini bukan hanya dialami oleh organisasi di luar negeri. FT UGM mengelola sejumlah aplikasi web berbasis PHP yang sebagian di antaranya masih berjalan di atas versi lama, sehingga proses modernisasi menjadi kebutuhan yang mendesak. Kondisi ini mencerminkan tantangan yang jamak dihadapi institusi pendidikan dan pemerintahan yang membangun sistem informasi berbasis PHP di era sebelum standar pengembangan modern diadopsi luas. Migrasi sering tertunda karena kompleksitas teknis dan kekhawatiran bahwa prosesnya akan mengganggu layanan yang sudah berjalan [3].

Secara teknis, migrasi dari PHP 7.x ke PHP 8.x bukan sesuatu yang sederhana. PHP 8.x membawa sejumlah *breaking changes* yang membuat kode PHP 7.x tidak bisa langsung dijalankan tanpa modifikasi [3]. Fungsi-fungsi yang sebelumnya umum digunakan seperti `create_function()`, `each()`, dan seluruh ekstensi `ext/mysql` dihapus. Sistem tipe menjadi jauh lebih ketat dengan tipe *union* dan tipe campuran, yang bisa memicu kesalahan *runtime* pada kode yang sebelumnya berjalan normal. PHP 8.x juga memperkenalkan fitur baru seperti argumen bernama, *match expression*, operator *nullsafe* (`?->`), dan kompilasi JIT [3]. Penanganan kesalahan pun berubah: sejumlah fungsi yang dulu mengembalikan `false` ketika gagal kini melempar pengecualian.

Melakukan semua perubahan ini secara manual pada ratusan atau ribuan *file* kode adalah pendekatan yang tidak realistis. Beberapa organisasi memilih pendekatan bertahap, beralih ke PHP 7.4 dahulu sebelum pindah ke PHP 8.x [3], yang menjadikan dukungan versi target yang dapat dikonfigurasi sebagai kebutuhan nyata, bukan sekadar fitur tambahan.

Alat otomatis yang tersedia saat ini sudah membantu, tapi masing-masing punya batas. Rector [7] adalah alat transformasi berbasis AST yang terbukti andal untuk perubahan sintaksis skala industri, sebagaimana ditunjukkan oleh Chen et al. [8] dalam studi migrasi kode TypeScript di Microsoft. Namun Rector tidak bisa menangani kasus yang membutuhkan pemahaman semantik. Penggantian `mysql_*()` dengan PDO atau MySQLi, misalnya, bukan sekadar mengganti nama fungsi; ini penulisan ulang logika akses basis data secara keseluruhan yang hanya bisa dilakukan jika konteks penggunaannya dipahami.

Di sisi keamanan, Semgrep [9] bisa mengidentifikasi pola kerentanan secara otomatis, dan PHPStan [10] bisa memeriksa kompatibilitas tipe kode dengan versi PHP target. Tapi tidak ada satu pun dari alat-alat ini yang secara inheren menggabungkan

deteksi kerentanan, transformasi kode, dan kepatuhan standar keamanan dalam satu alur kerja yang terintegrasi. Akibatnya tim pengembang yang mengerjakan migrasi dan tim keamanan yang melakukan audit bekerja secara terpisah. Strobl et al. [11] menemukan dari tiga kasus transformasi kode skala besar di sektor pemerintahan bahwa ketiadaan mekanisme validasi yang melekat pada proses transformasi menimbulkan risiko yang baru terasa jauh setelah sistem berjalan di produksi.

Tekanan bertambah bagi organisasi yang beroperasi di bawah standar keamanan informasi. ISO/IEC 27001:2022 [12] mensyaratkan praktik *secure coding* yang terdokumentasi dan dapat diaudit melalui tiga kontrol dalam Annex A.8: A.8.25 (*secure development lifecycle*), A.8.28 (*secure coding*), dan A.8.29 (pengujian keamanan dalam pengembangan dan penerimaan). Bagi organisasi yang sedang dalam proses sertifikasi ISO/IEC 27001:2022, bukti bahwa migrasi kode dilakukan dengan memperhatikan standar ini harus tersedia sebagai bagian dari dokumentasi audit. Menghasilkan bukti tersebut saat ini masih memerlukan pekerjaan manual yang terpisah dari proses migrasi.

Kemajuan dalam *Large Language Models* (LLM) membuka kemungkinan baru. LLM sudah terbukti dapat digunakan untuk mendeteksi kerentanan perangkat lunak [13] [14]. Li, Dutta, dan Naik [15] menunjukkan bahwa menggabungkan LLM dengan alat analisis statis menghasilkan deteksi kerentanan yang lebih baik dari masing-masing pendekatan yang berjalan sendiri. Stümpfle et al. [16] meneliti penggunaan LLM untuk transformasi kode yang membutuhkan pemahaman semantik dalam konteks migrasi varian perangkat lunak. Dengan kemampuan memahami konteks kode, LLM berpotensi mengisi celah yang tidak bisa ditangani alat berbasis aturan seperti Rector.

Kendala utamanya adalah privasi data. Model LLM berperforma tinggi seperti GPT-4 diakses melalui API *cloud*, yang berarti kode sumber harus dikirimkan ke *server* pihak ketiga. Untuk institusi seperti FT UGM yang mengelola kode sumber aplikasi internal yang bersifat rahasia, ini bukan pilihan yang bisa diterima. Perkembangan model LLM *open source* berukuran kecil hingga menengah beberapa tahun terakhir mengubah situasi ini. Model-model seperti DeepSeek Coder 6.7b [17], Qwen2.5-Coder 7b [18], CodeLlama 7b [19], Mistral 7b [20], dan Llama 3.1 8b [21] kini bisa dijalankan secara lokal pada perangkat keras konsumen ber-VRAM 8 GB melalui Ollama [22]. Seluruh proses inferensi terjadi di mesin lokal tanpa ada data yang keluar dari lingkungan organisasi.

Situasi ini menyisakan dua masalah mendasar yang belum terpecahkan. Pertama, migrasi kode PHP lama masih memerlukan intervensi manual besar untuk kasus yang butuh pemahaman semantik, dan alat yang ada tidak menyertakan pemeriksaan keamanan sebagai bagian dari alur migrasi. Kedua, organisasi yang harus memenuhi ISO/IEC 27001:2022 masih harus melakukan audit keamanan sebagai langkah terpisah setelah

migrasi selesai. Belum ada platform yang menggabungkan keduanya dalam satu alur kerja *open source* yang dapat dijalankan secara lokal, sebagaimana ditunjukkan oleh tinjauan literatur pada Bab II.

Penelitian ini membangun *platform* berbasis AI dan alat *open source* yang dapat secara otomatis mengubah aplikasi web PHP lama ke versi PHP target yang dapat dikonfigurasi, dengan dukungan teknis dari PHP 5.2 hingga PHP 8.x, sekaligus menyertakan pemeriksaan *secure coding* berbasis ISO/IEC 27001:2022. *Platform* ini menggunakan Rector [7] untuk transformasi kode berbasis AST, Semgrep [9] untuk pemindaian keamanan, PHPStan [10] untuk validasi pasca-konversi, serta lima model LLM *open source* yang dijalankan secara lokal melalui Ollama [22]. Studi kasus dilakukan pada kode PHP milik FT UGM dan CBT DTI UGM.

1.2 Rumusan Masalah

Berdasarkan latar belakang yang telah diuraikan, penelitian ini merumuskan empat permasalahan sebagai berikut:

1. Bagaimana merancang *pipeline* berbasis AI yang mampu melakukan konversi otomatis aplikasi web PHP 7.x ke PHP 8.3 menggunakan alat *open source*?
2. Bagaimana memvalidasi bahwa hasil konversi mempertahankan fungsionalitas kode sumber yang telah dikonversi?
3. Bagaimana mengintegrasikan pemeriksaan *secure coding* yang selaras dengan kontrol ISO/IEC 27001:2022 Annex A.8 ke dalam *pipeline* konversi otomatis?
4. Model LLM *open source* lokal mana yang memberikan analisis keamanan dan saran perbaikan kode PHP terbaik dalam konteks migrasi dari PHP 7.x ke PHP 8.3?

1.3 Tujuan Penelitian

Penelitian ini memiliki empat tujuan yang menjawab rumusan masalah di atas:

1. Membangun *pipeline* berbasis AI menggunakan alat *open source* untuk mengonversi aplikasi web PHP 7.x ke PHP 8.3 secara otomatis.
2. Memvalidasi bahwa hasil konversi mempertahankan fungsionalitas kode sumber melalui pemeriksaan validitas sintaksis dan kompatibilitas tipe pasca-konversi.
3. Mengimplementasikan mekanisme pemeriksaan *secure coding* yang dipetakan ke kontrol ISO/IEC 27001:2022 Annex A.8 sebagai bagian dari alur konversi.
4. Membandingkan performa lima model LLM *open source* yang dijalankan secara lokal untuk menentukan model yang paling efektif dalam memberikan analisis dan saran perbaikan keamanan kode PHP dalam konteks migrasi versi.

1.4 Batasan Penelitian

Penelitian ini memiliki batasan-batasan sebagai berikut:

1. **Ruang lingkup konversi:** Secara teknis, *pipeline* yang dibangun mendukung konversi dari PHP 5.2 ke atas, karena Rector menggunakan rantai *ruleset* kumulatif yang mencakup semua perubahan dari PHP 5.2 hingga versi target yang dipilih [7]. Namun studi kasus dalam penelitian ini menggunakan kode sumber PHP 7.x milik FT UGM dan CBT DTI UGM sebagai representasi kondisi yang paling umum ditemukan saat ini [2]. Versi target yang dapat dikonfigurasi mencakup PHP 7.4 hingga PHP 8.3, yang merupakan rentang versi paling relevan untuk kebutuhan modernisasi institusi saat ini [3].
2. **Studi kasus:** Penelitian ini menggunakan dua studi kasus: (1) aplikasi *Dashboard TCK (Target Capaian Kerja)* milik Fakultas Teknik (FT) Universitas Gadjah Mada, dibangun di atas *framework* CodeIgniter 3 dengan versi PHP 7.4.9; dan (2) aplikasi *Computer-Based Test (CBT)* milik Direktorat Teknologi Informasi (DTI) Universitas Gadjah Mada, dibangun di atas *framework* CodeIgniter 3 dengan persyaratan PHP ≥ 7.0 . *Pipeline* bekerja pada level *file* PHP individual dan tidak bergantung pada *framework* yang digunakan, sehingga secara teknis dapat diterapkan pada aplikasi berbasis *framework* lain seperti Laravel atau Symfony maupun pada aplikasi PHP tanpa *framework*. Pengujian terhadap *framework* selain CodeIgniter 3 bukan bagian dari ruang lingkup penelitian ini.
3. **Kontrol keamanan:** Pemeriksaan keamanan hanya dilakukan pada kontrol ISO/IEC 27001:2022 Annex A yang relevan dengan *secure coding*: A.8.25, A.8.28, dan A.8.29, serta A.5.17 dan A.8.24 dan A.8.26 yang turut dipetakan oleh *pipeline* [12].
4. **Model AI:** Penelitian ini mengevaluasi dan membandingkan lima model LLM *open source* yang dijalankan secara lokal melalui Ollama [22] dalam eksperimen komparasi *zero-shot*: DeepSeek Coder 6.7b [17], Qwen2.5-Coder 7b [18], CodeLlama 7b [19], Mistral 7b [20], dan Llama 3.1 8b [21]. Semua model digunakan tanpa *fine-tuning*.
5. **Lingkungan validasi:** Pengujian dilakukan dalam pengaturan lokal menggunakan kode sumber dari lingkungan institusional. Pengujian dalam lingkungan produksi skala besar bukan bagian dari ruang lingkup penelitian ini.
6. **Bahasa pemrograman:** Penelitian ini terbatas pada aplikasi PHP. Bahasa lain tidak dicakup.
7. **Kompleksitas aplikasi:** Aplikasi uji memiliki kompleksitas tingkat menengah, mencakup ratusan *file* PHP dengan campuran logika bisnis, akses basis data, dan

presentasi dalam satu basis kode *framework*.

1.5 Keamanan dan Privasi Data

Kode PHP dari FT UGM dan DTI UGM adalah aset institusi yang tidak boleh dikirimkan ke layanan eksternal. Batasan privasi data ini menjadi landasan dalam merancang arsitektur AI pada penelitian ini. Alih-alih menggunakan API LLM berbasis *cloud*, penelitian ini menggunakan Ollama sebagai *runtime* lokal sehingga seluruh inferensi terjadi di mesin pengembangan.

Tidak ada potongan kode sumber aplikasi yang dikirimkan ke layanan inferensi eksternal atau API LLM berbasis *cloud*. Seluruh proses analisis berlangsung secara statis: tidak ada koneksi ke basis data produksi FT UGM, tidak ada eksekusi kode PHP. Satu-satunya koneksi eksternal yang terjadi adalah panggilan ke Packagist API oleh modul `composer_analyzer.py` untuk memeriksa metadata versi dependensi, bukan kode sumber aplikasi. Keputusan ini sejalan dengan ISO/IEC 27001:2022 yang mensyaratkan pemisahan lingkungan pengembangan dan pengendalian akses terhadap aset informasi sensitif.

1.6 Manfaat Penelitian

1.6.1 Manfaat Akademis

Penelitian ini memberikan contoh nyata tentang cara mengintegrasikan kontrol *secure coding* ISO/IEC 27001:2022 ke dalam alur kerja transformasi kode otomatis [12], sesuatu yang belum dilakukan oleh penelitian-penelitian sebelumnya di bidang ini [6] [13] [16]. Selain itu, penelitian ini menghasilkan data empiris tentang performa model-model LLM *open source* lokal berukuran kecil hingga menengah dalam tugas analisis keamanan kode, yang relevan bagi institusi dengan sumber daya komputasi terbatas.

Desain modular *platform* memungkinkan pengembangan lebih lanjut oleh peneliti lain, misalnya dengan mengganti alat transformasi untuk mendukung bahasa pemrograman lain, menggunakan model AI yang lebih baru, atau memperluas pemetaan ke standar keamanan lain selain ISO/IEC 27001:2022.

1.6.2 Manfaat Praktis

Platform yang dibangun memudahkan pemindahan aplikasi PHP lama, khususnya bagi organisasi yang tidak memiliki banyak sumber daya pengembangan. Pemeriksaan kepatuhan keamanan disertakan langsung dalam proses migrasi [12], sehingga kerentanan dapat ditemukan bersamaan dengan konversi dan laporan kepatuhan dihasilkan secara otomatis. Dukungan versi target dari PHP 5.2 hingga PHP 8.x

mengakomodasi berbagai strategi migrasi, baik yang bertahap maupun yang langsung. Seluruh *platform* bersifat *open source* dan dapat digunakan secara gratis.

1.7 Sistematika Penulisan

Skripsi ini terdiri dari lima bab.

Bab I: Pendahuluan memaparkan latar belakang masalah, rumusan masalah, tujuan penelitian, batasan penelitian, keamanan dan privasi data, manfaat penelitian, dan sistematika penulisan.

Bab II: Tinjauan Pustaka dan Landasan Teoritis membahas penelitian-penelitian sebelumnya yang relevan dan kerangka teoritis, mencakup perubahan versi PHP, standar ISO/IEC 27001:2022, metodologi *secure coding*, analisis kode berbasis LLM, serta alat-alat yang digunakan: Rector, Semgrep, PHPStan, dan Ollama.

Bab III: Metodologi Penelitian menjelaskan arsitektur sistem, tahapan penelitian, desain *prompt* LLM, pemetaan kontrol ISO/IEC 27001:2022, rancangan eksperimen komparasi model, serta metode pengujian dan evaluasi.

Bab IV: Hasil dan Diskusi menyajikan hasil implementasi *pipeline* pada dua studi kasus (FT UGM dan CBT DTI UGM), mencakup tingkat keberhasilan konversi, perbandingan temuan keamanan sebelum dan sesudah konversi, hasil komparasi lima model LLM, dan diskusi mengenai kekuatan dan keterbatasan sistem.

Bab V: Kesimpulan dan Rekomendasi merangkum temuan berdasarkan tujuan yang ditetapkan dan memberikan saran untuk penelitian berikutnya.

BAB II

TINJAUAN PUSTAKA DAN DASAR TEORI

2.1 Tinjauan Literatur

Bagian ini membahas penelitian-penelitian sebelumnya yang relevan dengan tiga fokus utama studi ini: analisis keamanan otomatis pada aplikasi PHP, deteksi kerentanan berbasis LLM, dan transformasi kode yang melibatkan LLM. Masing-masing karya dibahas dari sisi masalah yang diatasi, kontribusinya, dan keterbatasannya. Bagian ini ditutup dengan tabel perbandingan yang memperlihatkan posisi penelitian ini di antara karya-karya tersebut.

2.1.1 Perlindungan Otomatis Aplikasi PHP dari Injeksi SQL

Merlo, Letarte, dan Antoniol [6] pada 2007 sudah menunjukkan bahwa analisis keamanan dan perbaikan kode PHP dapat diotomatisasi. Pendekatan mereka menggabungkan analisis statis, analisis dinamis, dan rekayasa ulang kode untuk melindungi aplikasi PHP lama dari injeksi SQL tanpa mengubah fungsionalitasnya. Caranya adalah dengan mengekstrak penjaga berbasis model dari kasus uji tepercaya, lalu secara otomatis menyisipkannya ke titik-titik akses basis data dalam kode sumber.

Hasilnya cukup kuat: pengujian pada phpBB versi 2.0.0 (37.193 baris kode PHP 4.2.2) berhasil menghentikan semua 176 serangan injeksi yang diuji tanpa satu pun *false positive*. Namun, pendekatan ini memiliki keterbatasan. Kualitas perlindungan sepenuhnya bergantung pada kelengkapan rangkaian pengujian yang digunakan selama fase analisis dinamis. Titik akses yang tidak tercakup pengujian tidak terlindungi.

Relevansi karya ini terhadap penelitian saat ini tidak terletak pada aspek teknisnya, melainkan pada konfirmasi bahwa otomatisasi analisis keamanan dan remediasi kode PHP dalam skala besar memang dapat dilakukan. Fakta bahwa studi ini sudah muncul hampir dua dekade lalu, namun solusi komprehensif yang bekerja dengan standar keamanan modern masih belum ada, justru mempertegas kesenjangan yang ingin diisi oleh penelitian ini.

2.1.2 Menggunakan LLM untuk Menemukan dan Memantau Kerentanan

Akuthota dkk. [13] meneliti kemampuan GPT-3.5-Turbo untuk deteksi dan pemantauan kerentanan perangkat lunak. Pendekatannya murni berbasis *prompt engineering* tanpa pelatihan ulang model sama sekali. Model berhasil menemukan pola kerentanan yang umum, meskipun akurasinya menurun seiring meningkatnya kompleksitas pola yang dicari.

Li et al. [14] mengambil pendekatan yang lebih terstruktur. Mereka menggabungkan analisis *patch* historis dengan analisis statis, lalu menambahkan tabel fitur kerentanan dan templat penganalisis untuk membuat klasifikasi LLM lebih akurat, terutama pada kerentanan yang membutuhkan pemahaman aliran data lintas fungsi. Evaluasi pada *dataset* CVE kernel Linux memperlihatkan hasil yang lebih baik dibandingkan analisis statis saja.

Terdapat dua temuan penting yang dapat ditarik dari kedua studi tersebut. LLM tujuan umum sudah bisa menemukan pola kerentanan hanya dengan *prompt engineering*, dan penggabungan LLM dengan analisis statis terstruktur memberikan hasil yang lebih akurat untuk kasus yang kompleks. Hambatan yang sama muncul di keduanya: model dijalankan via API *cloud*, yang menjadi kendala nyata ketika kode yang dianalisis bersifat rahasia. Penelitian ini mengatasi kendala tersebut dengan menjalankan semua model secara lokal melalui Ollama, sehingga tidak ada kode sumber yang keluar dari lingkungan organisasi.

2.1.3 Transformasi Kode dengan Bantuan LLM

Stümpfle dkk. [16] mengusulkan pendekatan untuk mengubah varian perangkat lunak yang dikloning menjadi *Software Product Line* (SPL) menggunakan LLM. Metodenya bekerja dalam tiga tahap: penyaringan titik variasi untuk menemukan perbedaan kode yang relevan secara semantik antar varian, rekayasa *prompt* untuk menghasilkan artefak SPL yang benar, dan *loop* umpan balik penyempurnaan diri yang mengirimkan hasil pengujian kembali ke model secara berulang hingga kode lolos kompilasi dan pengujian fungsional. *Loop* umpan balik ini terbukti secara signifikan mengurangi kegagalan akibat halusinasi model, meskipun efektivitasnya tetap bergantung pada kualitas langkah penyaringan awal.

Baik Stümpfle et al. maupun penelitian ini menggunakan LLM untuk transformasi kode yang melampaui substitusi sintaksis dan membutuhkan pemahaman semantik. *Loop* umpan balik dalam Stümpfle dkk. memiliki fungsi konseptual yang mirip dengan peran validasi PHPStan dalam *pipeline* penelitian ini: keduanya menggunakan *output* alat analisis statis untuk memverifikasi apakah transformasi berhasil. Perbedaan utamanya terletak pada fokus: Stümpfle et al. menangani ekstraksi fitur lintas varian untuk rekayasa lini produk, sedangkan penelitian ini berfokus pada migrasi versi dan verifikasi kepatuhan keamanan untuk kode warisan dalam satu bahasa.

2.1.4 Pendekatan Neuro-Simbolik untuk Deteksi Kerentanan Keamanan

Li, Dutta, dan Naik [15] memperkenalkan IRIS, sistem yang menggabungkan LLM dengan analisis statis untuk deteksi kerentanan pada tingkat seluruh repositori. Masalah yang diangkat cukup spesifik: alat analisis statis tradisional seperti CodeQL

sangat bergantung pada spesifikasi *taint* yang dibuat manual, dan spesifikasi ini hampir pasti tidak lengkap karena jumlah API pihak ketiga terus bertambah. LLM juga tidak bisa berjalan sendiri karena tidak mampu melakukan penalaran yang mencakup keseluruhan aliran kode dalam proyek berskala besar.

Solusi IRIS adalah membiarkan LLM menghasilkan spesifikasi *taint* secara otomatis berdasarkan pemahaman kontekstual terhadap API yang relevan, lalu menyerahkan analisis jalur ke alat analisis statis yang sudah ada. Pada *dataset* CWE-Bench-Java yang terdiri dari 120 kerentanan yang divalidasi secara manual, IRIS dengan GPT-4 berhasil mendeteksi 55 kerentanan dibandingkan hanya 27 oleh CodeQL saja, sekaligus menurunkan rata-rata *false positive* sebesar 5,21 poin persentase.

Hasil ini menjadi dasar empiris pemilihan pendekatan gabungan dalam penelitian ini. Perbedaan utamanya adalah IRIS mengandalkan GPT-4 via *cloud* dan hanya diuji pada Java. Penelitian ini mengambil pendekatan konseptual yang serupa, tetapi dengan model lokal melalui Ollama dan menargetkan PHP.

2.1.5 Dampak Jangka Panjang Transformasi Kode Otomatis

Strobl dkk. [11] menganalisis tiga kasus transformasi kode otomatis skala besar di sebuah organisasi pemerintah Austria, semuanya melibatkan konversi sistem warisan dari COBOL dan PL/I ke Java dengan ukuran lebih dari satu juta baris kode. Fokus utama studi ini bukan pada keberhasilan transformasi, melainkan pada dampak pascatransformasi.

Hasil studi tersebut mengungkapkan permasalahan yang signifikan. Transformasi otomatis seringkali menghasilkan kode yang sintaksis valid di bahasa target, tapi mempertahankan karakteristik struktural dari bahasa sumber sehingga sulit dipahami pengembang yang tidak kenal sistem lama. Lebih lanjut, kasus yang memiliki *test suite* otomatis sejak awal jauh lebih mudah dirawat pascatransformasi. Kasus tanpa pengujian otomatis menjadi beban jangka panjang.

Temuan ini menjadi alasan mengapa penelitian ini menyertakan PHPStan sebagai validasi pasca-konversi dan Semgrep sebagai pemindaian keamanan sebelum dan sesudah transformasi. Masalah yang ditinggalkan oleh konversi otomatis perlu terdeteksi segera, bukan bertahun-tahun kemudian.

2.1.6 Transformasi Kode Berbasis Pola untuk Migrasi Aplikasi

Cai et al. [23] mengusulkan pendekatan transformasi kode berbasis pola untuk migrasi aplikasi ke lingkungan *cloud*. Prosesnya iteratif: pemindaian kode untuk mengidentifikasi blok yang perlu diubah, pencocokan pola menggunakan ekspresi reguler yang diperluas, perancangan templat untuk kode target, lalu eksekusi

aturan transformasi. Pendekatan ini diuji pada 19 proyek *open source* Java dengan memigrasikannya ke Amazon Web Services (AWS).

Kontribusinya jelas: transformasi berbasis pola terbukti bisa mengurangi pekerjaan manual berulang pada migrasi skala besar. Namun, terdapat keterbatasan mendasar pada pendekatan tersebut. Ekspresi reguler yang diperluas tetap beroperasi pada level teks, bukan pada representasi struktural kode. Hasil ini membuatnya rentan gagal pada konstruksi kode yang kompleks atau tidak mengikuti pola yang telah didefinisikan sebelumnya.

Rector [7] bekerja pada AST, bukan teks, sehingga transformasinya lebih dapat diandalkan untuk kode produksi yang beragam. Selain itu, Cai et al. [23] tidak menyertakan aspek keamanan atau kepatuhan standar sama sekali dalam pendekatan mereka. Perbedaan ini mencerminkan bagaimana kebutuhan dalam transformasi kode otomatis telah berkembang: dari sekadar memindahkan kode ke lingkungan baru, menjadi memastikan kode yang dipindahkan juga aman.

2.1.7 Migrasi Kode Berbasis AST pada Skala Industri

Chen et al. [8] mendokumentasikan penerapan migrasi kode berbasis AST pada skala produksi di Microsoft. Pendekatan mereka menggunakan penggantian simbol berbasis AST untuk memigrasikan basis kode TypeScript berskala besar secara otomatis. Kunci dari pendekatan ini adalah bahwa transformasi dilakukan pada tingkat pohon sintaksis, bukan teks, sehingga menghasilkan perubahan yang struktural konsisten dan tidak bergantung pada gaya penulisan kode masing-masing pengembang.

Signifikansi studi ini terletak pada validasi skalabilitasnya, bukan pada inovasi radikal. Dengan membuktikan bahwa transformasi berbasis AST bisa dijalankan pada jutaan baris kode produksi tanpa regresi fungsional yang signifikan, Chen et al. mengkonfirmasi bahwa pilihan teknis yang sama yang mendasari Rector layak diandalkan dalam konteks institusional nyata.

Ada dua perbedaan konteks penting. Pertama, migrasi yang dilakukan Chen et al. adalah TypeScript ke TypeScript (*refactoring* dalam bahasa yang sama), sedangkan penelitian ini berhadapan dengan *breaking changes* antar versi PHP yang melibatkan penghapusan API dan perubahan sistem tipe. Kedua, seperti halnya Cai et al. [23], studi ini tidak menyentuh aspek keamanan sama sekali. Temuan keamanan yang muncul selama atau setelah migrasi bukan bagian dari cakupan mereka.

2.1.8 Ringkasan Perbandingan

Tabel 2.1. Perbandingan Penelitian Terdahulu dan Karakteristik Penelitian

Studi	Bahasa	AI/LLM Digunakan	Tugas Utama
Merlo et al. [6]	PHP	Tidak ada	<i>Security remediation</i>
Akuthota et al. [13]	<i>Multiple</i>	GPT-3.5-Turbo	<i>Vulnerability detection</i>
Li et al. [14]	C (Linux kernel)	LLM + analisis statis	<i>Vulnerability detection</i>
Stümpfle et al. [16]	C/C++	LLM	<i>Code transformation</i>
Li, Dutta & Naik [15]	Java	GPT-4	<i>Vulnerability detection</i>
Strobl et al. [11]	COBOL/PL/I	Tidak ada	<i>Code transformation</i>
Cai et al. [23]	Java	Tidak ada	<i>Cloud migration</i>
Chen et al. [8]	TypeScript	Tidak ada	<i>Code migration (AST)</i>
Penelitian ini	PHP	Membandingkan 5 LLM lokal dan memilih AI terbaik untuk migrasi PHP	Migrasi versi + <i>security compliance</i>

Tabel 2.2. Perbandingan Penelitian Terdahulu dan Aspek Metodologi

Studi	<i>Deployment</i>	Validasi Pasca-Konversi	Standar Keamanan	<i>Open Source</i>
Merlo et al. [6]	N/A	Tidak	Tidak ada	Ya
Akuthota et al. [13]	<i>Cloud</i>	Tidak	Tidak ada	Tidak
Li et al. [14]	<i>Cloud</i>	Tidak	Tidak ada	Tidak

(bersambung ke halaman berikutnya)

(lanjutan Tabel 2.2)

Studi	<i>Deployment</i>	Validasi Pasca-Konversi	Standar Keamanan	<i>Open Source</i>
Stümpfle et al. [16]	<i>Cloud</i>	Ya (<i>feedback loop</i>)	Tidak ada	Tidak
Li, Dutta & Naik [15]	<i>Cloud</i>	Tidak	Tidak ada	Ya (IRIS)
Strobl et al. [11]	N/A	Tidak	Tidak ada	Tidak
Cai et al. [23]	N/A	Tidak	Tidak ada	Tidak
Chen et al. [8]	N/A	Tidak	Tidak ada	Tidak
Penelitian ini	Lokal (Ollama)	Ya (PHPStan + Semgrep)	ISO/IEC 27001:2022	Ya

Kedua tabel memperlihatkan kesenjangan yang konsisten. Studi-studi yang berfokus pada keamanan tidak menangani migrasi versi. Studi-studi yang berfokus pada transformasi kode, termasuk yang sudah terbukti di skala industri seperti Chen et al. [8] tidak menyertakan pemeriksaan keamanan maupun pemetaan ke standar formal. Tidak satu pun dari kedelapan studi yang menggabungkan migrasi versi PHP, analisis keamanan berbasis LLM, validasi pasca-konversi, dan kepatuhan ISO/IEC 27001:2022 dalam satu alur kerja *open source* dengan *deployment* lokal. Kombinasi inilah yang menjadi kontribusi utama penelitian ini.

2.2 Dasar Teori

2.2.1 PHP dan Perubahan Antar Versi

PHP (*Hypertext Preprocessor*) menjadi bahasa skrip sisi *server* yang paling banyak digunakan di web sejak akhir 1990-an [1]. W3Techs mencatat bahwa 71,7% dari seluruh situs web yang memiliki bahasa pemrograman sisi *server* menggunakan PHP [2].

Untuk memahami tantangan migrasi yang dihadapi kode lama, perlu dipahami dulu karakteristik PHP 5.x yang masih banyak ditemukan di sistem yang belum bermigrasi. PHP 5.x, aktif digunakan dari sekitar 2004 hingga awal 2010-an, memiliki karakteristik yang berbeda secara fundamental dari versi modern. Yang paling signifikan adalah ekstensi `ext/mysql` dengan fungsi-fungsi seperti `mysql_connect()`, `mysql_query()`, dan `mysql_fetch_array()`. Fungsi-fungsi ini tidak mendukung *prepared statements* secara asli, sehingga rentan terhadap injeksi SQL jika *input* pengguna tidak disanitasi secara manual. Ekstensi ini sudah dinyatakan *deprecated* sejak PHP 5.5 dan dihapus sepenuhnya di PHP 7.0 [3]. PHP 5.x juga

menggunakan kata kunci `var` untuk deklarasi properti kelas, sintaks `array()` yang panjang, dan belum mendukung *type hints* skalar. Rector dapat menangani sebagian besar transformasi sintaksis dari PHP 5.x melalui *ruleset* kumulatifnya [7], namun penggantian `mysql_*()` tidak dapat dilakukan oleh Rector karena membutuhkan pemahaman semantik tentang konteks penggunaan basis data. Keterbatasan inilah yang secara langsung memotivasi kehadiran AI Engine dalam *pipeline* penelitian ini.

PHP 7.x membawa peningkatan performa signifikan lewat Zend Engine 3.0, menambahkan deklarasi tipe skalar, petunjuk tipe pengembalian, dan operator penggabungan *null*. PHP 7.4, versi terakhir seri ini, menambahkan properti bertipe dan fungsi panah sebelum dukungan resminya berakhir 28 November 2022 [3].

PHP 8.x membuat sejumlah *breaking changes* yang membuat kode PHP 7.x tidak bisa langsung dijalankan [3]. Selain penghapusan fungsi-fungsi yang sudah *deprecated*, sistem tipe menjadi jauh lebih ketat dengan tipe *union* dan tipe campuran. Fitur baru seperti *match expression*, operator *nullsafe* (`?->`), argumen bernama, dan kompilasi JIT diperkenalkan. Penanganan kesalahan juga berubah: beberapa fungsi yang sebelumnya mengembalikan *false* kini melempar pengecualian. Untuk basis kode besar, melakukan semua perubahan ini secara manual jelas tidak realistis.

2.2.2 ISO/IEC 27001:2022 dan Secure Coding

ISO/IEC 27001:2022 adalah standar internasional untuk Sistem Manajemen Keamanan Informasi (ISMS) yang dikembangkan bersama oleh ISO dan IEC [12]. Standar ini menetapkan persyaratan untuk membuat, menerapkan, memelihara, dan terus meningkatkan ISMS dalam suatu organisasi. Annex A memuat 93 kontrol keamanan yang dibagi ke dalam empat domain: Organisasi, Manusia, Fisik, dan Teknologi. Dari 93 kontrol tersebut, penelitian ini hanya memetakan yang langsung relevan dengan pengembangan perangkat lunak:

- **A.8.25** (*Secure development lifecycle*) mengharuskan aturan pengembangan yang aman ditetapkan dan diikuti di setiap tahap, termasuk penggunaan pedoman *secure coding* dan alat analisis statis.
- **A.8.28** (*Secure coding*) mengharuskan aturan pengkodean yang aman diikuti untuk mencegah kerentanan umum seperti injeksi, autentikasi yang rusak, pengungkapan data sensitif, dan kriptografi yang tidak aman.
- **A.8.29** (Pengujian keamanan dalam pengembangan dan penerimaan) mengharuskan pengujian keamanan menjadi bagian dari proses pengembangan sebelum kode masuk produksi.

Ketiga kontrol ini, bersama A.5.17, A.8.24, dan A.8.26 yang turut dipetakan oleh

pipeline, menjadi acuan resmi untuk mesin pengecekan keamanan dalam penelitian ini [12]. Aturan Semgrep yang digunakan berhubungan langsung dengan A.8.28 dan A.8.29. Struktur *pipeline* secara keseluruhan mencerminkan kebutuhan siklus hidup A.8.25.

2.2.3 OWASP Top 10 dan Kerentanan Aplikasi Web PHP

OWASP Top 10 adalah referensi standar untuk risiko keamanan paling kritis pada aplikasi web yang diterbitkan secara berkala oleh OWASP berdasarkan data dari ratusan organisasi di seluruh dunia [5]. Versi terbaru, OWASP Top 10:2021, relevan langsung dengan kondisi aplikasi PHP lama.

Injeksi menempati posisi ketiga dan merupakan temuan paling umum pada kode PHP lama [5]. Injeksi SQL sering muncul dari penggunaan `mysql_query()` tanpa parameterisasi. XSS juga termasuk kategori injeksi dan terjadi saat *output* tidak dieksekusi sebelum ditampilkan ke peramban. Kegagalan kriptografi, yang berada di posisi kedua, kerap muncul dalam praktik penyimpanan kata sandi menggunakan `md5()` atau `sha1()`, padahal keduanya sudah lama tidak dianggap aman.

Dalam penelitian ini, Semgrep dijalankan dengan *ruleset* `p/php` dan `p/owasp-top-ten` [9], yang secara langsung dipetakan ke kategori-kategori dalam OWASP Top 10:2021. Temuan Semgrep kemudian dipetakan ke kontrol ISO/IEC 27001:2022 yang relevan melalui skrip `iso_mapper.py`.

2.2.4 DevSecOps dan Integrasi Keamanan dalam *Pipeline* Pengembangan

DevSecOps adalah praktik yang mengintegrasikan keamanan ke dalam setiap tahap pengembangan perangkat lunak [14]. Pendekatan tradisional menempatkan pengujian keamanan sebagai langkah terpisah di akhir proses, dengan tim keamanan yang baru bekerja setelah kode selesai. Sebaliknya, DevSecOps mengintegrasikan keamanan sebagai bagian dari setiap keputusan teknis selama pengembangan berlangsung.

Dalam praktiknya, DevSecOps diwujudkan melalui integrasi alat keamanan otomatis ke dalam *pipeline*: analisis statis kode sumber (SAST), pemindaian dependensi, dan pengujian keamanan dinamis. Kerentanan yang ditemukan lebih awal jauh lebih murah untuk diperbaiki dibandingkan yang baru ditemukan setelah sistem berjalan di produksi.

Pipeline dalam penelitian ini menerapkan prinsip DevSecOps secara langsung: Semgrep memindai sebelum dan sesudah konversi, PHPStan memvalidasi kompatibilitas kode, dan AI Engine menangani kasus yang butuh analisis semantik. Keamanan bukan langkah audit terpisah, tapi bagian dari proses migrasi itu sendiri [12].

2.2.5 Metodologi *Research and Development* dengan Model Prototipe

Metodologi *Research and Development* (R&D) adalah pendekatan penelitian yang menghasilkan produk atau sistem yang dapat diuji dan divalidasi secara empiris, bukan sekadar analisis teoritis. Model prototipe adalah salah satu pendekatan dalam R&D di mana sistem dibangun dalam versi awal, diuji, lalu diperbaiki berdasarkan hasil pengujian secara berulang hingga mencapai kondisi yang stabil [24]. Pendekatan ini sesuai untuk sistem yang keputusan desainnya bergantung pada perilaku komponen eksternal yang sulit diprediksi di awal, seperti respons model LLM terhadap format *prompt* tertentu atau cara Rector menangani pola kode yang tidak biasa.

2.2.6 *Abstract Syntax Trees* dan *Static Analysis*

Analisis statis adalah teknik pemeriksaan kode sumber tanpa menjalankan program. Dalam konteks keamanan perangkat lunak, teknik ini digunakan untuk mengidentifikasi pola kerentanan, praktik pengkodean tidak aman, dan pelanggaran kebijakan secara otomatis. Analisis statis sudah menjadi bagian standar dari *pipeline* DevSecOps modern karena bisa dijalankan terus-menerus selama pengembangan tanpa beban tambahan yang signifikan [14].

Abstract Syntax Trees (AST) adalah representasi pohon dari kode sumber di mana setiap *node* mewakili konstruksi sintaksis seperti ekspresi, pernyataan, atau deklarasi. Alat yang bekerja dengan AST bisa menganalisis dan mengubah kode secara struktural, berbeda dari pendekatan berbasis teks biasa yang digunakan oleh Cai et al. [23]. Rector menggunakan PHP AST untuk menemukan pola yang perlu diubah dan menghasilkan kode penggantinya. Chen et al. [8] mendemonstrasikan bahwa pendekatan berbasis AST bukan sekadar teori; mereka menerapkannya untuk migrasi kode TypeScript di Microsoft pada skala produksi.

2.2.7 Rector: Alat Transformasi Kode Berbasis AST

Rector adalah alat *open source* untuk transformasi kode PHP berbasis AST [7]. Prosesnya: kode sumber PHP diubah menjadi AST, aturan transformasi diterapkan, lalu kode PHP baru dihasilkan dari pohon yang sudah dimodifikasi. Rector dilengkapi aturan bawaan untuk berpindah antar versi PHP, termasuk `LevelSetList::UP_TO_PHP_80` hingga `UP_TO_PHP_85`, dan *ruleset*-nya bersifat kumulatif sehingga mencakup semua perubahan dari versi sumber hingga versi target.

Dalam penelitian ini, Rector berperan sebagai mesin transformasi utama. Transformasi sintaksis dan struktural dari PHP 5.x atau 7.x ke PHP 8.x ditangani sepenuhnya oleh Rector. Transformasi ekstensi `ext/mysql` tidak dapat ditangani

karena membutuhkan penulisan ulang semantik, bukan sekadar penggantian sintaks. Oleh karena itu, tugas tersebut didelegasikan kepada AI Engine.

2.2.8 PHPStan: Alat Analisis Statis untuk PHP

PHPStan adalah alat analisis statis untuk PHP yang memeriksa kebenaran tipe data, konsistensi pemanggilan fungsi, dan kesalahan logika tanpa menjalankan program [10]. Berbeda dari Semgrep yang mencari pola kerentanan keamanan, PHPStan fokus pada integritas kode dari sisi kompatibilitas dan tipe.

PHPStan bekerja dengan sistem level 0–9, di mana level lebih tinggi berarti pemeriksaan lebih ketat. Dalam *pipeline* penelitian ini, PHPStan digunakan pada level 5 sebagai komponen validasi pasca-konversi. Setelah Rector selesai, PHPStan memeriksa apakah kode hasil konversi kompatibel dengan versi PHP target dan bebas dari kesalahan tipe. Perannya mendukung kontrol A.8.29 ISO/IEC 27001:2022 [12] dengan memastikan kode yang dihasilkan secara otomatis tidak mengandung kesalahan yang bisa memengaruhi keandalan sebelum masuk produksi.

2.2.9 Semgrep: Alat Analisis Statis Ringan untuk Keamanan

Semgrep adalah alat analisis statis ringan yang mendukung lebih dari 30 bahasa pemrograman, termasuk PHP [9]. Aturan keamanannya ditulis dalam format YAML dengan sintaks yang mirip dengan kode sumber yang dianalisis, sehingga pengguna bisa membuat aturan sendiri tanpa perlu memahami detail AST bahasa target. Registri aturan publiknya mencakup berbagai kerentanan umum seperti injeksi SQL, XSS, kriptografi lemah, dan deserialisasi tidak aman.

Dalam penelitian ini, Semgrep digunakan dua kali: sebelum konversi untuk menetapkan *baseline* keamanan kode asli, dan sesudah konversi untuk memastikan tidak ada kerentanan baru yang muncul. Kedua pemindaian ini mendukung kontrol A.8.28 dan A.8.29 ISO/IEC 27001:2022 [12].

2.2.10 Model-Model LLM untuk Analisis Kode

LLM (*Large Language Model*) adalah model bahasa neural berbasis *transformer* yang dilatih pada data teks dan kode dalam jumlah besar. LLM yang dilatih pada kode bisa memahami semantik kode, mengidentifikasi pola kerentanan, menyarankan perbaikan, dan menghasilkan kode baru [13]. Kemampuan ini berbeda dari analisis berbasis aturan: LLM mempertimbangkan konteks dan tujuan kode, bukan hanya strukturnya.

Penelitian ini mengevaluasi lima model LLM *open source* yang dijalankan secara lokal. Kriteria pemilihan ada dua: model harus bisa dijalankan di GPU dengan VRAM

8 GB menggunakan kuantisasi Q4, dan harus memiliki kemampuan pemahaman kode yang terdokumentasi dalam literatur ilmiah.

DeepSeek Coder 6.7b [17] memiliki 6,7 miliar parameter dan dilatih pada 2 triliun token dengan komposisi 87% kode sumber dari lebih dari 80 bahasa pemrograman.

Qwen2.5-Coder 7b [18] adalah model kode dari Alibaba dengan 7 miliar parameter, dilatih pada 5,5 triliun token kode, dan menunjukkan kemampuan yang kuat pada penyelesaian kode dan perbaikan *bug*.

CodeLlama 7b [19] dikembangkan Meta AI berbasis Llama 2. Model ini mendukung konteks hingga 100 ribu token dan tersedia dalam varian *instruct* yang dioptimalkan untuk mengikuti instruksi.

Mistral 7b [20] adalah model tujuan umum dari Mistral AI yang menggunakan mekanisme *grouped-query attention* (GQA) dan *sliding window attention* (SWA), membuatnya efisien secara komputasi.

Llama 3.1 8b [21] adalah model 8 miliar parameter dari Meta AI yang dilatih pada lebih dari 15 triliun token multibahasa dengan peningkatan signifikan dalam kemampuan penalaran dibanding pendahulunya.

Li, Dutta, dan Naik [15] sudah menunjukkan bahwa kombinasi LLM dan analisis statis menghasilkan deteksi kerentanan yang lebih baik dari masing-masing yang berjalan sendiri. Perbandingan performa kelima model di atas dalam konteks analisis keamanan kode PHP akan dibahas secara empiris di Bab IV.

2.2.11 Metrik Evaluasi Kualitas Keluaran LLM

Evaluasi kualitas keluaran model LLM pada tugas pemrograman memerlukan metrik yang dapat diverifikasi secara otomatis dan objektif. Dua dimensi utama yang digunakan dalam literatur adalah kemampuan mengikuti instruksi format dan kemampuan menghasilkan kode yang valid secara sintaksis.

Pass@k adalah metrik standar untuk mengukur kualitas kode yang dihasilkan LLM [19] [18]. Metrik ini mengukur probabilitas bahwa setidaknya satu dari k sampel kode yang dihasilkan model dapat lulus serangkaian pengujian. Pada nilai $k = 1$ dengan *greedy decoding*, $\text{pass}@1$ mengukur persentase percobaan yang menghasilkan solusi yang berhasil melewati pengujian dari total percobaan.

Instruction-following evaluation mengukur sejauh mana model mematuhi instruksi format yang diberikan dalam *prompt*, terlepas dari kualitas konten yang dihasilkan. Zhou dkk. [25] memperkenalkan IFEval yang mendefinisikan *prompt-level strict-accuracy* sebagai persentase *prompt* di mana seluruh instruksi yang dapat diverifikasi terpenuhi sekaligus. Pendekatan ini bersifat *all-or-nothing*: respons yang

hanya memenuhi sebagian instruksi tidak dihitung sebagai patuh.

Penelitian ini mengadaptasi kedua konsep tersebut ke dalam empat metrik formal yang disesuaikan dengan konteks migrasi PHP dan analisis keamanan.

Tingkat Konversi Rector (*Conversion Rate*, CR) mengukur persentase *file* PHP yang berhasil dikonversi oleh Rector:

$$CR = \frac{f_{success}}{f_{total}} \times 100\% \quad (2-1)$$

di mana $f_{success}$ adalah jumlah *file* yang berhasil dikonversi dan f_{total} adalah total *file* PHP dalam direktori `input/`.

Format Compliance Rate (FCR) mengadaptasi konsep *prompt-level strict-accuracy* dari IFEval [25] untuk mengukur persentase respons model yang memenuhi ketiga elemen format *prompt* sekaligus:

$$FCR = \frac{r_{compliant}}{r_{total}} \times 100\% \quad (2-2)$$

di mana $r_{compliant}$ adalah jumlah respons yang patuh format dan r_{total} adalah total percobaan per model. Metrik ini mencerminkan kemampuan model mengikuti instruksi, bukan kualitas kodenya.

Syntax Validity Rate (SVR) mengadaptasi konsep `pass@1` [19] [18] untuk mengukur persentase blok kode PHP yang diekstraksi dan lolos `php -l`:

$$SVR = \frac{c_{valid}}{c_{extracted}} \times 100\% \quad (2-3)$$

di mana c_{valid} adalah jumlah blok kode yang lolos pemeriksaan sintaks dan $c_{extracted}$ adalah total blok kode yang berhasil diekstraksi dari respons model. Hasil ini adalah metrik primer karena hasilnya konkret dan dapat diverifikasi secara independen.

Security Finding Delta (ΔF) mengukur perubahan jumlah temuan keamanan antara *pre-scan* dan *post-scan*:

$$\Delta F = F_{post} - F_{pre} \quad (2-4)$$

Nilai $\Delta F < 0$ menunjukkan pengurangan temuan, $\Delta F = 0$ berarti tidak ada perubahan, dan $\Delta F > 0$ tidak otomatis diinterpretasikan sebagai regresi karena bisa mencerminkan kerentanan laten yang baru terlihat setelah transformasi kode. Selain keempat metrik di atas, penelitian ini juga mencatat **Mean Confidence Score** ($\bar{C}_m$) sebagai metrik sekunder yang mengukur rata-rata skor kepercayaan yang dilaporkan

sendiri oleh model m :

$$\bar{C}_m = \frac{1}{n} \sum_{i=1}^n c_i \quad (2-5)$$

Untuk mengukur konsistensi antar *run*, digunakan variansi:

$$\sigma_m^2 = \frac{1}{n} \sum_{i=1}^n (c_i - \bar{C}_m)^2 \quad (2-6)$$

di mana n adalah jumlah *run* dan c_i adalah skor kepercayaan pada *run* ke- i . Perlu dicatat bahwa $\bar{C}_m$ adalah metrik sekunder; model LLM berukuran kecil umumnya tidak terkalibrasi dengan baik dalam menilai *output* mereka sendiri [13, 15], sehingga skor ini tidak bisa dijadikan proksi kualitas kode. FCR dan SVR merupakan dua dimensi yang independen: model dapat mencapai FCR tinggi dengan SVR rendah, atau sebaliknya [25]. Hal ini didukung oleh evaluasi CodeIF yang menemukan bahwa kepatuhan LLM terhadap instruksi (terutama instruksi multi-konstrain) sering kali mengorbankan konsistensi dan validitas kode yang dihasilkan [26]. Implikasi dari pola ini dibahas di Bab IV.

2.2.12 Ollama: Menerapkan LLM Secara Lokal

Beberapa alternatif dengan fungsi serupa tersedia, di antaranya LM Studio [27] dan llama.cpp [28]. LM Studio menyediakan antarmuka grafis yang intuitif untuk menjalankan model secara lokal, namun tidak menyediakan API REST bawaan yang dapat dipanggil langsung dari skrip Python tanpa konfigurasi tambahan. llama.cpp adalah *backend* inferensi berperforma tinggi yang ditulis dalam C/C++ tanpa dependensi eksternal [28] dan menjadi dasar teknis Ollama, namun memerlukan kompilasi manual dan tidak memiliki lapisan manajemen model yang terintegrasi.

Ollama dipilih karena tiga alasan. Pertama, API REST-nya yang kompatibel dengan format OpenAI memungkinkan integrasi langsung ke skrip Python tanpa pustaka tambahan. Kedua, manajemen model dilakukan melalui satu perintah `ollama pull` tanpa konfigurasi manual, sehingga eksperimen dapat direproduksi dengan mudah di lingkungan lain. Ketiga, Ollama mendukung kuantisasi Q4_0 secara otomatis yang memungkinkan model berukuran 6–8 miliar parameter berjalan dalam VRAM 8 GB tanpa pengaturan tambahan.

BAB III

METODOLOGI PENELITIAN

Bab ini menjelaskan langkah-langkah yang diambil dalam penelitian ini untuk mencapai tujuan yang ditetapkan dalam Subbab 1.3. Cakupannya meliputi alat dan bahan yang digunakan, metode penelitian, arsitektur sistem, alur data *pipeline*, desain *prompt* LLM, pemetaan kontrol ISO/IEC 27001:2022, rancangan eksperimen komparasi model, dan metode evaluasi.

3.1 Alat dan Bahan Penelitian

3.1.1 Perangkat Keras

Seluruh proses pengembangan dan pengujian dalam penelitian ini dilakukan pada satu unit laptop HP Victus 16-r0xxx dengan spesifikasi sebagai berikut:

- Sistem operasi: Windows 11 Home Single Language 64-bit (Build 26200)
- Prosesor: Intel Core i7-13700HX, 24 inti logis, kecepatan dasar 2,1 GHz
- Memori: 16.384 MB RAM
- GPU diskrit: NVIDIA GeForce RTX 4060 dengan VRAM 8 GB
- GPU terintegrasi: Intel UHD Graphics
- Penyimpanan: NVMe SSD 1 TB

Kode sumber FT UGM dan DTI UGM bersifat rahasia dan tidak boleh dikirimkan ke layanan AI eksternal, sehingga seluruh komponen AI dalam *pipeline* ini dijalankan secara lokal melalui Ollama. RTX 4060 dengan VRAM 8 GB memungkinkan kelima model yang dievaluasi (masing-masing 6–8 miliar parameter) dimuat sepenuhnya ke GPU pada kuantisasi Q4_0, sehingga model dapat berjalan tanpa mengirimkan data ke luar lingkungan lokal.

3.1.2 Perangkat Lunak

- **Python 3.x:** Bahasa pemrograman utama untuk membangun *pipeline* yang menghubungkan semua modul. Dipilih karena kemudahannya memanggil perintah eksternal via *subprocess* dan ketersediaan pustaka `requests` untuk berkomunikasi dengan API Ollama.
- **Rector:** Alat transformasi kode berbasis AST untuk PHP, dikonfigurasi secara dinamis sesuai versi target yang dipilih.
- **Semgrep:** Alat analisis statis untuk pemindaian kerentanan. Dijalankan dengan *ruleset*

p/php dan p/owasp-top-ten.

- **PHPStan:** Alat analisis statis untuk validasi tipe dan kompatibilitas kode PHP, dijalankan pada level 5.
- **Ollama:** *Platform* untuk menjalankan LLM secara lokal, diakses via API REST di `localhost:11434`. Justifikasi pemilihan Ollama dibandingkan alternatif LM Studio dan llama.cpp dibahas pada Subbab 2.2.12. Secara teknis, Ollama memuat bobot model dalam format GGUF ke dalam VRAM GPU menggunakan *backend* llama.cpp. Pada RTX 4060 dengan VRAM 8 GB, kelima model yang diuji menghasilkan rata-rata 20–40 token per detik pada kuantisasi Q4_0. Ollama menyimpan model yang sudah dimuat di VRAM selama sesi aktif sehingga latensi *cold start* hanya terjadi sekali per sesi.
- **PHP 8.4.1:** Interpreter PHP untuk validasi sintaks menggunakan `php -l`.
- **Composer:** Manajer dependensi PHP untuk instalasi Rector dan PHPStan.
- **Visual Studio Code:** Sebagai IDE utama selama pengembangan.

3.1.3 Model LLM yang Dievaluasi

Lima model LLM *open source* dievaluasi dalam penelitian ini: DeepSeek Coder 6.7b, Qwen2.5-Coder 7b, CodeLlama 7b, Mistral 7b, dan Llama 3.1 8b. Kelima model dijalankan pada kuantisasi Q4_0 agar dapat dimuat ke dalam VRAM 8 GB. Rincian spesifikasi dan literatur pendukung masing-masing model telah diuraikan pada Subbab 2.2.10.

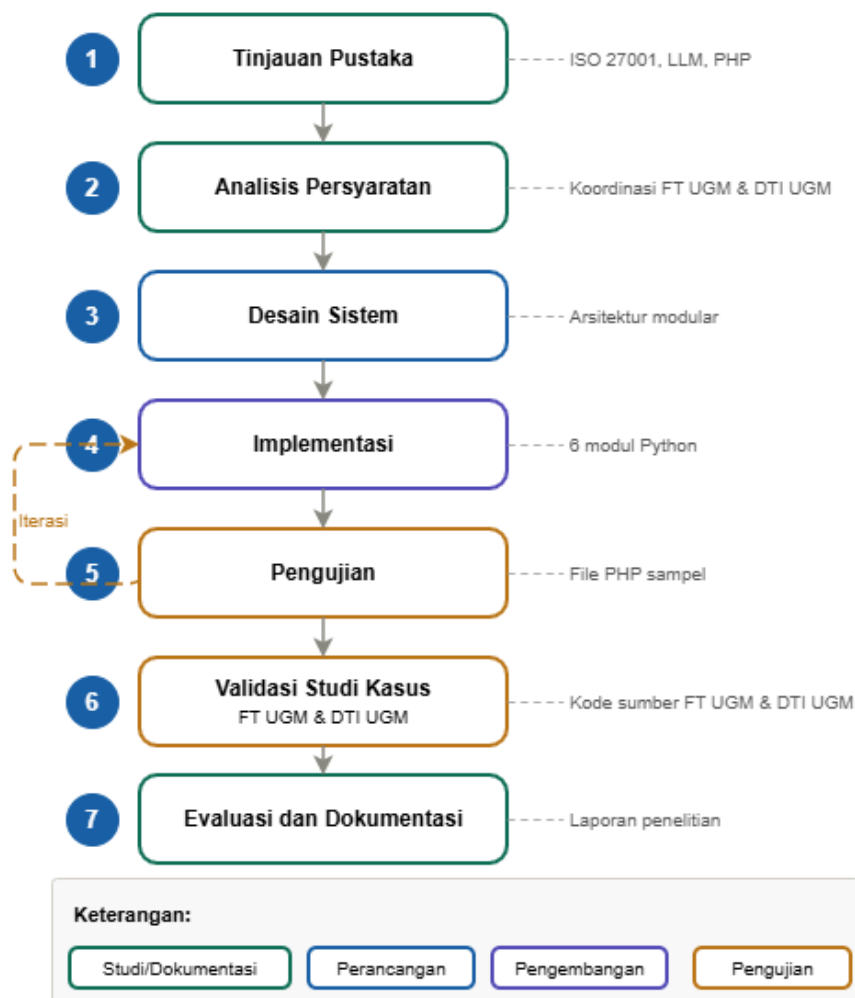
3.1.4 Bahan Penelitian

- **Dokumen ISO/IEC 27001:2022:** Acuan utama untuk pemetaan kontrol keamanan.
- **Kode sumber PHP dari FT UGM:** Kumpulan *file* PHP dari aplikasi *Dashboard* TCK berbasis CodeIgniter 3.x dengan PHP 7.4.9. Bersifat rahasia dan hanya digunakan untuk analisis statis tanpa akses ke basis data produksi.
- **Kode sumber PHP dari DTI UGM:** Kumpulan *file* PHP dari aplikasi *Computer-Based Test* (CBT) berbasis CodeIgniter 3.x dengan persyaratan PHP ≥ 7.0 . Bersifat rahasia dengan perlakuan privasi data yang sama dengan dataset FT UGM.
- **Dokumentasi resmi PHP:** Referensi untuk memverifikasi kebenaran konversi Rector.
- **Registri aturan Semgrep:** Aturan publik p/php dan p/owasp-top-ten untuk pemindaian keamanan.

3.2 Metode Penelitian

Penelitian ini menggunakan metodologi R&D dengan model prototipe sebagaimana diuraikan pada Subbab 2.2.5.

Pipeline otomasi yang dirancang dalam penelitian ini merupakan wujud konkret dari manajemen perangkat lunak dalam skala basis kode nyata: Rector menangani pembaruan versi PHP secara sistematis, sementara komponen AI Engine berbasis LLM merekomendasikan perbaikan kerentanan yang teridentifikasi. Kedua fungsi ini berjalan dalam satu alur terpadu yang dapat diterapkan ulang pada basis kode lain. Gambar 3.1 menunjukkan alur penelitian yang terdiri dari tujuh tahapan.



Gambar 3.1. Alur penelitian dengan model prototipe

1. **Tinjauan pustaka:** Mempelajari permasalahan migrasi PHP lama, persyaratan ISO/IEC 27001:2022, kemampuan model LLM *open source*, dan alat analisis statis yang relevan. Koordinasi awal dengan FT UGM dan DTI UGM dilakukan pada tahap ini.
2. **Analisis persyaratan:** Mendefinisikan persyaratan fungsional dan non-fungsional

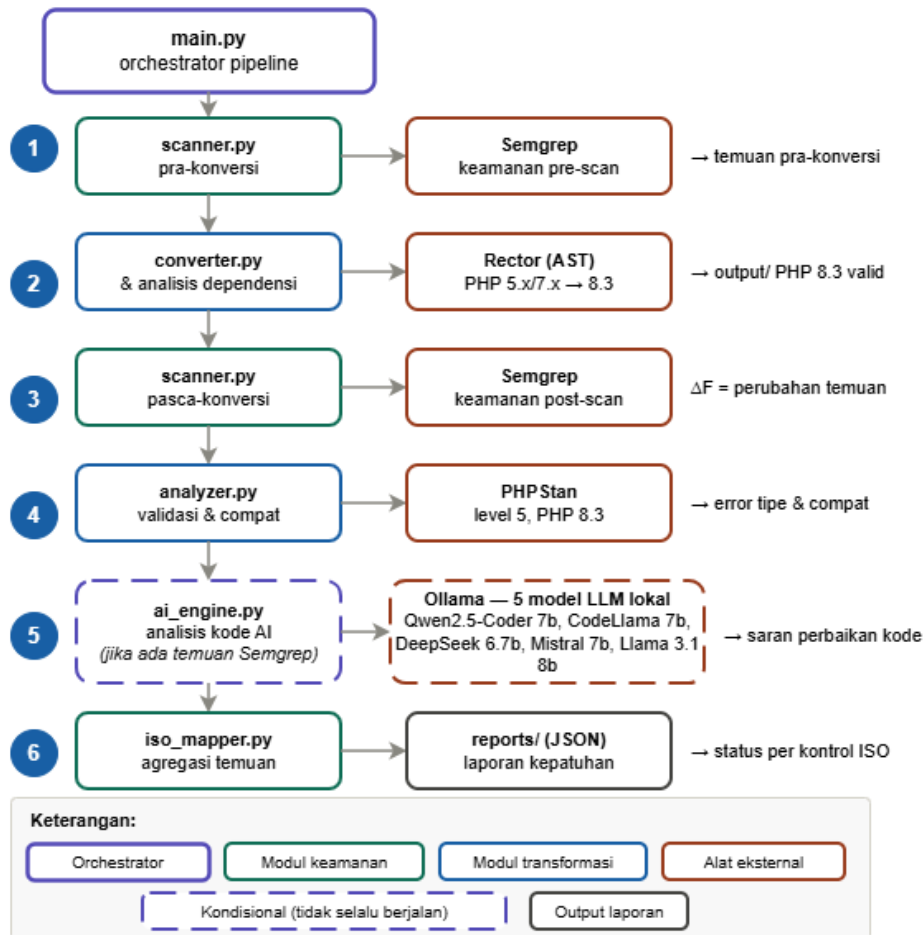
berdasarkan hasil tinjauan pustaka dan koordinasi dengan FT UGM dan DTI UGM, termasuk menentukan kontrol ISO yang dicakup dan persyaratan privasi data.

3. **Desain sistem:** Menentukan struktur enam modul *pipeline*, alur data antar modul, dan cara setiap modul saling berkomunikasi, termasuk merancang desain eksperimen komparasi LLM.
4. **Implementasi:** Membangun enam modul fungsional Python satu per satu, dikoordinasikan oleh `main.py` sebagai orkestrator. Setiap modul diuji secara terpisah sebelum diintegrasikan.
5. **Pengujian:** Menguji prototipe menggunakan *file* PHP buatan sendiri dan potongan kode representatif untuk memverifikasi setiap modul sebelum dijalankan pada dataset studi kasus. Jika ditemukan masalah, proses kembali ke tahap implementasi (iterasi).
6. **Validasi studi kasus:** Pengujian akhir menggunakan kode sumber FT UGM dan DTI UGM setelah prototipe stabil.
7. **Evaluasi dan dokumentasi:** Menganalisis hasil dan menyusun laporan penelitian.

3.3 Arsitektur Sistem

Sistem terdiri dari enam modul fungsional Python yang dikoordinasikan oleh `main.py` sebagai orkestrator yang masing-masing menangani satu langkah dalam proses konversi dan analisis keamanan. Arsitektur modular memungkinkan setiap bagian diuji, diperbaiki, atau diganti secara independen.

Gambar 3.2 menunjukkan hubungan antar modul.



Gambar 3.2. Arsitektur sistem *pipeline* dengan enam modul fungsional dan satu orkestrator

3.3.1 Scanner (scanner.py)

Modul pertama yang berjalan. Scanner menjalankan Semgrep pada direktori `input/` sebelum konversi dimulai untuk menetapkan *baseline* keamanan kode asli. Hasil pemindaian dikelompokkan berdasarkan jenis kerentanan (injeksi SQL, XSS, *path traversal*, injeksi perintah, fungsi usang, kriptografi lemah) dan diberi tingkat prioritas. Data ini menjadi pembanding untuk mengukur perubahan keamanan setelah konversi.

3.3.2 Converter (converter.py)

Modul ini menggunakan Rector untuk transformasi kode PHP berbasis AST. Argumen CLI `-target-php` menentukan versi target; nilai yang diterima adalah "7.4", "8.0", "8.1", "8.2", atau "8.3". Sebelum Rector dijalankan, seluruh *file* PHP dari `input/` disalin dahulu ke `output/`. Rector kemudian memodifikasi *file* di `output/` langsung tanpa membuat salinan baru. *File* yang gagal dikonversi tetap ada di `output/` sebagai salinan kode asli dan statusnya dicatat `FAILED` di laporan; direktori `input/` tidak dimodifikasi sama sekali. Konfigurasi Rector dibuat sebagai *tempfile* saat

runtime dan dihapus otomatis setelahnya.

Tabel 3.1. Pemetaan argumen `-target-php` ke konfigurasi Rector

Nilai <code>-target-php</code>	Chain <i>LevelSetList</i> yang diterapkan	Cakupan <i>rule</i> kumulatif
7.4	UP_TO_PHP_53 s.d. UP_TO_PHP_74	PHP 5.3, 5.4, 5.5, 5.6, 7.0, 7.1, 7.2, 7.3, 7.4
8.0	UP_TO_PHP_53 s.d. UP_TO_PHP_80	Semua <i>rule</i> 7.4 + PHP 8.0
8.1	UP_TO_PHP_53 s.d. UP_TO_PHP_81	Semua <i>rule</i> 8.0 + PHP 8.1
8.2	UP_TO_PHP_53 s.d. UP_TO_PHP_82	Semua <i>rule</i> 8.1 + PHP 8.2
8.3	UP_TO_PHP_53 s.d. UP_TO_PHP_83	Semua <i>rule</i> 8.2 + PHP 8.3

Target PHP 8.3 digunakan dalam penelitian ini. Selain *level sets* di atas, *pipeline* juga menambahkan `SetList::CODE_QUALITY`, `DEAD_CODE`, `EARLY_RETURN`, dan `TYPE_DECLARATION` untuk semua nilai target. Mengingat *ruleset* yang digunakan bersifat kumulatif, kode PHP 5.x dapat diproses langsung menuju PHP 8.3 dalam satu langkah. Jenis-jenis transformasi yang ditangani Rector dan keterbatasan Rector terhadap pola semantik seperti `mysql_*()` telah diuraikan pada Subbab 2.2.7.

3.3.3 Analyzer (analyzer.py)

Setelah konversi, Analyzer menjalankan PHPStan pada direktori `output/` untuk memverifikasi kompatibilitas kode dengan versi PHP target. Level 5 dipilih sebagai keseimbangan antara keketatan dan jumlah *false positive* yang wajar untuk kode warisan. Setiap temuan PHPStan dikategorikan sebagai ERROR atau WARNING, lalu dikaitkan dengan kontrol ISO/IEC 27001:2022 yang relevan.

3.3.4 AI Engine (ai_engine.py)

Modul ini menerima temuan dari Semgrep *pre-scan* sebagai masukan, bukan dari PHPStan dan bukan dari *post-scan*. Temuan dengan prioritas 1–5 dikirim ke AI Engine: SQL Injection (prioritas 1), XSS (prioritas 2), fungsi usang (prioritas 3), *hardcoded credentials* dan *path traversal* (prioritas 4), serta SSRF (prioritas 5). Temuan yang tidak terklasifikasi (prioritas 99) tidak diproses. Prioritas ditentukan berdasarkan potensi dampak langsung terhadap kerahasiaan dan integritas sistem serta frekuensi kemunculannya pada aplikasi PHP warisan menurut OWASP Top 10.

Untuk setiap temuan yang lolos filter, modul mengirimkan konteks dan potongan kode ke model LLM melalui endpoint `/api/chat` Ollama di `localhost:11434`. Jika model tidak menghasilkan blok kode PHP sama sekali, respons tetap dicatat dengan *placeholder* `// Manual review required` dan tidak dilewati (diabaikan). Jika Ollama tidak tersedia, *pipeline* tetap berjalan tanpa komponen AI. Desain *prompt* yang digunakan dibahas dalam Subbab 3.5.

3.3.5 ISO Mapper (`iso_mapper.py`)

Modul ini menerima semua hasil dari Scanner, Analyzer, dan AI Engine sebagai objek Python *in-memory* langsung dari `main.py`, lalu memetakannya ke kontrol ISO/IEC 27001:2022 secara berbasis aturan. Tidak ada pembacaan *file* JSON. Pemetaan berbasis aturan dipilih agar hasilnya deterministik dan dapat diaudit. Detail pemetaan dibahas dalam Subbab 3.6.

3.3.6 Main (`main.py`)

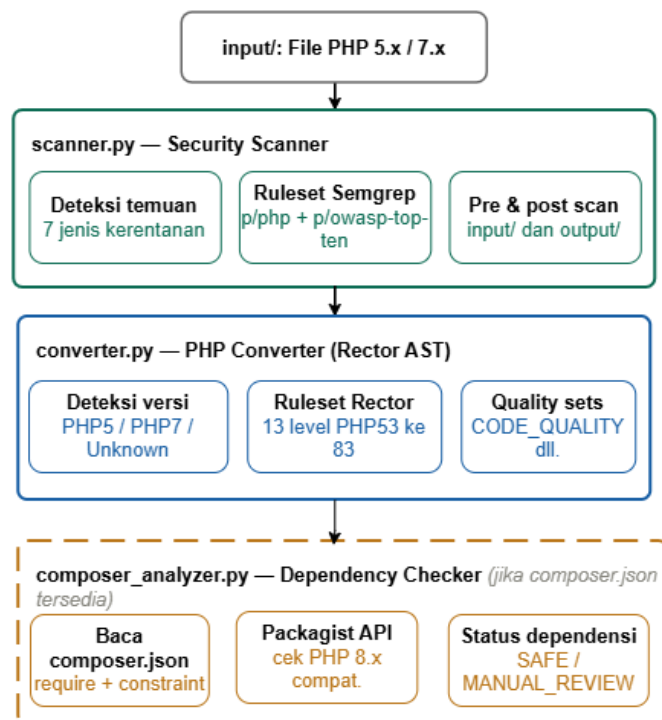
File `main` adalah orkestrator yang mengontrol seluruh *pipeline*. Menerima direktori *input* dan versi PHP target sebagai argumen CLI, menjalankan keenam modul secara berurutan, dan menghasilkan laporan JSON di direktori `reports/`. Ringkasan hasil ditampilkan di konsol menggunakan pustaka Rich. Contoh kerangka laporan JSON yang dihasilkan:

```
1 {
2   "overall_status": "NON_COMPLIANT",
3   "duration_seconds": 228.4,
4   "conversion": {
5     "total_files": 245,
6     "converted": 239,
7     "conversion_rate": 97.6
8   },
9   "iso_controls": {
10    "A.5.17": {"status": "COMPLIANT", "findings": 0},
11    "A.8.28": {"status": "NON_COMPLIANT", "findings": 2790}
12  },
13  "semgrep": {
14    "pre_scan_findings": 11,
15    "post_scan_findings": 11,
16    "delta_f": 0
17  }
18 }
```

3.3.7 Composer Analyzer (`composer_analyzer.py`)

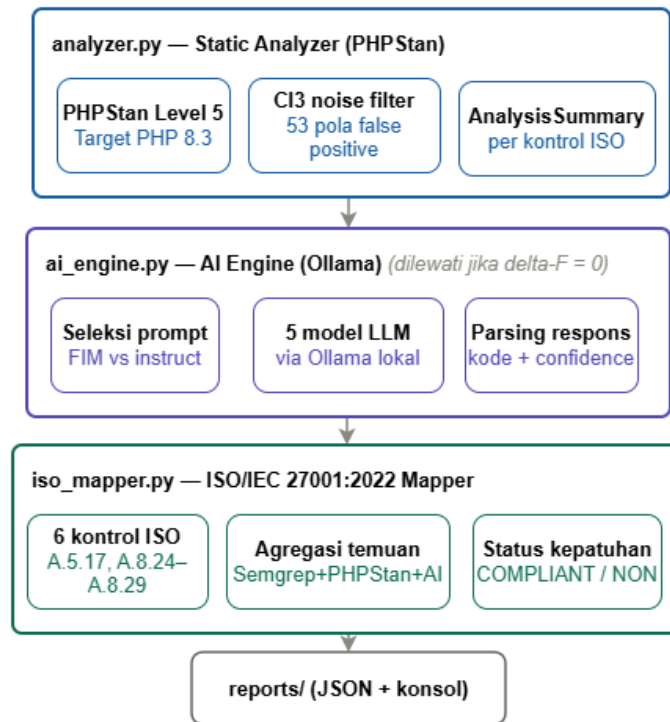
Modul ini membaca berkas `composer.json` pada direktori *root* repositori dan memeriksa kompatibilitas setiap dependensi terhadap PHP 8.x menggunakan data dari Packagist. Jika berkas `composer.json` tidak ditemukan, modul dilewati secara otomatis tanpa menghentikan *pipeline*. Setiap dependensi diklasifikasikan sebagai `SAFE` (versi yang dikonfigurasi mendukung PHP 8.x secara deklaratif) atau `MANUAL REVIEW` (kompatibilitas tidak dapat diverifikasi secara otomatis).

3.4 Alur Data Pipeline



Gambar 3.3. Alur data *pipeline*: tahap masukan: Scanner, Converter, dan Composer Analyzer

File PHP ditempatkan di `input/`. Scanner menjalankan Semgrep pada `input/` untuk menetapkan *baseline* keamanan kode asli (*pre-scan*). Converter menyalin semua *file* ke `output/` lalu menjalankan Rector dengan versi target yang ditentukan; `input/` tidak dimodifikasi sama sekali. Setelah konversi, Scanner menjalankan Semgrep kembali pada `output/` (*post-scan*) untuk mengukur perubahan postur keamanan melalui nilai ΔF . Composer Analyzer memeriksa kompatibilitas dependensi `composer.json` terhadap PHP 8.x, atau dilewati otomatis jika berkas tidak ditemukan.



Gambar 3.4. Alur data *pipeline*: tahap keluaran: Analyzer, AI Engine, ISO Mapper, dan laporan akhir

Analyzer menjalankan PHPStan level 5 pada `output/` untuk memverifikasi kompatibilitas kode dengan versi PHP target. AI Engine mengambil temuan Semgrep prioritas 1–5 dan mengirimkannya ke model LLM untuk analisis dan saran perbaikan; modul ini dilewati otomatis jika tidak ada temuan. ISO Mapper mengumpulkan semua temuan dari Scanner, Analyzer, dan AI Engine lalu memetakannya ke enam kontrol ISO/IEC 27001:2022. `main.py` menggabungkan semuanya menjadi laporan JSON dan menampilkan ringkasan di konsol.

3.5 Desain Prompt LLM

Desain *prompt* adalah salah satu keputusan metodologis yang paling berpengaruh terhadap kualitas respons model. *Prompt* dirancang untuk memenuhi tiga tujuan: menghasilkan kode perbaikan yang valid secara sintaksis, menghasilkan skor kepercayaan yang dapat dibaca otomatis oleh *pipeline*, dan dapat dijalankan secara *zero-shot* tanpa contoh mengingat tidak tersedianya *dataset* berlabel.

Prompt yang dijelaskan pada subbab ini adalah *prompt* standar Kondisi A yang digunakan secara identik untuk semua model.

3.5.1 Struktur Prompt

Prompt terdiri dari dua bagian yang dikirim melalui endpoint `/api/chat`: *system message* dan *user message*.

System message:

```
1 You are a PHP security expert and migration specialist.  
2 You analyze PHP code for security vulnerabilities and provide  
3 secure PHP 8.x replacements.  
4 Always follow output format instructions exactly as given.
```

User message untuk setiap temuan:

```
1  
2 TASK: Analyze the following PHP code for a [vulnerability_type]  
3 vulnerability and provide a secure PHP 8.x replacement.  
4 ISO/IEC 27001:2022 Controls: [relevant_controls]  
5 Context: File: [filename], line [line_number],  
6         Semgrep rule: [rule_id], Finding: [description]  
7 VULNERABLE CODE:  
8 ```php  
9 [code_snippet]  
10 ```  
11 Respond in English:  
12 1. Explain the vulnerability and its security risk.  
13 2. Provide the corrected PHP 8.x code in a ```php code block.  
14 After your explanation and code fix, write exactly this on the  
15 last line:  
16 CONFIDENCE: [number between 0 and 100]  
17 Example last line: CONFIDENCE: 85
```

Sebagai ilustrasi, berikut contoh pengisian *placeholder* di atas untuk temuan SQL Injection pada `Output.php` baris 768 (*rule*: `tainted-sql-string`, kontrol A.8.26 dan A.8.28): Potongan kode yang disisipkan pada *placeholder* `[code_snippet]` dibatasi pada 2.000 karakter pertama dari *file* sumber. Pembatasan ini diterapkan untuk menjaga agar ukuran *prompt* tetap dalam batas *context window* default Ollama dan menghindari pemotongan respons akibat token yang melebihi kapasitas model. Konsekuensinya, untuk *file* PHP yang panjang, model hanya menerima bagian awal kode dan tidak selalu memiliki konteks lengkap untuk menganalisis kerentanan secara menyeluruh. Keterbatasan ini dibahas lebih lanjut dalam Subbab ??.

```

1 TASK: Analyze the following PHP code for a SQL Injection
2 vulnerability and provide a secure PHP 8.x replacement.
3 ISO/IEC 27001:2022 Controls: A.8.26, A.8.28
4 Context: File: Output.php, line 768,
5         Semgrep rule: tainted-sql-string,
6         Finding: $_SERVER['QUERY_STRING'] used directly in
7                 cache path construction without sanitization
8 VULNERABLE CODE:
9 ```php
10 $uri .= '?' . $_SERVER['QUERY_STRING'];
11 $cache_path .= md5(
12     $CI->config->item('base_url')
13     . $CI->config->item('index_page')
14     . ltrim($uri, '/'));
15
16 if ( ! @unlink($cache_path)) {
17     log_message('error',
18         'Unable to delete cache file for ' . $uri);
19     return FALSE;
20 }
21 ```
22 Respond in English:
23 1. Explain the vulnerability and its security risk.
24 2. Provide the corrected PHP 8.x code in a ```php code block.
25 After your explanation and code fix, write exactly this on the
26 last line:
27 CONFIDENCE: [number between 0 and 100]
28 Example last line: CONFIDENCE: 85

```

Blok kode PHP diekstraksi dari respons model menggunakan pencocokan pola *markdown* ```php ... ```. Jika pola ini tidak ditemukan, *pipeline* mencoba mengekstraksi blok kode generik ``` ... ``` sebagai *fallback*. Kode hasil ekstraksi kemudian divalidasi menggunakan `php -l` untuk memverifikasi kebenaran sintaksisnya sebelum disertakan dalam laporan. Jika tidak ada blok kode yang berhasil diekstraksi sama sekali, respons tetap dicatat dengan *placeholder* `// Manual review required`.

Contoh keluaran yang diharapkan dari model untuk temuan di atas:

```
1 ### Explanation of Vulnerability
2 The code uses $_SERVER['QUERY_STRING'] directly in cache
3 path construction without sanitization, allowing path
4 traversal or cache poisoning attacks.
5
6 Here's the corrected PHP 8.x code:
7 ```php
8 $uri .= '?' . urlencode($_SERVER['QUERY_STRING']);
9 $cache_path .= md5(
10     $CI->config->item('base_url')
11     . $CI->config->item('index_page')
12     . ltrim($uri, '/'));
13
14 if (!@unlink($cache_path)) {
15     log_message('error',
16         'Unable to delete cache file for '
17         . urlencode($uri));
18     return FALSE;
19 }
20 ```
21 CONFIDENCE: 78
```

Tiga elemen yang harus hadir sekaligus agar respons dihitung patuh format: penjelasan kerentanan, blok kode PHP yang valid, dan baris `CONFIDENCE :` di akhir.

Teks lengkap *prompt* Kondisi B untuk masing-masing model disertakan pada Lampiran 5.2.

3.5.2 Keputusan Desain Prompt

Penyertaan kontrol ISO/IEC 27001:2022: Kontrol ISO yang relevan disertakan di setiap *prompt*. Informasi ini bertujuan untuk mendorong model menghasilkan saran perbaikan yang mempertimbangkan kepatuhan standar, bukan sekadar memperbaiki sintaks.

Instruksi format di akhir pesan: Format `CONFIDENCE : [0-100]` diletakkan di bagian akhir dengan instruksi eksplisit termasuk contoh konkret. Model kecil cenderung lebih patuh pada instruksi yang dekat dengan akhir pesan.

Parsing skor berlapis: Karena tidak semua model mengikuti format yang diminta, `ai_engine.py` menggunakan enam pola *regex* berurutan untuk mengekstraksi skor: (0) tag XML `<confidence>`, (1) bilangan bulat dekat kata

“confidence”, (2) desimal 0.x dekat “confidence”, (3) persentase dekat “confidence”, (4) desimal *bare* di mana saja, dan (5) frasa bahasa alami seperti “not sure” yang dipetakan ke nilai tetap. Jika seluruh pola gagal diekstraksi, sistem akan mengembalikan nilai *default* 0,0.

Temperature 0,1: Dipilih untuk meminimalkan variasi acak antar percobaan. Setiap model dijalankan tiga kali per temuan dengan *prompt* identik, sehingga perbedaan hasil antar *run* mencerminkan variabilitas model yang sebenarnya. Ollama tidak menyediakan pengaturan *seed* inferensi yang konsisten untuk seluruh model yang diuji, sehingga variasi kecil antar *run* tetap mungkin terjadi meskipun *temperature* dibuat rendah (0,1).

Zero-shot tanpa contoh: Tidak ada contoh perbaikan kode disertakan karena penelitian ingin mengevaluasi kemampuan bawaan model dalam kondisi yang mencerminkan penggunaan nyata. Hal ini juga memastikan bahwa seluruh model dibandingkan pada kondisi yang setara.

Skor kepercayaan sebagai metrik sekunder: Skor ini adalah penilaian mandiri dari model dan tidak bisa diverifikasi secara independen. Dalam analisis Bab IV, skor kepercayaan adalah metrik sekunder; metrik primer adalah validitas sintaks kode yang dihasilkan, diukur dengan `php -l`.

3.6 Desain Pemetaan ISO/IEC 27001:2022

Pemetaan temuan ke kontrol ISO/IEC 27001:2022 dilakukan secara berbasis aturan (*rule-based*) di dalam `iso_mapper.py`. Data diterima langsung sebagai objek Python *in-memory* dari `main.py`, tidak dibaca dari *file* JSON. Pendekatan berbasis aturan ini dipilih agar hasilnya deterministik dan bisa diaudit, berbeda dari pendekatan berbasis AI yang hasilnya bisa berubah antar inferensi. Ada enam kontrol yang dipetakan, sebagaimana ditunjukkan pada Tabel 3.2.

Status akhir setiap kontrol ditentukan berdasarkan ada tidaknya temuan terbuka setelah *pipeline* selesai. COMPLIANT berarti tidak ada temuan yang dipetakan ke kontrol tersebut. NON_COMPLIANT berarti ada temuan Semgrep aktif. PARTIAL berarti hanya ada temuan PHPStan tanpa temuan Semgrep. Status COMPLIANT pada A.5.17 dan A.8.24 tidak menjamin bahwa kode telah terbebas dari kerentanan secara mutlak; status tersebut sekadar menunjukkan bahwa *ruleset* yang digunakan tidak menghasilkan temuan yang dipetakan ke kedua kontrol itu pada dataset ini.

Tabel 3.2. Pemetaan sumber temuan ke kontrol ISO/IEC 27001:2022 Annex A

Kontrol ISO	Judul	Sumber temuan yang dipetakan
A.5.17	<i>Authentication Information</i>	Semgrep: <i>hardcoded credentials</i>
A.8.24	<i>Use of Cryptography</i>	Semgrep: <code>md5()</code> / <code>sha1()</code> untuk kata sandi
A.8.25	<i>Secure Development Lifecycle</i>	Semgrep (semua) + PHPStan ERROR/WARNING
A.8.26	<i>Application Security Requirements</i>	Semgrep: SQL Injection, XSS
A.8.28	<i>Secure Coding</i>	Semgrep (semua) + PHPStan ERROR
A.8.29	<i>Security Testing in Development</i>	Semgrep: <i>Path Traversal/SSRF</i> + PHPStan ERROR/WARNING

3.6.1 Mekanisme Klasifikasi Temuan

Pemetaan dari hasil temuan Semgrep ke kontrol ISO dilakukan dengan fungsi `_classify()` di `scanner.py`. Fungsi ini memeriksa `rule_id` dan `message` dari setiap temuan Semgrep menggunakan pencocokan *substring* (bukan ekspresi reguler) terhadap daftar kata kunci yang telah ditetapkan. Hasilnya adalah penugasan `vuln_type`, daftar `iso_controls`, dan nilai prioritas. Tabel 3.3 menunjukkan pemetaan kata kunci ke jenis kerentanan dan kontrol ISO yang ditugaskan.

Pendekatan *keyword matching* ini dipilih dibandingkan pendekatan berbasis AI karena tiga alasan. Pertama, hasilnya deterministik: temuan yang sama selalu menghasilkan pemetaan yang sama tanpa variasi antar inferensi. Kedua, dapat diaudit secara langsung karena seluruh logika pemetaan tersimpan sebagai kode Python yang bisa diperiksa dan diverifikasi. Ketiga, tidak memerlukan koneksi eksternal atau model tambahan, sehingga konsisten dengan persyaratan privasi data yang ditetapkan dalam Subbab 1.5.

Tabel 3.3. Pemetaan kata kunci `rule_id` Semgrep ke jenis kerentanan dan kontrol ISO/IEC 27001:2022

Kata Kunci (<code>rule_id/message</code>)	Jenis Kerentanan	Kontrol ISO	Prioritas
sql, sql_i, injection	SQL Injection	A.8.26, A.8.28	1
xss, cross-site	XSS	A.8.26, A.8.28	2
deprecated, mysql_	Fungsi Usang	A.8.25, A.8.28	3
hardcoded, secret, password	Kredensial Hardcoded	A.5.17, A.8.28	4
path, traversal	Path Traversal	A.8.28, A.8.29	4
ssrf, server-side-request-forgery	SSRF	A.8.28, A.8.29	5
md5, sha1, weak.*crypt	Kriptografi Lemah	A.8.24, A.8.28	6

3.7 Rancangan Eksperimen Komparasi Model LLM

Eksperimen komparasi dirancang dengan kondisi yang sepenuhnya terkontrol dan dilakukan terpisah dari pengujian *pipeline* utama menggunakan skrip evaluasi khusus.

Eksperimen ini mencakup tiga kondisi yang dirancang secara bertahap. **Kondisi A** adalah *baseline*: semua model menerima *prompt* yang identik secara *zero-shot* tanpa optimasi apa pun. **Kondisi B** mengoptimasi *prompt* per model berdasarkan pola kegagalan yang terobservasi pada Kondisi A, untuk mengetahui sejauh mana performa model bisa ditingkatkan melalui penyesuaian *prompt*. **Kondisi C** mengeksplorasi variasi parameter *temperature* dan *context window* pada model terbaik hasil Kondisi A dan B.

3.7.1 Kondisi Eksperimen

- **Input:** 11 temuan Semgrep dari *pre-scan* dataset FT UGM
- **Jumlah percobaan:** 3 *run* per temuan per model (33 percobaan per model, 165 total)
- **Temperature:** 0,1 untuk semua model
- **Prompt:** identik untuk semua model pada Kondisi A (*zero-shot*); dioptimasi per model pada Kondisi B
- **Model:** dijalankan lokal melalui Ollama tanpa modifikasi

3.7.2 Metrik Evaluasi

Definisi formal seluruh metrik yang digunakan dalam penelitian ini beserta landasannya dalam literatur telah diuraikan dalam Subbab 2.2.11. Secara ringkas, lima metrik yang diterapkan adalah: Conversion Rate (CR) untuk mengukur keberhasilan konversi Rector, Format Compliance Rate (FCR) untuk mengukur kepatuhan format respons model, Syntax Validity Rate (SVR) sebagai metrik primer kualitas kode yang dihasilkan, Security Finding Delta (ΔF) untuk mengukur perubahan postur keamanan pasca-konversi, dan Mean Confidence Score ($\bar{C}_m$) sebagai metrik sekunder konsistensi model.

Dalam eksperimen ini, setiap model dijalankan sebanyak 33 percobaan (3 *run* per temuan, 11 temuan), sehingga $r_{total} = 33$ per model untuk perhitungan FCR. SVR ditetapkan sebagai metrik primer karena hasilnya dapat diverifikasi secara independen menggunakan `php -l`, sedangkan $\bar{C}_m$ bersifat sekunder karena merupakan penilaian mandiri model yang tidak dapat diverifikasi dari luar.

3.7.3 Interpretasi Trade-off Antar Metrik

FCR dan SVR merupakan dua dimensi yang independen dan perlu diinterpretasikan bersama, sebagaimana dijelaskan dalam Subbab 2.2.11. Model dengan FCR tinggi namun SVR rendah menunjukkan kemampuan mengikuti instruksi format tetapi kualitas kode yang buruk. Sebaliknya, model dengan FCR rendah namun SVR tinggi mengabaikan instruksi format tetapi menghasilkan kode berkualitas baik. Kedua kondisi ini punya implikasi praktis yang berbeda dan dibahas secara empiris di Bab IV.

3.8 Metode Pengujian dan Evaluasi

Pengujian dilakukan dengan pendekatan berbasis keluaran (*output-oriented evaluation*), dengan fokus pada hasil setiap modul dibandingkan dengan detail implementasi internalnya. Terdapat lima metrik utama:

1. **Tingkat konversi Rector:** Persentase *file* PHP yang berhasil dikonversi tanpa kesalahan fatal Rector, dihitung per *file* dan secara keseluruhan.
2. **Validitas sintaks pasca-konversi:** Persentase *file* hasil konversi yang lolos `php -l`. Diukur secara objektif. Validitas sintaks tidak menjamin kebenaran logika program atau keamanan hasil transformasi, tetapi dipilih sebagai metrik primer karena dapat diverifikasi secara objektif dan otomatis.
3. **Perbedaan temuan keamanan:** Selisih jumlah temuan Semgrep antara *pre-scan* dan *post-scan*. Temuan baru setelah konversi tidak otomatis diinterpretasikan sebagai regresi keamanan, tetapi hal tersebut dapat mencerminkan kerentanan laten yang sebelumnya tersembunyi.

4. **Performa model LLM:** Diukur menggunakan *format compliance rate* (sekunder) dan *syntax validity rate* (primer) sebagaimana dijelaskan dalam Subbab 3.7.2.
5. **Status kepatuhan ISO/IEC 27001:2022:** Status per kontrol (COMPLIANT, PARTIAL, atau NON_COMPLIANT) berdasarkan logika pemetaan dalam Subbab 3.6.

Untuk hasil PHPStan, jumlah kesalahan yang tinggi tidak secara langsung diinterpretasikan sebagai kegagalan *pipeline*. Kesalahan PHPStan pada kode warisan yang baru dimigrasi sebagian besar mencerminkan *technical debt* yang sudah ada sebelum migrasi, bukan akibat dari proses konversi. Perbedaan ini dibahas lebih rinci di Bab IV.

BAB IV

HASIL DAN DISKUSI

Bab ini menyajikan hasil implementasi *pipeline* pada dua studi kasus: kode PHP milik FT UGM (Dashboard TCK) dan kode PHP milik DTI UGM (Sistem CBT), beserta analisis perbandingan keduanya. Setiap studi kasus diawali dengan deskripsi dataset yang digunakan, diikuti hasil konversi Rector, pemindaian Semgrep, validasi PHPStan, dan pemetaan kepatuhan ISO/IEC 27001:2022. Studi kasus pertama juga mencakup eksperimen komparasi lima model LLM pada tiga kondisi serta analisis dependensi *composer*. Bagian penutup menyajikan perbandingan hasil kedua studi kasus secara menyeluruh.

4.1 Studi Kasus 1: FT UGM (Dashboard TCK)

4.1.1 Deskripsi Dataset

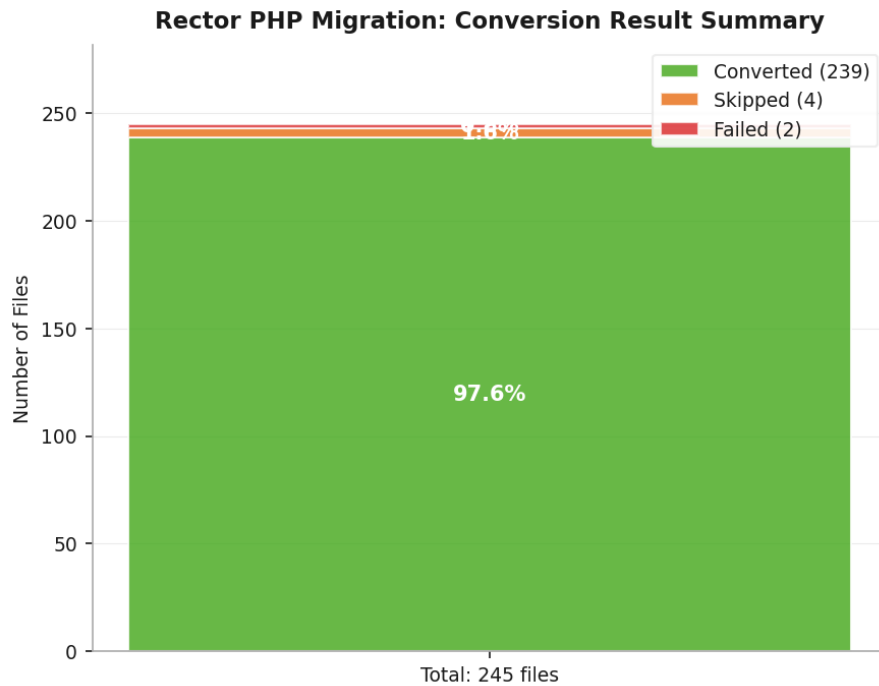
Studi kasus pertama menggunakan 245 *file* PHP dari satu aplikasi web internal berbasis CodeIgniter 3.x yang dikelola oleh FT UGM. Struktur direktorinya mengikuti konvensi standar CodeIgniter 3.x: *application/* untuk kode aplikasi (kontroler, model, *view*, *helper*, konfigurasi, layanan) dan *system/* untuk kode *framework*. Kode diperoleh melalui koordinasi langsung dengan FT UGM dan hanya digunakan untuk analisis statis dalam lingkungan lokal, tanpa akses ke basis data produksi dan tanpa eksekusi kode.

Hanya *file* *.php* yang diproses; *file* lain seperti *.html*, *.js*, dan *.css* tidak disalin ke *output/* dan tidak dianalisis. Dataset mencerminkan karakteristik kode warisan yang umum: pencampuran logika bisnis, akses basis data, dan presentasi dalam *file* yang sama, serta beberapa pola kode PHP 5.x yang masih ada meski aplikasi secara keseluruhan berjalan di atas PHP 7.x.

Untuk eksperimen komparasi LLM, digunakan 11 temuan dari Semgrep *pre-scan*: 1 SQL Injection dan 10 SSRF (*Server-Side Request Forgery*). Hasil ini adalah seluruh populasi temuan *pre-scan*, bukan subset yang dipilih secara subjektif.

4.1.2 Hasil Konversi Rector

Rector dijalankan terhadap 245 *file* PHP dari dataset FT UGM dengan target versi PHP 8.3. Dari 245 *file* tersebut, 239 *file* berhasil dikonversi, 4 *file* dilewati (*skipped*), dan 2 *file* gagal diproses. Tingkat konversi keseluruhan ($CR = 97,6\%$), sebagaimana ditunjukkan pada Gambar 4.5.



Gambar 4.5. Ringkasan hasil konversi Rector terhadap 245 *file* PHP dataset FT UGM

Karena dataset mengandung campuran kode PHP 5.x dan PHP 7.x, Rector menerapkan rantai *ruleset* kumulatif dari `UP_TO_PHP_53` hingga `UP_TO_PHP_83` secara otomatis dalam satu proses. Hal ini membuktikan bahwa *pipeline* dapat menangani kode dari berbagai era PHP sekaligus tanpa konfigurasi tambahan.

4.1.2.1 Contoh Transformasi Rector

Sebagai gambaran nyata mengenai jenis-jenis perubahan yang dilakukan Rector, berikut tiga contoh transformasi yang ditemukan pada dataset FT UGM.

Transformasi 1: Array sintaks pendek (**ArrayShortSyntaxRector**)

Pada `system/core/Security.php`, deklarasi *array* menggunakan sintaks lama diubah ke sintaks pendek PHP 5.4:

```
1 // Sebelum (PHP 7.x)
2 public $filename_bad_chars = array(
3     './', '<!--', '-->', '<', '>',
4     '"', "'", '&', '$', '#',
5 );
6 protected $_never_allowed_str = array(
7     'document.cookie' => '',
8     'document.write'  => '',
9 );
10
11 // Sesudah (PHP 8.3)
12 public $filename_bad_chars = [
13     './', '<!--', '-->', '<', '>',
14     '"', "'", '&', '$', '#',
15 ];
16 protected $_never_allowed_str = [
17     'document.cookie' => '',
18     'document.write'  => '',
19 ];
```

Transformasi 2: Operator *null coalescing* (**NullCoalescingRector**)

Pada `system/helpers/url_helper.php`, pola pengecekan tiga bagian `isset()` diubah ke operator `??` yang lebih ringkas:

```
1 // Sebelum (PHP 7.x)
2 $atts[$key] = isset($attributes[$key])
3     ? $attributes[$key] : $val;
4
5 // Sesudah (PHP 8.3)
6 $atts[$key] = $attributes[$key] ?? $val;
```

Transformasi 3: Fungsi `str_contains()` (`StrContainsRector`)

Pada `system/helpers/url_helper.php`, pola pencarian substring dengan `strpos()` diubah ke fungsi `str_contains()` yang dikenalkan di PHP 8.0. Rector juga menambahkan *cast* (`string`) karena hasil dari `$_SERVER['SERVER_SOFTWARE']` bertipe *mixed* di PHP 8.x:

```
1 // Sebelum (PHP 7.x)
2 if ($method === 'auto'
3     && isset($_SERVER['SERVER_SOFTWARE'])
4     && strpos($_SERVER['SERVER_SOFTWARE'],
5         'Microsoft-IIS') !== FALSE)
6
7 // Sesudah (PHP 8.3)
8 if ($method === 'auto'
9     && isset($_SERVER['SERVER_SOFTWARE'])
10    && str_contains(
11        (string) $_SERVER['SERVER_SOFTWARE'],
12        'Microsoft-IIS'))
```

Ketiga transformasi ini mencerminkan kategori perubahan yang paling umum dilakukan Rector: modernisasi sintaks, penggunaan API PHP yang lebih baru, dan penambahan informasi tipe yang dibutuhkan PHP 8.x.

4.1.2.2 File yang Gagal Dikonversi

Kedua *file* yang gagal dikonversi mengalami *internal error* yang sama, yaitu pada fungsi `FiberNodeScopeResolver::callNodeCallback()` yang menerima argumen bertipe `null`, padahal seharusnya bertipe `PhpParser\Node`. Permasalahan ini merupakan *bug* pada versi Rector yang digunakan, bukan berasal dari kode sumber FT UGM.

File pertama, yaitu `captcha_helper.php`, memiliki pola percabangan yang mengembalikan tipe data berbeda, yaitu `GdImage` dan `resource`, bergantung pada hasil evaluasi `function_exists()`. Rector menggunakan *Fiber*, sebuah mekanisme konkurensi ringan yang diperkenalkan di PHP 8.1, sebagai unit eksekusi untuk menganalisis setiap *node* AST secara terpisah selama proses transformasi [3]. Dalam kondisi ini, *PHPStan Fiber* yang digunakan oleh Rector kehilangan referensi terhadap *node* AST ketika menganalisis percabangan dengan perbedaan tipe tersebut.

File kedua, yaitu `form_helper.php`, mengandung lebih dari 15 definisi fungsi kondisional yang dibungkus dalam konstruksi `if (!function_exists(...))` pada ruang lingkup *file* yang sama. Banyaknya *fiber* analisis yang berjalan secara paralel untuk setiap fungsi menyebabkan potensi kondisi *race*, di mana salah satu *callback*

menerima *node* yang telah selesai diproses oleh *fiber* lain.

Kedua *file* tersebut tetap disertakan dalam direktori `output/` sebagai salinan kode asli, sehingga proses konversi tetap berjalan tanpa kehilangan data.

Setelah proses konversi, seluruh *file* pada direktori `output/` diuji validitas sintaksisnya menggunakan perintah `php -l`. Hasil pengujian menunjukkan tidak adanya *parse error*, sehingga tingkat validitas sintaks pasca-konversi mencapai 100%.

4.1.3 Hasil Pemindaian Keamanan Semgrep

4.1.3.1 Pre-Scan: Baseline Keamanan Kode Asli

Pemindaian Semgrep terhadap 241 *file* PHP pada direktori `input/` (dari total 245 *file*; 4 *file* tidak disertakan karena tidak mengandung kode PHP yang dapat dianalisis oleh *ruleset* Semgrep) menghasilkan 11 temuan, yang terdiri atas 1 kerentanan SQL Injection dan 10 kerentanan SSRF (*Server-Side Request Forgery*). Seluruh temuan tersebut terlokalisasi pada satu *file*, yaitu `Output.php`.

Kerentanan SQL Injection teridentifikasi pada baris 768, di mana data dari variabel `$_SERVER['QUERY_STRING']` digunakan secara langsung dalam konstruksi *cache path* tanpa melalui proses sanitasi yang sesuai. Selain itu, terdapat 10 temuan SSRF yang muncul pada beberapa bagian dalam `Output.php`. Temuan ini disebabkan oleh penggunaan nama *file* yang berasal dari *input* pengguna dalam operasi *file system*, sehingga membuka peluang akses terhadap sumber daya yang tidak diinginkan.

Terpusatnya seluruh temuan pada satu *file* mengindikasikan pola yang umum pada kode warisan, di mana modul yang menangani *output* dan *cache* cenderung menjadi titik kerentanan akibat tingginya interaksi dengan data eksternal yang tidak divalidasi secara konsisten.

4.1.3.2 Post-Scan: Perbandingan Setelah Konversi

Pemindaian Semgrep terhadap direktori `output/` setelah proses konversi oleh Rector menghasilkan jumlah temuan yang identik dengan tahap *pre-scan*, yaitu 11 temuan. Nilai perubahan temuan keamanan ($\Delta F = F_{post} - F_{pre} = 0$) menunjukkan tidak adanya perbedaan. Distribusi jenis kerentanan juga tetap sama, yaitu 1 SQL Injection dan 10 SSRF, seluruhnya berada pada *file* yang sama.

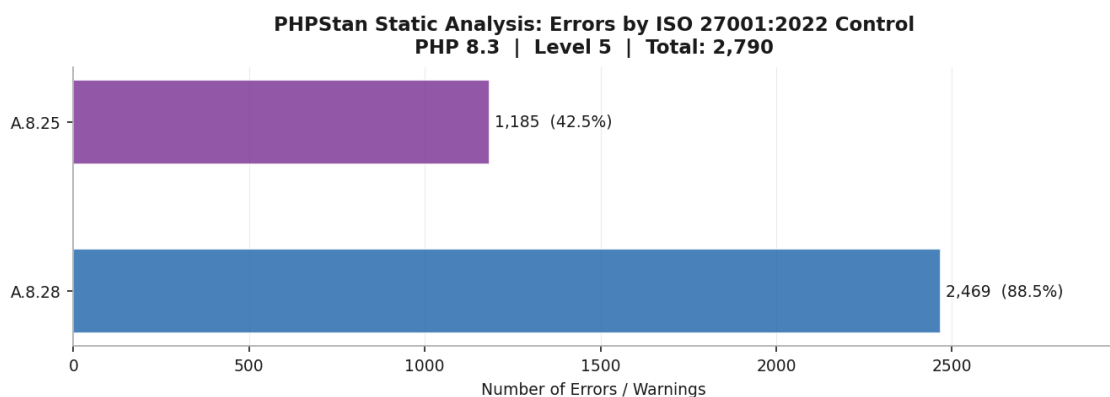
Hasil ini sesuai dengan ekspektasi dan mengindikasikan dua hal. Pertama, proses konversi oleh Rector tidak memperkenalkan kerentanan baru pada kode FT UGM. Kedua, kerentanan yang telah ada sebelumnya tidak dapat diatasi melalui transformasi sintaksis berbasis AST, karena memerlukan perbaikan pada tingkat logika program (semantik), yang berada di luar cakupan pendekatan tersebut.

4.1.4 Hasil Validasi PHPStan

PHPStan level 5 dijalankan terhadap kode hasil konversi di direktori `output/` dengan target PHP 8.3. Hasilnya adalah 2.790 temuan yang terdiri dari 2.469 ERROR dan 321 WARNING, tersebar di 179 dari 241 *file* yang dianalisis. Di antara temuan tersebut, 354 di antaranya merupakan *noise* dari arsitektur dinamis CodeIgniter 3 yang tidak dapat dianalisis secara statis oleh PHPStan, meliputi *magic property* dan fungsi *helper* yang diinjeksi saat *runtime*.

Sebagian besar *error* yang ditemukan PHPStan berasal dari tiga kategori utama. Pertama, kelas dari *library* pihak ketiga yang tidak ditemukan, seperti `PhpOffice\PhpSpreadsheet` dan `Dotenv\Dotenv`: PHPStan tidak dapat menemukan kelas-kelas ini karena hanya kode sumber yang dianalisis, bukan dependensi lengkap aplikasi. Kedua, penggunaan nilai kembalian fungsi `void` sebagai nilai, misalnya `Result of method sendResponse() (void) is used`, yang merupakan pola umum pada kode warisan yang ditulis tanpa deklarasi tipe eksplisit. Ketiga, ketidakkonsistenan tipe seperti `Cannot access property $role on array`, yang mencerminkan penggunaan *array* sebagai pengganti objek bertipe tanpa definisi yang jelas.

Temuan-temuan ini merupakan manifestasi dari *technical debt* (akumulasi masalah kualitas kode yang penanganannya ditunda) yang telah ada sebelum migrasi, bukan kesalahan yang ditimbulkan oleh proses konversi. PHP 8.3 memiliki sistem tipe yang jauh lebih ketat dibandingkan PHP 7.x, sehingga masalah yang sebelumnya tidak terdeteksi karena PHP 7.x lebih permisif kini menjadi terlihat oleh PHPStan. Gambar 4.6 menunjukkan distribusi temuan PHPStan berdasarkan kontrol ISO/IEC 27001:2022 yang dipetakan.



Gambar 4.6. Distribusi temuan PHPStan berdasarkan kontrol ISO/IEC 27001:2022 Annex A

Angka PHPStan yang tinggi justru menunjukkan manfaat nyata dari komponen validasi dalam *pipeline* ini. Tanpa PHPStan, 2.790 potensi masalah tipe dan

kompatibilitas ini tidak akan terdeteksi sampai kode dijalankan di lingkungan produksi, sesuai dengan temuan Strobl et al. [11] tentang pentingnya jaminan kualitas otomatis dalam transformasi kode skala besar.

4.1.5 Status Kepatuhan ISO/IEC 27001:2022

Berdasarkan pemetaan yang dilakukan oleh `iso_mapper.py`, status kepatuhan terhadap enam kontrol ISO/IEC 27001:2022 yang dipetakan adalah sebagaimana ditunjukkan pada Tabel 4.1.

Tabel 4.1. Status kepatuhan ISO/IEC 27001:2022 hasil *pipeline* pada dataset FT UGM

Kontrol	Judul	Dasar Penilaian	Status
A.5.17	<i>Authentication Information</i>	Tidak ada temuan <i>hardcoded credentials</i>	COMPLIANT
A.8.24	<i>Use of Cryptography</i>	Tidak ada temuan penggunaan <code>md5()</code> / <code>sha1()</code> untuk kata sandi	COMPLIANT
A.8.25	<i>Secure Development Lifecycle</i>	1.185 temuan PHPStan kategori <i>undefined/not found</i> yang dipetakan ke kontrol ini	NON_COMPLIANT
A.8.26	<i>Application Security Requirements</i>	1 temuan SQL Injection dari Semgrep	NON_COMPLIANT
A.8.28	<i>Secure Coding</i>	Temuan Semgrep aktif dan 2.469 ERROR PHPStan	NON_COMPLIANT
A.8.29	<i>Security Testing in Development</i>	10 temuan SSRF dari Semgrep masih terbuka	NON_COMPLIANT

Status keseluruhan adalah NON_COMPLIANT. Angka temuan per kontrol pada tabel ini dapat melebihi total temuan unik (2.790) karena satu temuan PHPStan dapat dipetakan ke lebih dari satu kontrol ISO sekaligus. Hasil ini sejalan dengan kondisi kode warisan yang dianalisis, serta secara objektif merepresentasikan postur keamanan aplikasi sebelum tahap remediasi manual.

Dua kontrol yang berstatus COMPLIANT, yaitu A.5.17 dan A.8.24, perlu dipahami dalam konteks yang tepat. Status ini berarti *ruleset* Semgrep yang digunakan tidak menghasilkan temuan yang dipetakan ke kedua kontrol tersebut, bukan berarti kode bebas dari masalah autentikasi atau kriptografi secara absolut.

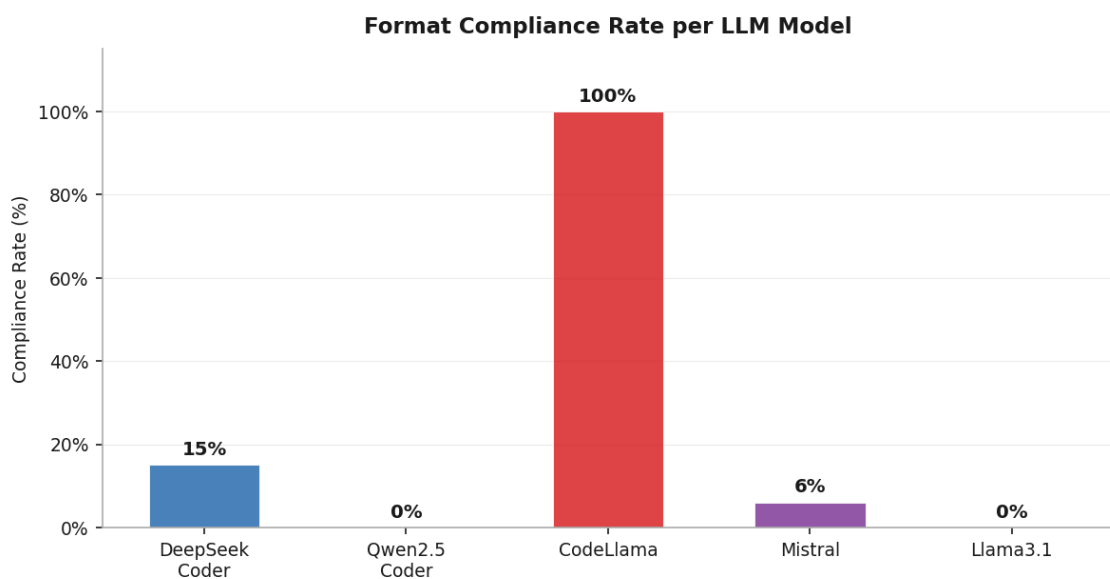
Kontrol A.8.29 berstatus `NON_COMPLIANT` karena terdapat 10 temuan SSRF aktif dari Semgrep yang dipetakan ke kontrol ini dan belum diatasi. Berdasarkan mekanisme pemetaan berbasis aturan yang didefinisikan dalam Subbab 3.6, keberadaan temuan Semgrep aktif pada kontrol mana pun menghasilkan status `NON_COMPLIANT`, terlepas dari apakah *pipeline* sudah menjalankan proses pengujian keamanan otomatis atau belum. Laporan kepatuhan ini dihasilkan secara otomatis dan dapat langsung digunakan sebagai dokumentasi audit ISO/IEC 27001:2022 [12].

4.1.6 Hasil Komparasi Lima Model LLM (Kondisi A)

Eksperimen Kondisi A dijalankan dengan *prompt* yang identik untuk semua model (*zero-shot*), 11 temuan Semgrep *pre-scan* sebagai masukan, 3 *run* per temuan per model, dan *temperature* 0,1. Total percobaan adalah 165 (33 per model). Semua model dijalankan secara lokal melalui Ollama tanpa modifikasi.

4.1.6.1 Format Compliance Rate

Gambar 4.7 menunjukkan *format compliance rate* untuk masing-masing model pada Kondisi A.

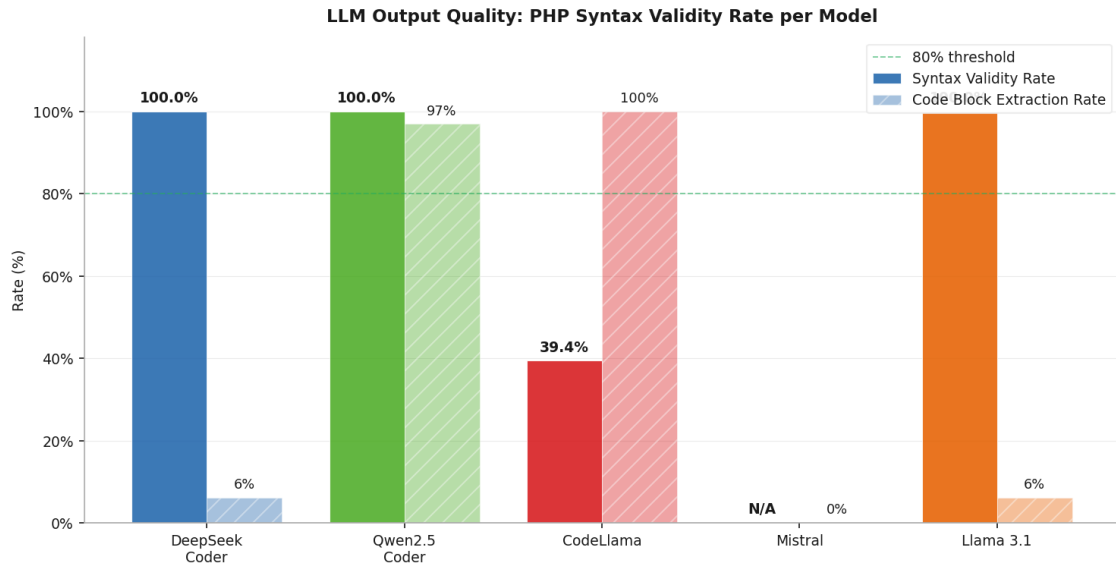


Gambar 4.7. *Format compliance rate* kelima model LLM pada Kondisi A (*zero-shot*, *prompt* identik)

CodeLlama adalah satu-satunya model yang secara konsisten mengikuti format instruksi *prompt* di semua 33 percobaan (100%). DeepSeek Coder mengikuti format di 5 dari 33 percobaan (15%). Mistral mengikuti format di 2 dari 33 percobaan (6%). Qwen2.5-Coder dan Llama 3.1 tidak menghasilkan satu pun respons yang memenuhi ketiga elemen format sekaligus.

4.1.6.2 Syntax Validity Rate

Gambar 4.8 menunjukkan *syntax validity rate* dan *code block extraction rate* untuk masing-masing model.



Gambar 4.8. *Syntax validity rate* dan *code block extraction rate* kelima model LLM pada Kondisi A

Hasilnya memperlihatkan gambaran yang berlawanan dengan metrik format. CodeLlama yang memiliki *format compliance* 100% ternyata hanya menghasilkan kode PHP yang *valid* secara sintaksis pada 9 dari 33 blok kode yang berhasil diekstraksi ($SVR = 27,3\%$). Hal tersebut berarti 24 dari 33 blok kode CodeLlama mengandung *parse error*. Sebaliknya, Qwen2.5-Coder yang memiliki *format compliance* 0% berhasil mengekstraksi blok kode PHP dari 32 dari 33 percobaan (97%), dan seluruh 32 blok kode tersebut lolos pemeriksaan `php -l` ($SVR = 100\%$). Model ini mengabaikan instruksi format sepenuhnya, tetapi secara konsisten menghasilkan kode yang berkualitas baik.

Mistral berhasil mengekstraksi 1 blok kode dari 33 percobaan, tetapi blok tersebut tidak lolos `php -l` (0% validitas). DeepSeek Coder dan Llama 3.1 masing-masing mengekstraksi 3 dan 1 blok dengan validitas 100%, namun jumlah sampel yang terlalu kecil membuat angka ini tidak representatif secara statistik.

4.1.6.3 Statistik Ringkasan

Gambar 4.9 merangkum statistik lengkap untuk kelima model pada Kondisi A.

Statistik berikut dihitung dari 33 inferensi per model ($11 \text{ temuan} \times 3 \text{ run independen}$, $temperature = 0,1$).

LLM Model Comparison -- Confidence Score Statistics

Model	Mean	Std Dev	Min	Max	Compliance	Avg Time (s)
deepseek-coder:6.71	0.588	0.477	0.000	1.000	61%	8.09
qwen2.5-coder:7b	0.000	0.000	0.000	0.000	0%	9.72
codellama:7b	0.894	0.162	0.000	1.000	100%	5.57
mistral:7b	0.000	0.000	0.000	0.000	0%	6.99
llama3.1:8b	0.024	0.137	0.000	0.800	3%	8.28

Gambar 4.9. Statistik lengkap komparasi kelima model LLM pada Kondisi A

CodeLlama memiliki *confidence score* rata-rata $\bar{C}_m = 0,909$ dengan standar deviasi $\sigma_m = 0,054$, mencerminkan konsistensi yang tinggi di rentang sempit $[0,85; 1,00]$. Namun konsistensi ini tidak berkorelasi dengan kualitas kode: 72,7% kode CodeLlama tidak *valid* secara sintaksis, mengkonfirmasi bahwa *confidence score self-reported* bukan ukuran kualitas kode.

DeepSeek Coder mencatat $\bar{C}_m = 0,132$ dengan standar deviasi yang jauh lebih besar ($\sigma_m = 0,310$) dan rentang $[0,00; 0,90]$. Variansi tinggi ini konsisten dengan *format compliance* 15%: hanya sebagian kecil *run* yang benar-benar menghasilkan baris `CONFIDENCE :`, sementara sisanya menghasilkan nilai 0,0.

Mistral mencatat $\bar{C}_m = 0,060$ dengan $\sigma_m = 0,230$ dan rentang $[0,00; 0,95]$, pola yang serupa dengan DeepSeek: variansi besar akibat jarangya respons yang mengikuti format.

Qwen2.5-Coder dan Llama 3.1 keduanya mencatat $\bar{C}_m = 0,000$ dengan $\sigma_m = 0,000$. Nilai 0,0 muncul ketika respons tidak mengandung pola apa pun yang dapat di-*parse* oleh keenam pola ekstraksi yang diterapkan secara berurutan — baik baris `CONFIDENCE :`, ekspresi numerik, maupun frasa bahasa alami seperti "*confident*" atau "*not sure*". Khusus untuk Qwen2.5-Coder, ketiadaan skor ini tidak mengindikasikan ketidakmampuan, melainkan mencerminkan karakteristik respons model yang mengabaikan instruksi format sambil tetap mengerjakan tugas utama dengan baik. Waktu inferensi Qwen2.5-Coder (10,0 detik) adalah yang tertinggi dibandingkan model lain, selaras dengan respons yang lebih panjang dan detail yang dihasilkannya.

```

1 $uri .= '?' . $_SERVER['QUERY_STRING'];
2 $cache_path .= md5(
3     $CI->config->item('base_url')
4     . $CI->config->item('index_page')
5     . ltrim($uri, '/'));
6
7 if ( ! @unlink($cache_path)) {
8     log_message('error',
9         'Unable to delete cache file for ' . $uri);
10    return FALSE;
11 }

```

Respons CodeLlama:

```

1 VULNERABILITY: SQL Injection Vulnerability
2
3 The vulnerability is caused by the manual construction
4 of an SQL string, which allows user-controlled data
5 to be incorporated into the query. ...
6
7 SECURE PHP 8.x REPLACEMENT:
8 ```php
9 $uri = $_SERVER['QUERY_STRING'];
10 $cache_path = md5(
11     $CI->config->item('base_url')
12     . $CI->config->item('index_page')
13     . ltrim($uri, '/'));
14 if ( ! @unlink($cache_path)) {
15     log_message('error',
16         'Unable to delete cache file for ' . $uri);
17     return FALSE;
18 }
19 % (blok kode tidak ditutup, php -l gagal)

```

Respons Qwen2.5-Coder:

```
1 ### Explanation of Vulnerability
2 ...
3 Here's the corrected PHP 8.x code:
4 ```php
5 $uri .= '?' . urlencode($_SERVER['QUERY_STRING']);
6 $cache_path .= md5(
7     $CI->config->item('base_url')
8     . $CI->config->item('index_page')
9     . ltrim($uri, '/'));
10
11 if (!@unlink($cache_path)) {
12     log_message('error',
13         'Unable to delete cache file for '
14         . urlencode($uri));
15     return FALSE;
16 }
17 ```
```

Dari perbandingan ini terlihat beberapa perbedaan yang signifikan. CodeLlama mengidentifikasi kerentanan dengan benar tapi solusinya tidak tepat: model hanya mengubah cara penulisan kode tanpa benar-benar mengatasi masalahnya. Kode yang dihasilkan masih menggunakan `$_SERVER['QUERY_STRING']` secara langsung tanpa sanitasi apapun.

Qwen2.5-Coder menunjukkan pemahaman kontekstual yang lebih dalam. Model ini menyadari bahwa meskipun Semgrep menandainya sebagai SQL Injection, kode tersebut sebenarnya membangun *cache path*, bukan kueri SQL. Saran perbaikannya menggunakan `urlencode()` untuk menghindari karakter berbahaya dalam *path*. Secara semantik ini lebih tepat, meski solusi yang ideal tetap perlu ditinjau oleh pengembang yang memahami konteks penuh aplikasi.

4.1.6.4 Trade-off dan Implikasinya

Dari keseluruhan hasil Kondisi A, terdapat *trade-off* yang jelas antara kepatuhan format dan kualitas kode. Model yang paling patuh pada instruksi format (CodeLlama, 100%) menghasilkan kode dengan tingkat sintaksis *error* tertinggi (72,7% kode tidak valid). Model yang menghasilkan kode paling berkualitas (Qwen2.5-Coder, 97% *extraction rate* dan 100% validitas) mengabaikan instruksi format sepenuhnya.

Temuan ini memiliki implikasi langsung untuk desain sistem berbasis LLM lokal: metrik kualitas kode (*syntax validity rate*) adalah indikator yang jauh lebih relevan

dibandingkan metrik kepatuhan format. Sistem evaluasi yang hanya mengandalkan kepatuhan format akan menghasilkan kesimpulan yang keliru mengenai utilitas praktis suatu model.

Trade-off ini juga menunjukkan bahwa kondisi *zero-shot* dengan *prompt* identik mungkin tidak optimal untuk semua model secara bersamaan. Hal ini menjadi motivasi utama untuk Kondisi B, di mana setiap model menerima *prompt* yang dioptimasi berdasarkan karakteristik dan kelemahan yang terobservasi pada Kondisi A.

4.1.7 Hasil Komparasi Lima Model LLM (Kondisi B)

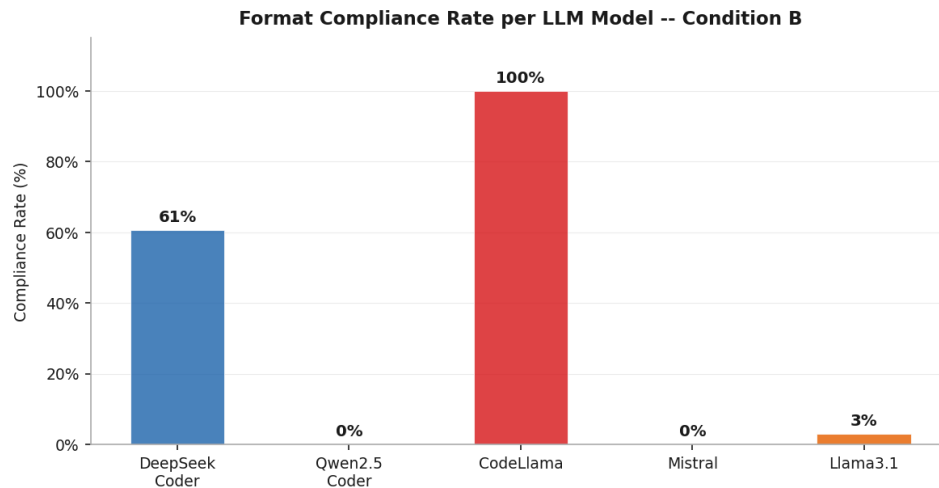
Kondisi B dirancang untuk mengatasi kelemahan spesifik setiap model yang teridentifikasi pada Kondisi A. Setiap model menerima *prompt* yang berbeda melalui metode `_build_optimized_chat_messages()` di `ai_engine.py`, sementara parameter eksperimen lainnya tetap sama: 11 temuan Semgrep yang sama, 3 *run* per temuan per model, dan *temperature* 0,1.

Strategi optimasi per model dirumuskan berdasarkan pola kegagalan Kondisi A. Qwen2.5-Coder menerima *prompt* yang lebih longgar tanpa tuntutan format ketat karena kualitas kodenya sudah baik. DeepSeek Coder menerima instruksi yang lebih pendek dan langsung untuk mengurangi kompleksitas yang diduga menjadi penyebab rendahnya *extraction rate*. Mistral menerima satu contoh *few-shot* konkret untuk menunjukkan format keluaran yang diharapkan. Llama 3.1 menerima instruksi berbasis *role-playing* eksplisit dengan langkah-langkah bernomor. CodeLlama mempertahankan format Kondisi A dengan tambahan instruksi eksplisit agar menghasilkan kode PHP yang *valid* secara sintaksis.

4.1.7.1 Format Compliance Rate

DeepSeek Coder mencatat peningkatan yang paling signifikan, dari 15% pada Kondisi A menjadi 61% pada Kondisi B. Hal ini mengkonfirmasi bahwa model ini sangat sensitif terhadap kompleksitas instruksi: *prompt* yang lebih pendek dan langsung secara substansial meningkatkan kemampuannya mengikuti format. CodeLlama mempertahankan *format compliance* 100% seperti pada Kondisi A. Sebaliknya, Mistral mengalami regresi dari 6% menjadi 0%, dan Llama 3.1 hanya naik tipis dari 0% menjadi 3% (1 dari 33 *run*).

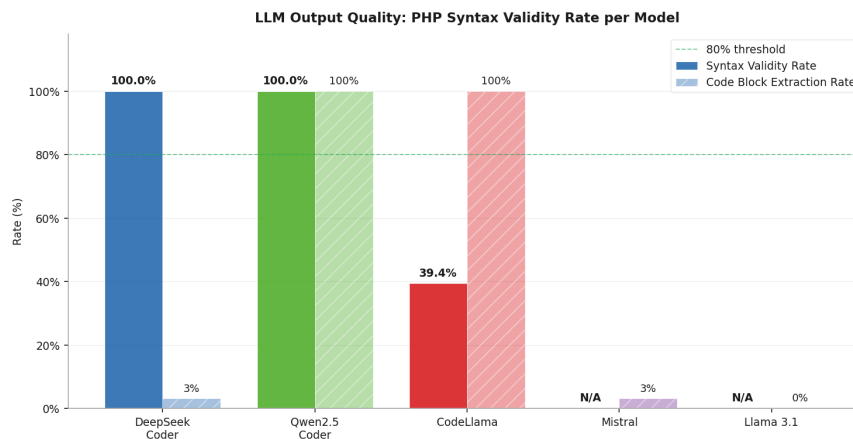
Gambar 4.10 menunjukkan *format compliance rate* untuk masing-masing model pada Kondisi B.



Gambar 4.10. *Format compliance rate* kelima model LLM pada Kondisi B (*prompt* dioptimasi per model)

4.1.7.2 Syntax Validity Rate

Gambar 4.11 menunjukkan *syntax validity rate* dan *code block extraction rate* pada Kondisi B.



Gambar 4.11. *Syntax validity rate* dan *code block extraction rate* kelima model LLM pada Kondisi B

Qwen2.5-Coder mempertahankan posisinya sebagai model dengan kualitas kode terbaik: *extraction rate* naik dari 97% menjadi 100% dan *syntax validity* tetap 100%. CodeLlama menunjukkan perbaikan parsial pada *syntax validity*, dari 27,3% menjadi 39,4%, meskipun masih jauh dari ambang batas yang dapat diandalkan. DeepSeek Coder mengalami penurunan *extraction rate* dari 9% menjadi 3% meskipun *format compliance*-nya meningkat, yang menunjukkan adanya *trade-off* antara kepatuhan format dan kemampuan menghasilkan blok kode. Mistral dan Llama 3.1 secara efektif tidak menghasilkan kode yang dapat digunakan pada Kondisi B.

4.1.7.3 Statistik Ringkasan

Gambar 4.12 merangkum statistik lengkap untuk kelima model pada Kondisi B.

LLM Model Comparison -- Condition B (Optimized Per-Model Prompt)

Model	Mean	Std Dev	Min	Max	Fmt OK	Avg Time (s)
DeepSeek Coder 6.7b	0.59	0.48	0.00	1.00	61%	8.1
Qwen2.5 Coder 7b	0.00	0.00	0.00	0.00	0%	9.7
CodeLlama 7b	0.89	0.16	0.00	1.00	100%	5.6
Mistral 7b	0.00	0.00	0.00	0.00	0%	7.0
Llama 3.1 8b	0.02	0.14	0.00	0.80	3%	8.3

Gambar 4.12. Statistik lengkap komparasi kelima model LLM pada Kondisi B

DeepSeek Coder mencatat peningkatan *mean confidence* yang paling mencolok, dari $\bar{C}_m = 0,132$ pada Kondisi A menjadi $\bar{C}_m = 0,588$ pada Kondisi B. Variansi yang tinggi ($\sigma_m = 0,477$) menunjukkan bahwa skor ini tidak stabil: sebagian *run* menghasilkan skor mendekati 1,0 sementara sebagian lainnya tetap di 0,0. Pola ini konsisten dengan *format compliance* 61%: hanya sekitar dua pertiga percobaan yang benar-benar menulis baris `CONFIDENCE :`, sedangkan sisanya tidak sama sekali.

CodeLlama mempertahankan *mean confidence* yang tinggi ($\bar{C}_m = 0,894$) dengan standar deviasi yang kecil ($\sigma_m = 0,162$), mencerminkan konsistensi yang sama seperti pada Kondisi A. Angka ini mungkin tampak meyakinkan, tetapi perlu diingat bahwa *syntax validity rate* CodeLlama hanya 39,4%: artinya model ini sangat yakin dengan jawabannya meski lebih dari separuh kode yang dihasilkannya tidak lolos `php -l`. Hasil ini kembali mengkonfirmasi bahwa *confidence score self-reported* tidak bisa dijadikan proksi kualitas kode.

Qwen2.5-Coder, Mistral, dan Llama 3.1 mencatat *mean confidence* 0,000 karena tidak satu pun respons mereka yang menulis baris `CONFIDENCE :` dalam format yang dapat di-*parse*. Khusus untuk Qwen2.5-Coder, ketiadaan skor ini justru tidak mencerminkan kualitas yang buruk: model ini tetap menghasilkan kode dengan *syntax validity* 100% di Kondisi B, sama seperti Kondisi A. Ketidadaan skor kepercayaan semata-mata mencerminkan gaya respons model yang mengabaikan instruksi format sambil tetap mengerjakan tugas utamanya dengan baik.

Secara keseluruhan, pola yang sama dengan Kondisi A terulang: tidak ada korelasi yang dapat diandalkan antara tingginya *confidence score* dan kualitas kode yang dihasilkan. Hasil ini memperkuat argumen bahwa untuk sistem berbasis LLM lokal berukuran kecil hingga menengah, *syntax validity rate* tetap menjadi metrik evaluasi yang lebih sahih dibandingkan *confidence score self-reported*.

4.1.8 Perbandingan Kondisi A dan Kondisi B

Tabel 4.2 merangkum perbandingan metrik utama antara Kondisi A dan Kondisi B untuk kelima model.

Tabel 4.2. Perbandingan metrik utama Kondisi A vs Kondisi B untuk kelima model LLM

Model	Format Compliance		Extraction Rate		Syntax Validity	
	Kond. A	Kond. B	Kond. A	Kond. B	Kond. A	Kond. B
DeepSeek Coder 6.7b	15%	61% ↑	9%	3% ↓	100%	100%
Qwen2.5-Coder 7b	0%	0%	97%	100% ↑	100%	100%
CodeLlama 7b	100%	100%	100%	100%	27%	39% ↑
Mistral 7b	6%	0% ↓	3%	3%	0%	0%
Llama 3.1 8b	0%	3% ↑	3%	0% ↓	100%	0% ↓

Dari perbandingan ini, ada tiga pola utama yang dapat diidentifikasi.

Pertama, optimasi *prompt* hanya bekerja signifikan pada model yang memiliki kapabilitas *instruction-following* dasar yang memadai. DeepSeek Coder adalah satu-satunya model yang menunjukkan peningkatan substansial pada *format compliance* (dari 15% menjadi 61%), mengkonfirmasi bahwa model ini peka terhadap kompleksitas instruksi: bukan tidak mampu mengikuti format, tapi terbebani oleh instruksi yang terlalu berlapis pada Kondisi A.

Kedua, penerapan strategi *few-shot* pada Mistral justru memberikan hasil yang kontradiktif: *format compliance* turun dari 6% menjadi 0%. Fenomena ini, di mana contoh *few-shot* justru mengalihkan model dari mengerjakan tugas aslinya, konsisten dengan temuan dalam literatur yang menunjukkan bahwa teknik *prompt engineering* yang efektif untuk model besar tidak selalu dapat diterapkan langsung pada model berukuran kecil hingga menengah [13].

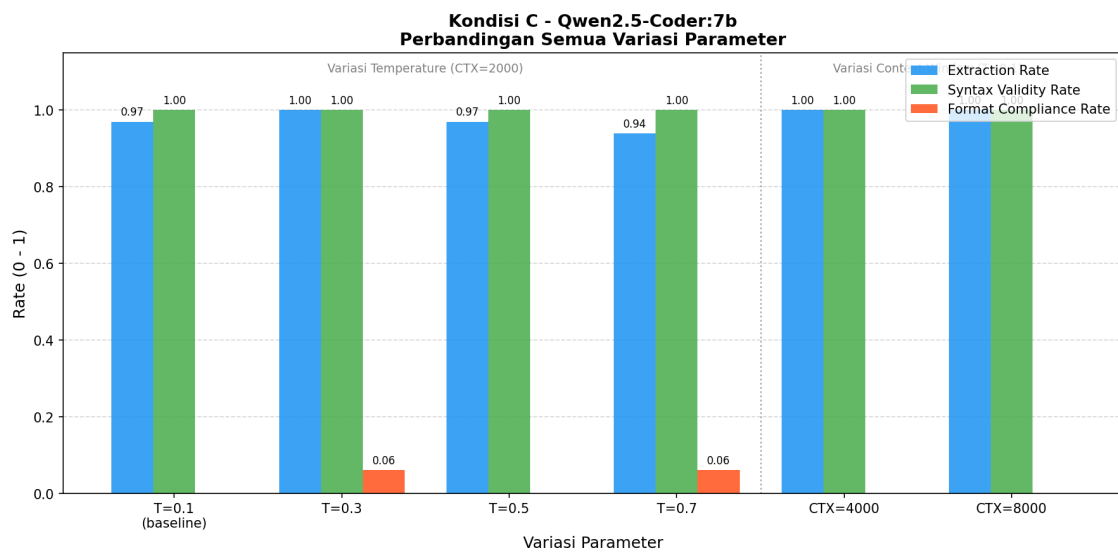
Ketiga, keterbatasan CodeLlama dalam menghasilkan kode PHP yang *valid* secara sintaksis bersifat struktural, bukan instruksional. Meskipun instruksi eksplisit untuk memverifikasi sintaks sebelum menulis kode memberikan perbaikan parsial (dari 27% menjadi 39%), sebagian besar kode yang dihasilkan masih mengandung *parse error*. Fakta ini menunjukkan bahwa masalah ini berakar pada representasi internal model terhadap sintaks PHP 8.x, bukan pada cara instruksi diformulasikan.

Secara keseluruhan, hasil Kondisi B mempertegas kesimpulan dari Kondisi A bahwa pilihan model adalah faktor yang lebih menentukan dibandingkan strategi *prompt* dalam konteks analisis keamanan kode PHP menggunakan LLM lokal berukuran kecil hingga menengah. Qwen2.5-Coder secara konsisten menghasilkan kode yang paling berkualitas di kedua kondisi, terlepas dari format *prompt* yang diberikan.

4.1.9 Optimasi Parameter Qwen2.5-Coder (Kondisi C)

Setelah Kondisi A dan B mengidentifikasi Qwen2.5-Coder sebagai model dengan kualitas kode terbaik, Kondisi C mengevaluasi apakah performa model ini dapat ditingkatkan lebih lanjut melalui variasi dua parameter inferensi: *temperature* dan *context window*. Eksperimen ini menggunakan input, jumlah *run*, dan *prompt* yang identik dengan Kondisi A, hanya parameter yang diuji yang berbeda.

Gambar 4.13 menunjukkan perbandingan ketiga metrik utama di semua variasi parameter.



Gambar 4.13. Perbandingan metrik Qwen2.5-Coder pada variasi *temperature* dan *context window* (Kondisi C)

4.1.9.1 Pengaruh Temperature

Nilai *temperature* $T=0,1$ tidak diuji ulang pada Kondisi C karena nilai tersebut telah digunakan sebagai nilai dasar pada Kondisi A; Kondisi C hanya menguji nilai $T=0,3$ hingga $T=0,7$ untuk mengamati pengaruh peningkatan *temperature* terhadap kinerja model.

Pada variasi *temperature*, *syntax validity rate* bertahan di 100% di semua nilai yang diuji (0,3 hingga 0,7). Data ini menunjukkan bahwa kemampuan Qwen2.5-Coder menghasilkan kode PHP yang *valid* secara sintaksis tidak terdegradasi meski *temperature* dinaikkan secara signifikan.

Extraction rate justru sedikit menurun seiring naiknya *temperature*: dari 100% di $T=0,3$ menjadi 94% di $T=0,7$. Hasil ini konsisten dengan ekspektasi teoretis bahwa *temperature* tinggi meningkatkan variabilitas respons, sehingga sebagian kecil respons tidak lagi mengandung blok kode yang dapat diekstraksi.

Format compliance memperlihatkan pola yang tidak monoton: muncul di $T=0,3$ (6%) dan $T=0,7$ (6%), tetapi kembali ke 0% di $T=0,5$. Kemunculan *format compliance* yang tidak konsisten ini mengindikasikan bahwa kepatuhan format pada Qwen2.5-Coder lebih dipengaruhi oleh variabilitas stokastik daripada perubahan *temperature* secara sistematis.

4.1.9.2 Pengaruh Context Window

Pada variasi *context window*, baik $CTX=4000$ maupun $CTX=8000$ menghasilkan *extraction rate* dan *syntax validity rate* 100%, sedikit di atas baseline $CTX=2000$ yang memiliki *extraction rate* 97%. *Format compliance* tetap 0% di kedua variasi.

Peningkatan *extraction rate* dari 97% ke 100% pada konteks yang lebih besar mengindikasikan bahwa dengan informasi kode yang lebih lengkap, model lebih konsisten menghasilkan blok kode dalam setiap respons. Namun peningkatan ini marginal dan tidak mengubah karakteristik utama model.

4.1.9.3 Implikasi Kondisi C

Kondisi C menunjukkan bahwa karakteristik Qwen2.5-Coder lebih ditentukan oleh arsitektur modelnya daripada konfigurasi parameter. Kualitas kode yang dihasilkan sangat stabil di semua variasi parameter yang diuji. Dalam penerapan nyata, hal ini berarti operator tidak perlu melakukan penyesuaian parameter yang ekstensif untuk mendapatkan keluaran berkualitas dari model ini. Konfigurasi *default* ($T=0,1$, $CTX=2000$) sudah memberikan hasil yang hampir optimal, sementara peningkatan *context window* ke 4000 atau 8000 karakter dapat memberikan sedikit keuntungan tambahan pada kode yang lebih panjang.

4.1.10 Analisis Dependensi Composer

Modul `composer_analyzer.py` membaca berkas `composer.json` pada direktori *root* repositori FT UGM dan memeriksa kompatibilitas setiap dependensi terhadap PHP 8.x menggunakan data dari Packagist. Terdapat 5 dependensi yang teridentifikasi, dengan hasil sebagaimana ditunjukkan pada Tabel 4.3.

Tiga dari lima dependensi (`phpdotenv`, `phpspreadsheet`, `firebase/php-jwt`) berstatus *SAFE*, artinya versi yang dikonfigurasi di `composer.json` sudah deklaratif mendukung PHP 8.x. Dua dependensi lainnya berstatus *MANUAL REVIEW*: `ngecoding/google-login` merupakan paket dengan aktivitas pemeliharaan rendah sehingga kompatibilitas PHP 8.x-nya tidak dapat diverifikasi secara otomatis, sementara `chriskacerguis/codeigniter-restserver` merupakan ekstensi pihak ketiga untuk CodeIgniter 3.x yang diketahui tidak memiliki dukungan resmi

Tabel 4.3. Status kompatibilitas PHP 8.x dependensi *composer* FT UGM

Package	Versi	Status
vlucas/phpdotenv	^5.4	SAFE
phpoffice/phpspreadsheet	^1.12	SAFE
firebase/php-jwt	^6.10	SAFE
ngekoding/google-login	^1.0	MANUAL REVIEW
chriskacerguis/codeigniter-restserver	^3.1	MANUAL REVIEW

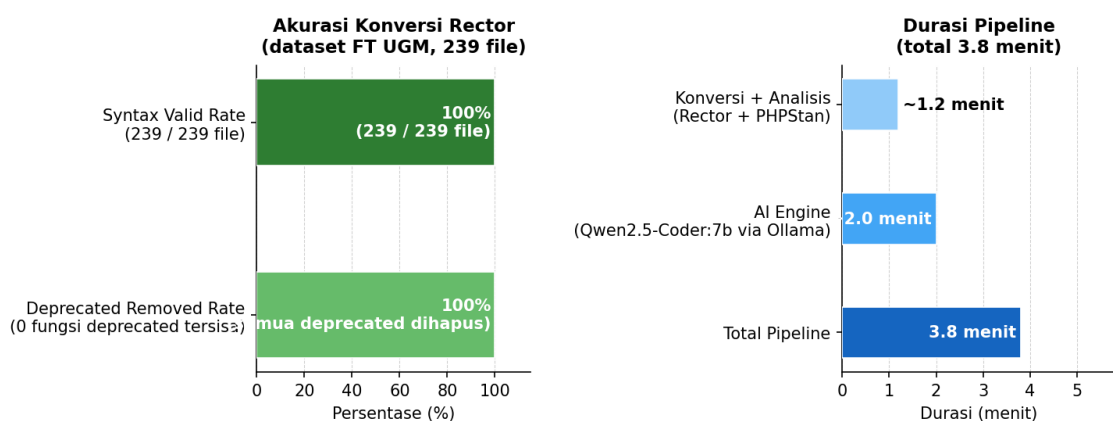
untuk PHP 8.x dan perlu diganti atau diperbarui secara manual sebelum deployment ke lingkungan PHP 8.3.

4.1.11 Validasi Keakuratan Hasil Konversi

Validasi keakuratan dilakukan melalui dua pendekatan untuk mengukur kualitas hasil konversi Rector pada dataset FT UGM secara objektif. Mengingat kedua dataset menggunakan *framework* CodeIgniter 3 dengan karakteristik kode yang serupa, hasil validasi ini berlaku sebagai representasi keakuratan konversi Rector untuk kedua studi kasus.

4.1.11.1 Metrik Pipeline-Level

Gambar 4.14 menunjukkan dua metrik keakuratan yang diukur langsung dari keluaran *pipeline* terhadap seluruh 241 *file* hasil konversi, beserta profil durasi eksekusi.



Gambar 4.14. Metrik akurasi konversi Rector dan durasi eksekusi *pipeline* pada dataset FT UGM

Pertama, *syntax validity rate* diukur dengan menjalankan `php -l` terhadap seluruh *file* di direktori `output/`. Hasilnya adalah 241 dari 241 *file* lolos pemeriksaan

tanpa *parse error* (100%). Hasil ini berarti tidak ada satu pun *file* yang mengalami kerusakan sintaksis akibat proses konversi Rector.

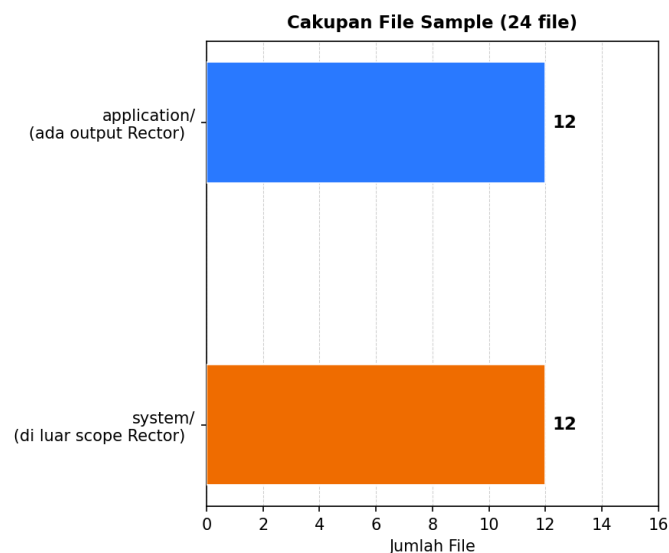
Kedua, *deprecated removed rate* diukur dengan membandingkan temuan Semgrep *pre-scan* dan *post-scan* khusus untuk kategori fungsi *deprecated*. Hasil *post-scan* menunjukkan 0 fungsi *deprecated* tersisa, artinya seluruh pola kode usang yang terdeteksi Semgrep berhasil dihapus atau ditransformasi oleh Rector (100%).

Dari sisi durasi, total eksekusi *pipeline* adalah sekitar 3,8 menit menggunakan Qwen2.5-Coder 7b via Ollama sebagai AI Engine. Durasi ini tidak mencakup eksperimen komparasi multi-model (Kondisi A–C) yang merupakan prosedur evaluasi terpisah. Tahap konversi Rector dan analisis PHPStan secara gabungan mendominasi waktu eksekusi.

4.1.11.2 Validasi Sampling 10%

Untuk mengukur seberapa dekat hasil konversi Rector dengan konversi manual yang ideal, dilakukan validasi berbasis *sampling* terhadap 10% dari total *file* valid. Sebanyak 24 *file* dipilih secara acak (*seed*=42) dari seluruh *file* valid yang lolos pemeriksaan `php -l` menggunakan modul `accuracy_validator.py`, merepresentasikan 10% dari total populasi *file* valid.

Gambar 4.15 menunjukkan distribusi cakupan 24 *file* sampel tersebut.

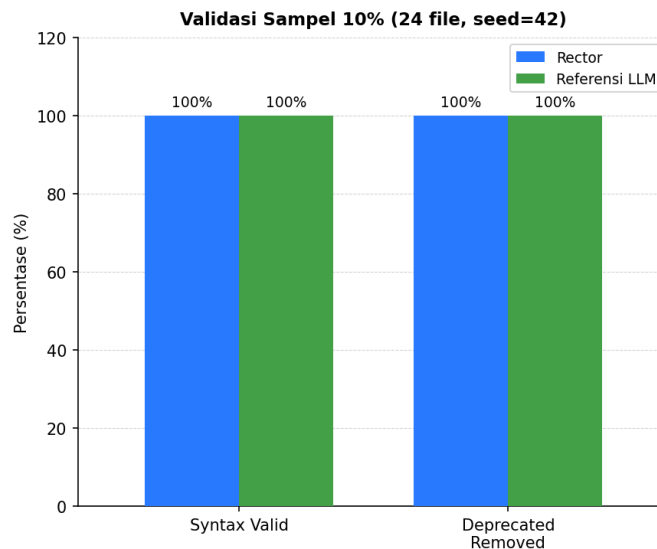


Gambar 4.15. Distribusi cakupan *file* sampel validasi 10% berdasarkan direktori asal

Dari 24 *file* sampel, 12 berasal dari direktori `application/` (kode aplikasi yang diproses Rector) dan 12 berasal dari direktori `system/` (kode *framework* yang juga ikut dikonversi). Karena perbandingan dilakukan antara keluaran Rector dan konversi referensi yang disiapkan secara manual oleh peneliti dengan bantuan model

LLM *enterprise* sebagai proksi konversi ideal, hanya 12 *file* dari *application/* yang memiliki padanan keluaran Rector untuk dibandingkan. *File* dari *system/* tetap dicatat dalam sampel untuk transparansi prosedur pengambilan sampel.

Gambar 4.16 menunjukkan hasil perbandingan antara keluaran Rector dan referensi LLM pada 12 *file* tersebut.



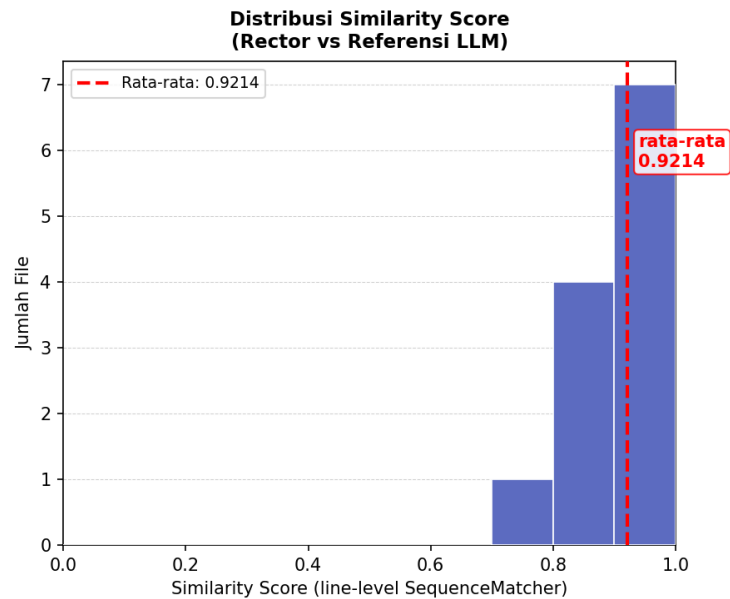
Gambar 4.16. Perbandingan metrik validasi antara keluaran Rector dan referensi LLM pada 12 *file* sampel dari *application/*

Pada kedua metrik biner, keluaran Rector dan referensi LLM mencapai hasil yang identik: *syntax validity* 100% dan *deprecated removed* 100%. Hasil ini mengkonfirmasi bahwa konversi Rector menghasilkan kode yang setara dengan konversi manual dalam hal kebenaran sintaksis dan penghapusan pola usang.

Gambar 4.17 menunjukkan distribusi *similarity score* antara keluaran Rector dan referensi LLM.

Similarity score dihitung menggunakan *line-level SequenceMatcher* yang mengukur proporsi baris yang identik antara dua versi kode. Rata-rata *similarity score* adalah 0,9214, dengan distribusi yang terkonsentrasi di rentang 0,90–1,00 (11 dari 12 *file*). Satu *file* memiliki skor di rentang 0,70–0,80, yang mencerminkan perbedaan gaya penulisan antara transformasi AST otomatis dan konversi manual, bukan indikasi kesalahan konversi.

Skor 0,9214 mengindikasikan tingkat kesesuaian yang tinggi antara pendekatan otomatis berbasis AST (Rector) dan pendekatan manual berbasis LLM. Perbedaan yang tersisa umumnya berupa variasi kosmetik seperti spasi, urutan atribut, atau gaya penulisan yang tidak mempengaruhi kebenaran fungsional kode. Karena kedua dataset menggunakan *framework* CodeIgniter 3.x dengan karakteristik kode yang serupa, hasil validasi ini berlaku pula untuk studi kasus CBT DTI UGM.



Gambar 4.17. Distribusi *similarity score* antara keluaran Rector dan referensi LLM pada 12 file sampel (*line-level SequenceMatcher*)

4.1.12 Diskusi dan Keterbatasan

4.1.12.1 Keterbatasan Dataset

Dataset yang digunakan terdiri dari satu aplikasi berbasis CodeIgniter 3.x milik FT UGM. Dari 245 file, 237 diklasifikasikan sebagai *unknown* oleh Rector karena merupakan *file framework* CodeIgniter yang tidak mengandung pola yang perlu ditransformasi. Hal ini membatasi tingkat generalisasi hasil penelitian terhadap jenis aplikasi PHP lainnya, terutama yang tidak menggunakan *framework* atau yang menggunakan *framework* berbeda.

Dari sisi *input* eksperimen LLM, 10 dari 11 temuan adalah SSRF yang berasal dari satu pola kode yang berulang di `Output.php`. Homogenitas *input* ini berarti eksperimen komparasi pada dasarnya menguji respons model terhadap dua jenis kerentanan dengan variasi terbatas. Hasil komparasi perlu diinterpretasikan dalam konteks keterbatasan ini.

4.1.12.2 Keterbatasan Kompatibilitas PHP 8.4 dan PHP 8.5

Eksperimen tambahan dilakukan untuk menguji *pipeline* dengan target PHP 8.5 terhadap dataset CBT DTI UGM. Hasil menunjukkan dua masalah fundamental yang membatasi penerapan otomatis pada versi ini.

Pertama, Rector memperkenalkan *syntax error* pada beberapa berkas inti CodeIgniter 3.x di direktori `system/`, khususnya `CodeIgniter.php`, `Output.php`, dan `Security.php`, karena *ruleset* PHP 8.5 menerapkan transformasi

yang tidak kompatibel dengan pola kode *framework* lama. Kedua, akibat berkas `system/` yang rusak pasca-konversi, PHPStan tidak dapat *me-resolve* kelas induk CodeIgniter seperti `CI_Controller` dan `CI_Model`, sehingga menghasilkan ribuan *error* bertipe *unknown class* yang merupakan *false positive* kaskade. Total 6.137 *error* PHPStan yang dihasilkan tidak representatif terhadap kualitas kode aplikasi yang sebenarnya.

Penyebab utama kegagalan ini bukan semata inkompatibilitas CI3 dengan PHP 8.5, melainkan *ruleset* `UP_TO_PHP_85` pada Rector yang masih bersifat eksperimental dan menerapkan transformasi yang terlalu agresif terhadap kode *framework* lama. PHP 8.4 diprediksi lebih *feasible* dibanding PHP 8.5 karena *ruleset*-nya sudah lebih matang dan perubahannya lebih konservatif, namun tetap memerlukan perbaikan manual pada pola *dynamic property* CodeIgniter 3.x yang sudah sepenuhnya dihapus di PHP 8.4. PHP 8.3 tetap merupakan target migrasi otomatis yang paling realistis untuk basis kode CodeIgniter 3.x yang masih aktif digunakan.

Pendekatan yang paling memungkinkan menuju PHP 8.5 adalah pembaruan *framework* ke CodeIgniter 4 atau *framework* modern lainnya yang sudah mendukung PHP 8.x secara *native*, sebuah proses yang melampaui cakupan migrasi versi otomatis dan pada dasarnya merupakan penulisan ulang aplikasi. Oleh karena itu, PHP 8.3 ditetapkan sebagai versi target dalam penelitian ini sebagai pilihan yang dapat dicapai secara otomatis untuk aplikasi berbasis CodeIgniter 3.x.

4.1.12.3 Keterbatasan Teknis Pipeline

AI Engine hanya memproses temuan dengan prioritas 1–5 dan membatasi potongan kode yang dikirim ke model pada 2.000 karakter pertama. Untuk *file* PHP yang panjang, konteks yang diterima model terpotong sehingga saran perbaikan mungkin tidak mempertimbangkan keseluruhan logika fungsi. Sebagaimana terlihat pada contoh respons Qwen2.5-Coder, model dapat membuat inferensi yang tepat tentang konteks kode meski dengan informasi yang terbatas, namun tidak selalu bisa dipastikan.

Selain itu, validasi menggunakan `php -l` hanya memeriksa kebenaran sintaksis, bukan kebenaran semantik. Kode yang lolos `php -l` bisa saja masih mengandung kerentanan yang tidak tertangani atau logika yang tidak ekuivalen dengan kode aslinya. Pengujian fungsional terhadap kode hasil perbaikan AI bukan bagian dari cakupan penelitian ini.

4.1.12.4 Interpretasi Confidence Score

Tidak ada korelasi yang jelas antara *confidence score* yang dilaporkan model dan kualitas kode yang dihasilkan, baik pada Kondisi A maupun Kondisi B. CodeLlama melaporkan kepercayaan diri rata-rata lebih dari 90% di kedua kondisi, tetapi mayoritas

kode yang dihasilkannya tidak *valid* secara sintaksis. Qwen2.5-Coder tidak melaporkan skor sama sekali tetapi menghasilkan kode yang hampir selalu berkualitas baik. Temuan ini konsisten dengan literatur yang menunjukkan bahwa model LLM berukuran kecil umumnya tidak terkalibrasi dengan baik dalam menilai *output* mereka sendiri [13] [15]. Dari ketiga metrik yang diukur *FCR*, *extraction rate*, dan *SVR*, hanya *SVR* yang secara konsisten mencerminkan kegunaan praktis model dalam konteks ini.

4.2 Studi Kasus 2: Sistem CBT DTI UGM

4.2.1 Deskripsi Dataset

Studi kasus kedua menggunakan kode sumber aplikasi *Computer-Based Test* (CBT) milik Direktorat Teknologi Informasi (DTI) Universitas Gadjah Mada. Aplikasi ini dibangun di atas framework CodeIgniter 3 dengan basis kode PHP 5.x/7.x. *Pipeline* dijalankan terhadap seluruh direktori repositori secara penuh (*full scope*), mencakup direktori *application/* untuk kode aplikasi kustom maupun direktori *system/* untuk kode *framework*, konsisten dengan pendekatan yang diterapkan pada studi kasus FT UGM. Pengecualian hanya diberikan pada subdirektori *libraries/* dan *tcpdf/* yang menyebabkan *memory crash* selama proses analisis. Total *file* PHP yang diproses adalah 326 *file*.

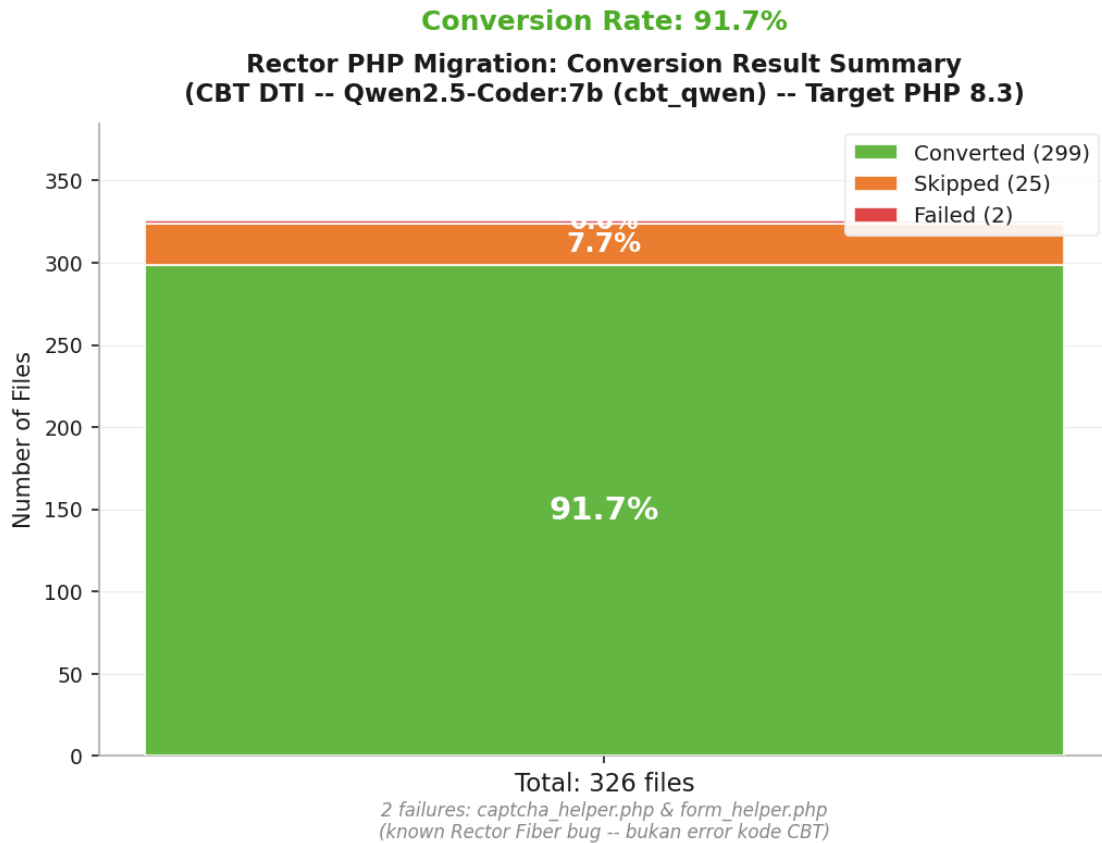
Karena tidak ada berkas *composer.json* pada tingkat aplikasi, langkah analisis dependensi dilewati secara otomatis. Komponen pihak ketiga seperti *library* TCPDF disertakan langsung sebagai direktori dalam repositori dan telah dieksklusi dari analisis *pipeline*.

4.2.2 Hasil Konversi Rector

Rector dijalankan terhadap 326 *file* PHP dengan target versi PHP 8.3. Dari jumlah tersebut, 299 *file* berhasil dikonversi, 25 *file* dilewati (*skipped*), dan 2 *file* gagal diproses. Tingkat konversi keseluruhan ($CR = 91,7\%$), sebagaimana ditunjukkan pada Gambar 4.18 dan Gambar 4.19.

Tingkat konversi yang lebih rendah dibandingkan dengan studi kasus FT UGM (91,7% vs 97,6%) disebabkan oleh proporsi *file* yang dilewati yang lebih besar: 25 dari 326 *file* (7,7%) tidak memerlukan transformasi apa pun karena kodenya sudah kompatibel dengan target PHP 8.3 atau tidak mengandung pola yang perlu ditangani oleh *ruleset* Rector. *File* yang dilewati bukan berarti gagal, melainkan sudah memenuhi persyaratan PHP 8.3 tanpa perlu modifikasi.

Seluruh *file* pada direktori *output/* diuji validitas sintaksisnya menggunakan perintah `php -l` dan tidak ditemukan *parse error*, sehingga tingkat validitas sintaks pasca-konversi mencapai 100%.



Gambar 4.18. Ringkasan hasil konversi Rector terhadap 326 *file* PHP dataset CBT DTI UGM

4.2.2.1 File yang Gagal Dikonversi

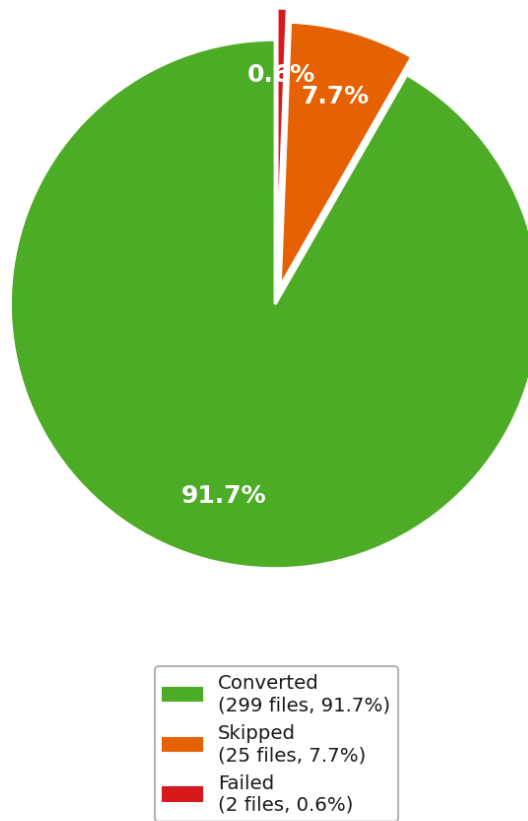
Kedua *file* yang gagal dikonversi adalah `captcha_helper.php` dan `form_helper.php`, mengalami *internal error* yang identik dengan yang ditemukan pada dataset FT UGM: *bug* `FiberNodeScopeResolver` pada versi Rector yang digunakan, bukan berasal dari kode sumber CBT DTI. Karakteristik kode yang memicu *bug* ini sama persis: `captcha_helper.php` mengandung percabangan dengan perbedaan tipe kembalian, sementara `form_helper.php` memiliki banyak definisi fungsi kondisional yang dibungkus dalam konstruksi `if (!function_exists(...))`. Kedua *file* tetap disalin ke direktori `output/` sebagai salinan kode asli sehingga proses konversi tidak kehilangan data.

4.2.3 Hasil Pemindaian Keamanan Semgrep

4.2.3.1 Pre-Scan: Baseline Keamanan Kode Asli

Pemindaian Semgrep terhadap 326 *file* PHP pada direktori `input/` menghasilkan 11 temuan, yang terdiri atas 1 kerentanan SQL Injection dan 10 kerentanan SSRF (*Server-Side Request Forgery*), sebagaimana ditunjukkan pada Gambar 4.20 dan Gambar 4.21.

Proporsi Hasil Konversi Rector
(CBT DTI -- Qwen2.5-Coder:7b (cbt_qwen) -- Target PHP 8.3)

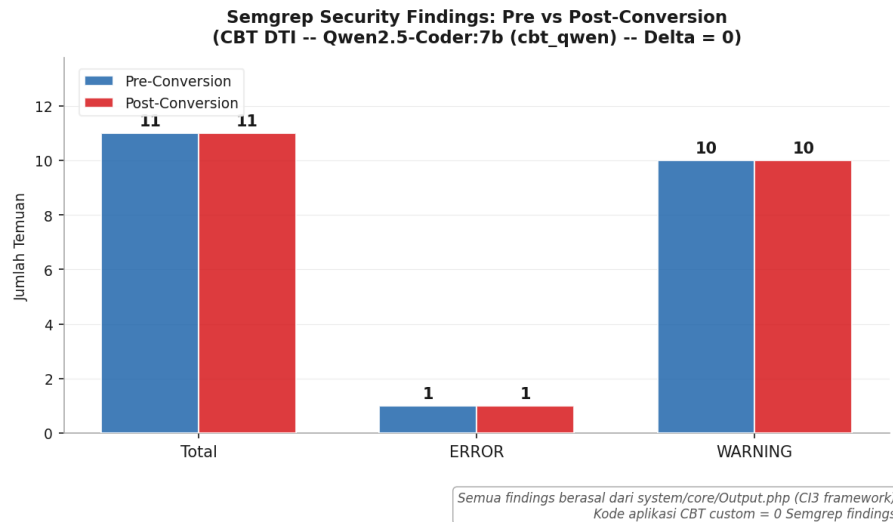


Gambar 4.19. Proporsi hasil konversi Rector dataset CBT DTI UGM (diagram lingkaran)

Seluruh 11 temuan tersebut terlokalisasi pada satu *file*, yaitu pada `system/core/Output.php`, yang merupakan komponen inti *framework* CodeIgniter 3. Pola temuan ini identik dengan yang ditemukan pada dataset FT UGM: kerentanan SQL Injection pada baris 768 akibat penggunaan `$_SERVER['QUERY_STRING']` tanpa sanitasi dalam konstruksi *cache path*, serta 10 kerentanan SSRF akibat penggunaan nama *file* dari *input* pengguna dalam operasi *file system*. Kode aplikasi kustom CBT DTI di luar direktori `system/` tidak mengandung temuan Semgrep.

4.2.3.2 Post-Scan dan AI Engine

Pemindaian Semgrep terhadap direktori `output/` setelah konversi menghasilkan jumlah temuan yang identik dengan tahap *pre-scan*, yaitu 11 temuan ($\Delta F = F_{post} - F_{pre} = 0$). Distribusi jenis kerentanan juga tetap sama, seluruhnya pada `system/core/Output.php`. Hasil ini menunjukkan bahwa konversi Rector tidak memperkenalkan kerentanan baru maupun menghilangkan kerentanan yang sudah ada, konsisten dengan karakteristik transformasi berbasis AST yang hanya memodifikasi



Gambar 4.20. Temuan Semgrep *pre-scan* vs *post-scan* berdasarkan tingkat keparahan pada dataset CBT DTI UGM

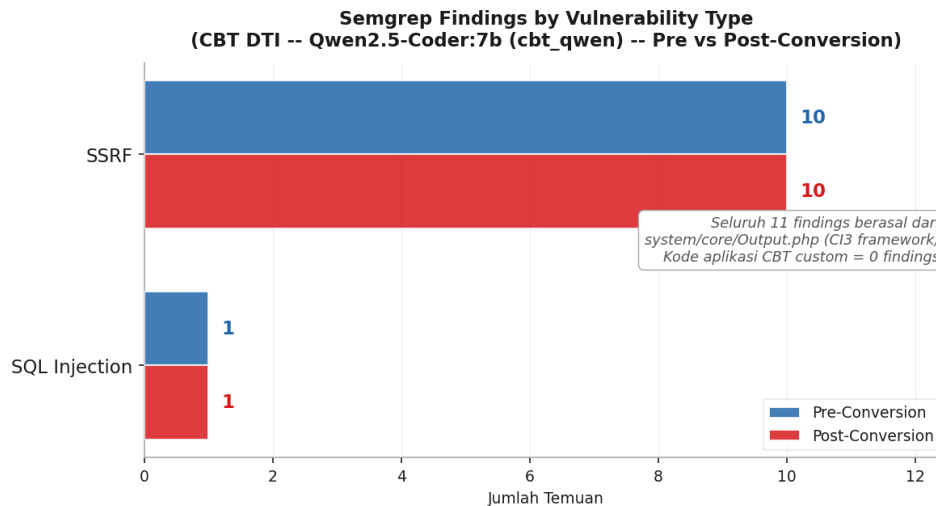
sintaks tanpa mengubah logika program.

Karena terdapat 11 temuan Semgrep, modul AI Engine diaktifkan secara otomatis oleh *pipeline*. Model *qwen2.5-coder:7b* melalui Ollama memproses seluruh 11 temuan dan menghasilkan saran perbaikan dengan rata-rata *confidence* 26%. Model dipilih berdasarkan hasil eksperimen komparasi pada studi kasus FT UGM yang mengidentifikasi Qwen2.5-Coder sebagai model dengan kualitas kode terbaik. Satu-satunya pengecualian adalah temuan SQL Injection pada *Output.php* baris 768 yang mendapat *confidence* 0%, karena potongan kode yang dikirim ke model tidak menyertakan konteks yang cukup untuk menganalisis konstruksi internal *framework*. Seluruh saran perbaikan dari AI Engine bersifat informatif dan memerlukan tinjauan manual sebelum diterapkan, karena seluruh temuan berasal dari kode *framework* yang tidak seharusnya dimodifikasi secara langsung.

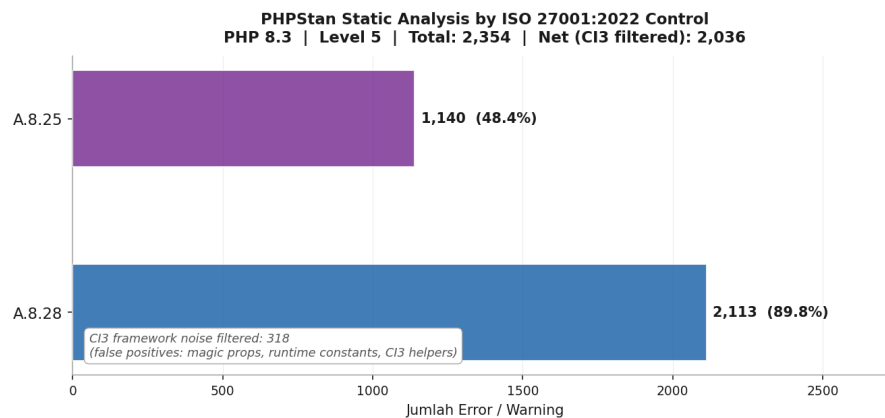
4.2.4 Hasil Validasi PHPStan

PHPStan *level 5* dijalankan terhadap kode hasil konversi di direktori *output/* dengan target PHP 8.3. Hasilnya adalah 2.354 temuan. Di antara temuan tersebut, sekitar 318 merupakan *false positive* dari *framework* CodeIgniter 3 yang timbul karena PHPStan tidak dapat menelusuri *magic property* dan fungsi *helper* yang diinjeksi secara dinamis, konsisten dengan 354 *noise* CI3 yang teridentifikasi pada dataset FT UGM. Distribusi temuan berdasarkan kontrol ISO/IEC 27001:2022 ditunjukkan pada Gambar 4.22.

Sebagaimana pada studi kasus FT UGM, mayoritas temuan PHPStan pada dataset CBT DTI bersumber dari keterbatasan PHPStan dalam memahami arsitektur CodeIgniter 3.x. PHPStan tidak dapat menelusuri dua kategori elemen yang diinjeksi secara dinamis oleh *framework* pada saat *runtime*: (1) *magic property* seperti *\$this->db* dan



Gambar 4.21. Temuan Semgrep *pre-scan* vs *post-scan* berdasarkan jenis kerentanan pada dataset CBT DTI UGM



Gambar 4.22. Distribusi temuan PHPStan berdasarkan kontrol ISO/IEC 27001:2022 Annex A pada dataset CBT DTI UGM

\$this->load yang berasal dari CI_Controller dan CI_Model, dan (2) fungsi-fungsi *helper* seperti `base_url()`, `redirect()`, dan `form_open()` yang dimuat secara dinamis. Karena direktori `system/` CodeIgniter dianalisis bersama kode aplikasi, PHPStan menghasilkan sejumlah besar laporan *undefined* untuk elemen-elemen tersebut yang merupakan *false positive* kerangka kerja.

Pola distribusi *error* PHPStan pada CBT DTI menunjukkan konsentrasi tinggi pada kontrol A.8.28 (*Secure Coding*) dengan 2.113 temuan (89,8% dari total), sementara A.8.25 (*Secure Development Lifecycle*) mencatat 1.140 temuan (48,4%). Sebagaimana pada studi kasus pertama, angka PHPStan yang tinggi mencerminkan akumulasi *technical debt* yang sudah ada sebelum migrasi, bukan kesalahan yang ditimbulkan oleh proses konversi.

4.2.5 Status Kepatuhan ISO/IEC 27001:2022

Berdasarkan pemetaan yang dilakukan oleh `iso_mapper.py`, status kepatuhan terhadap enam kontrol ISO/IEC 27001:2022 yang dipetakan adalah sebagaimana ditunjukkan pada Tabel 4.4.

Tabel 4.4. Status kepatuhan ISO/IEC 27001:2022 hasil *pipeline* pada dataset CBT DTI UGM

Kontrol	Judul	Dasar Penilaian	Status
A.5.17	<i>Authentication Information</i>	Tidak ada temuan <i>hardcoded credentials</i>	COMPLIANT
A.8.24	<i>Use of Cryptography</i>	Tidak ada temuan penggunaan <code>md5()</code> / <code>sha1()</code> untuk kata sandi	COMPLIANT
A.8.25	<i>Secure Development Lifecycle</i>	1.140 temuan PHPStan (mayoritas <i>false positive</i> CI3)	NON_COMPLIANT
A.8.26	<i>Application Security Requirements</i>	1 temuan SQL Injection dari Semgrep (<code>Output.php</code> , CI3 <i>framework</i>)	NON_COMPLIANT
A.8.28	<i>Secure Coding</i>	2.113 temuan PHPStan dan temuan Semgrep aktif	NON_COMPLIANT
A.8.29	<i>Security Testing in Development</i>	10 temuan SSRF dari Semgrep masih terbuka	NON_COMPLIANT

Status keseluruhan adalah NON_COMPLIANT. Temuan pada A.8.26 dan A.8.29 bersumber dari `system/core/Output.php` milik *framework* CodeIgniter 3, bukan dari kode aplikasi kustom CBT DTI. Hasil ini konsisten dengan cakupan analisis *full scope* yang diterapkan pada kedua studi kasus.

4.2.6 Analisis Dependensi Composer

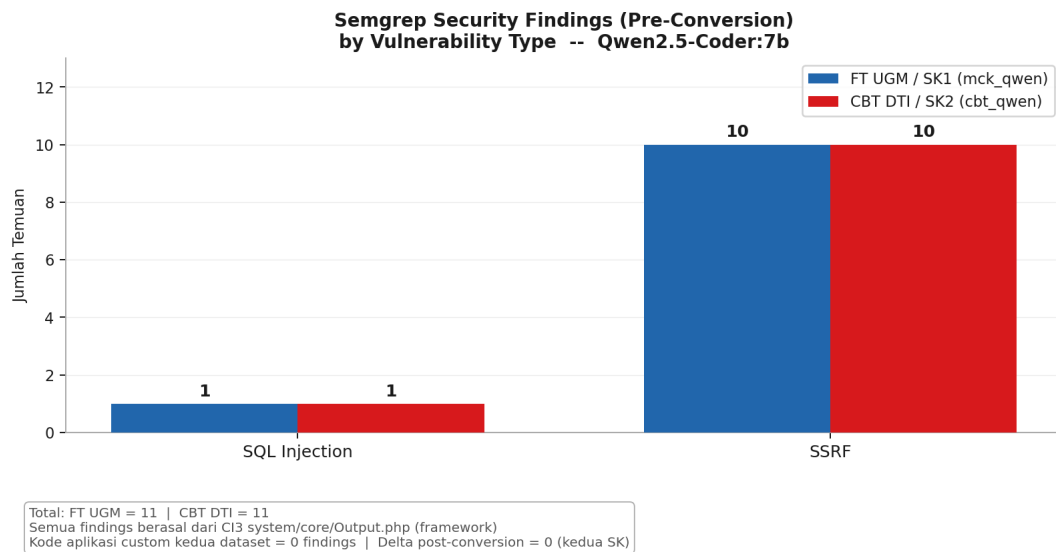
Aplikasi CBT DTI UGM tidak memiliki berkas `composer.json` pada tingkat aplikasi. Komponen pihak ketiga seperti *library* TCPDF disertakan langsung sebagai direktori dalam repositori dan telah dieksklusi dari analisis *pipeline*. Oleh karena itu, modul `composer_analyzer.py` tidak menghasilkan keluaran untuk studi kasus ini dan langkah analisis dependensi dilewati secara otomatis.

4.3 Perbandingan Kedua Studi Kasus

Bagian ini membandingkan hasil implementasi *pipeline* pada kedua studi kasus secara berdampingan untuk mengidentifikasi pola yang konsisten maupun perbedaan yang signifikan.

4.3.1 Perbandingan Temuan Keamanan Semgrep

Gambar 4.23 menunjukkan perbandingan temuan Semgrep *pre-scan* berdasarkan jenis kerentanan pada kedua dataset.



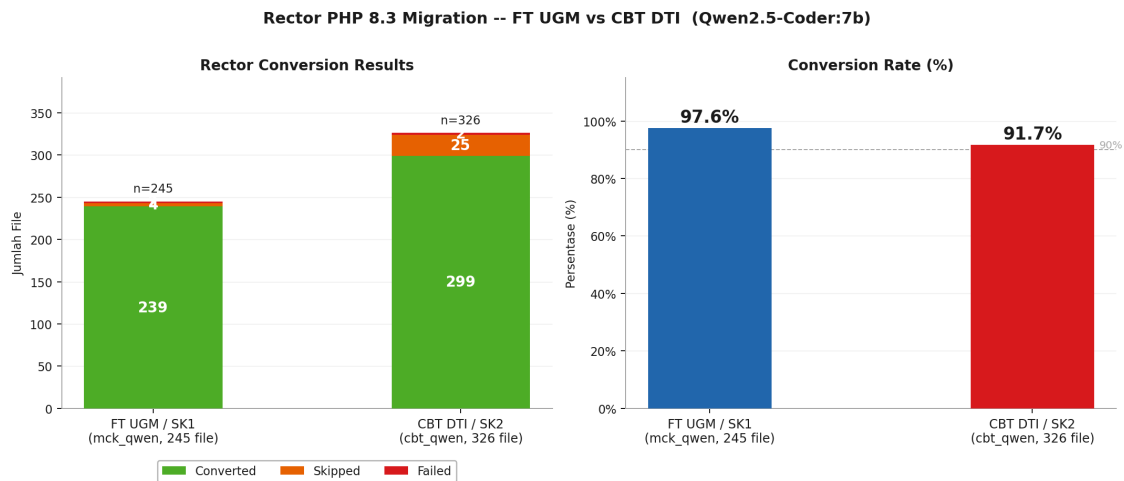
Gambar 4.23. Perbandingan temuan Semgrep *pre-scan* berdasarkan jenis kerentanan pada kedua studi kasus

Dataset FT UGM dan CBT DTI masing-masing menghasilkan 11 temuan Semgrep *pre-scan*, seluruhnya terlokalisasi pada `system/core/Output.php` yang merupakan komponen inti *framework* CodeIgniter 3. Pola temuan identik: 1 SQL Injection dan 10 SSRF pada kedua dataset. Pola ini mengonfirmasi fakta bahwa kedua aplikasi menggunakan versi CodeIgniter 3 yang sama dengan kode *framework* yang tidak dimodifikasi. Kode aplikasi kustom pada kedua dataset tidak menghasilkan temuan Semgrep.

Pada kedua studi kasus, nilai $\Delta F = 0$ menunjukkan konversi Rector tidak memperkenalkan maupun menghilangkan kerentanan. Temuan yang ada memerlukan remediasi pada tingkat kode *framework*, yang berada di luar cakupan transformasi sintaksis otomatis.

4.3.2 Perbandingan Tingkat Konversi Rector

Gambar 4.24 menunjukkan perbandingan hasil konversi Rector pada kedua dataset.

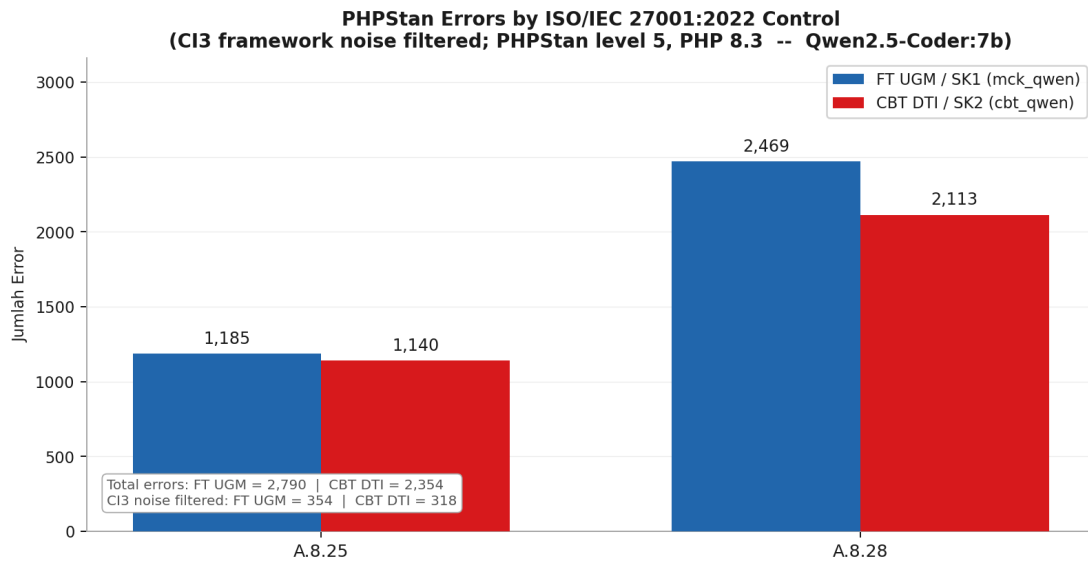


Gambar 4.24. Perbandingan hasil konversi Rector pada kedua studi kasus

FT UGM mencatat *conversion rate* 97,6% (239/245) sementara CBT DTI mencatat 91,7% (299/326). Perbedaan 5,9 poin persentase ini terutama disebabkan oleh proporsi *file* yang dilewati: CBT DTI memiliki 25 *file skipped* (7,7%) dibanding 4 *file* pada FT UGM (1,6%). Kedua dataset mengalami kegagalan pada 2 *file* yang sama (*captcha_helper.php* dan *form_helper.php*) akibat *bug* *FiberNodeScopeResolver* pada Rector, mengkonfirmasi bahwa kegagalan ini bersifat sistemik pada versi Rector yang digunakan, bukan spesifik pada salah satu dataset. Pada kedua studi kasus, validitas sintaks pasca-konversi mencapai 100%.

4.3.3 Perbandingan Temuan PHPStan

Gambar 4.25 menunjukkan perbandingan distribusi *error* PHPStan berdasarkan kontrol ISO/IEC 27001:2022 pada kedua dataset.



Gambar 4.25. Perbandingan *error* PHPStan berdasarkan kontrol ISO/IEC 27001:2022 pada kedua studi kasus

FT UGM menghasilkan 2.790 *error* PHPStan sementara CBT DTI menghasilkan 2.354 *error*. Keduanya dijalankan pada PHPStan *level* 5 dengan target PHP 8.3, sehingga angka ini dapat dibandingkan secara langsung. Sebagian besar *error* pada kedua dataset merupakan *false positive* akibat keterbatasan PHPStan dalam menelusuri arsitektur dinamis CodeIgniter 3.x, khususnya *magic property* dan fungsi *helper* yang diinjeksi saat *runtime*. Di samping itu, sebagian *error* mencerminkan masalah kompatibilitas dan kualitas kode aplikasi yang sesungguhnya, sebagaimana dibahas pada subbab sebelumnya. Jumlah *error* yang lebih tinggi pada FT UGM, meskipun ukuran datasetnya lebih kecil (245 vs 326 *file*), disebabkan oleh penggunaan dependensi pihak ketiga yang lebih beragam, PHPStan tidak dapat *me-resolve* kelas-kelas seperti `PhpOffice\PhpSpreadsheet` dan `Dotenv\Dotenv` karena dependensi tidak diinstal secara penuh di lingkungan analisis.

4.3.4 Ringkasan Perbandingan dan Analisis Dependensi Composer

Tabel 4.5 merangkum seluruh metrik utama kedua studi kasus dalam satu tampilan, termasuk status dependensi *composer* FT UGM.

Tabel 4.5. Ringkasan perbandingan metrik *pipeline* dan status dependensi *composer* kedua studi kasus

Metrik	FT UGM / SK1 (mck_qwen)	CBT DTI / SK2 (cbt_qwen)
File PHP dianalisis	245	326
Semgrep <i>findings</i> (pre)	11	11
– SQL Injection	1	1 (CI3 core)
– SSRF	10	10 (CI3 core)
Semgrep delta (post–pre)	+0 (stabil)	+0 (stabil)
Rector <i>converted</i>	239 (97.6%)	299 (91.7%)
Rector <i>skipped</i>	4	25
Rector <i>failed</i>	2 (<i>Fiber bug</i>)	2 (<i>Fiber bug</i>)
PHPStan total <i>errors</i>	2,790	2,354
CI3 <i>noise filtered</i>	354	318
AI <i>recommendations</i>	11 (Qwen2.5-Coder:7b)	11 (Qwen2.5-Coder:7b)
ISO <i>overall status</i>	NON-COMPLIANT	NON-COMPLIANT
Kode aplikasi <i>custom</i> (Semgrep)	0 <i>findings</i>	0 <i>findings</i>

PHPStan *errors* pada kedua studi kasus mayoritas merupakan *false positive* dari CI3 *framework* (magic props, runtime constants). Delta Semgrep bernilai 0 untuk kedua SK karena Rector tidak memperkenalkan maupun menghilangkan *vulnerability*. Seluruh Semgrep *findings* yang terdeteksi berasal dari CI3 `system/core/Output.php` dan bukan merupakan bagian dari kode aplikasi *custom*.

Secara keseluruhan, kedua studi kasus menunjukkan pola yang konsisten: *pipeline* berhasil menjalankan seluruh tahapan secara otomatis, konversi Rector menghasilkan kode yang valid secara sintaksis di kedua dataset, dan status ISO/IEC 27001:2022 keduanya adalah NON_COMPLIANT yang disebabkan oleh *error* PHPStan. Perbedaan utama terletak pada keberadaan temuan Semgrep pada kode kustom: FT UGM memiliki kerentanan aktif yang memerlukan remediasi manual, sementara CBT DTI tidak menghasilkan temuan Semgrep di luar kode *framework*. Dari sisi durasi eksekusi, kedua studi kasus sebanding, sekitar 3–4 menit, karena keduanya menggunakan Qwen2.5-Coder 7b sebagai AI Engine dengan satu kali inferensi per temuan; eksperimen komparasi multi-model (Kondisi A–C) pada studi kasus FT UGM merupakan prosedur evaluasi terpisah dan tidak termasuk dalam pengukuran durasi *pipeline*.

BAB V

KESIMPULAN DAN SARAN

5.1 Kesimpulan

Penelitian ini membangun *pipeline* berbasis Python yang mengintegrasikan konversi otomatis aplikasi web PHP lama ke versi PHP target dengan pemeriksaan kepatuhan *secure coding* berbasis ISO/IEC 27001:2022 dalam satu alur kerja *open source* yang dapat dijalankan secara lokal. Komponen konversi utama adalah Rector yang bekerja secara deterministik berbasis AST, sementara komponen AI berperan sebagai pemberi saran perbaikan semantik terhadap kerentanan yang tidak dapat ditangani oleh transformasi sintaksis. Berdasarkan hasil implementasi pada dua studi kasus nyata, berikut kesimpulan yang menjawab tujuan penelitian yang telah ditetapkan.

Pertama, platform yang mampu melakukan konversi otomatis aplikasi web PHP lama ke versi PHP target yang dapat dikonfigurasi berhasil dikembangkan. Rector mencatat tingkat konversi 97,6% pada dataset FT UGM (239 dari 245 *file*) dan 91,7% pada dataset CBT DTI UGM (299 dari 326 *file*), dengan tingkat validitas sintaks pasca-konversi mencapai 100% pada kedua studi kasus. Kegagalan konversi pada dua *file* di kedua dataset (*captcha_helper.php* dan *form_helper.php*) disebabkan oleh *bug* internal Rector pada *FiberNodeScopeResolver*, bukan berasal dari kode sumber. *Pipeline* terbukti mampu menangani kode dari berbagai era PHP secara serentak melalui mekanisme *ruleset* kumulatif Rector, dengan durasi eksekusi sekitar 3–4 menit untuk kedua dataset menggunakan Qwen2.5-Coder 7b sebagai AI Engine. Eksperimen komparasi multi-model (Kondisi A–C) yang dilakukan pada studi kasus FT UGM merupakan prosedur evaluasi terpisah dan tidak termasuk dalam pengukuran durasi *pipeline*.

Kedua, mekanisme pemeriksaan *secure coding* yang terhubung dengan kontrol ISO/IEC 27001:2022 Annex A berhasil diimplementasikan. Semgrep dijalankan sebelum dan sesudah konversi untuk mengukur perubahan postur keamanan, sementara *iso_mapper.py* memetakan setiap temuan ke kontrol yang relevan secara deterministik dan dapat diaudit. Nilai $\Delta F = 0$ (selisih jumlah temuan keamanan antara *pre-scan* dan *post-scan*) pada kedua studi kasus mengonfirmasi bahwa proses konversi tidak memperkenalkan kerentanan baru. Status kepatuhan keseluruhan pada kedua dataset adalah *NON_COMPLIANT*, yang mencerminkan kondisi nyata kode warisan sebelum remediasi manual dilakukan, bukan kegagalan *pipeline*.

Ketiga, sistem *quality assurance* yang memeriksa hasil konversi terhadap kebenaran fungsional dan kepatuhan keamanan berhasil dibangun. PHPStan *level 5* mendeteksi 2.790 temuan pada dataset FT UGM dan 2.354 temuan pada dataset CBT

DTI UGM. Sebagian besar temuan ini merupakan *false positive* akibat keterbatasan PHPStan dalam menelusuri *magic property* dan fungsi *helper* yang diinjeksi secara dinamis oleh arsitektur CodeIgniter 3.x pada saat *runtime*; sebagian lain mencerminkan akumulasi *technical debt* yang sudah ada sebelum migrasi, yang baru terlihat karena sistem tipe PHP 8.3 lebih ketat dibanding versi sebelumnya. Dalam kedua kasus, temuan ini bukan akibat proses konversi. Meskipun demikian, angka ini memperlihatkan manfaat nyata komponen validasi: tanpa PHPStan, ribuan potensi masalah kompatibilitas tipe tidak akan terdeteksi sebelum kode dijalankan di lingkungan produksi, sebagaimana ditemukan oleh Strobl et al. [11].

Keempat, dokumentasi otomatis berupa laporan konversi dan pemetaan kepatuhan ISO/IEC 27001:2022 berhasil disusun. Laporan JSON yang dihasilkan secara otomatis mencakup status konversi per *file*, temuan keamanan Semgrep, hasil validasi PHPStan, status per kontrol ISO, dan kompatibilitas dependensi *composer*. Laporan ini dapat langsung digunakan sebagai dokumentasi audit tanpa pekerjaan manual tambahan.

Di luar keempat tujuan tersebut, penelitian ini menghasilkan temuan empiris tentang perilaku model LLM lokal berukuran kecil dalam konteks analisis keamanan kode. Eksperimen komparasi terhadap lima model menunjukkan bahwa *Format Compliance Rate* dan *Syntax Validity Rate* merupakan dua dimensi yang independen: CodeLlama mencatat FCR tertinggi (100%) namun SVR terendah (27,3% pada Kondisi A), sementara Qwen2.5-Coder mengabaikan instruksi format sepenuhnya (FCR 0%) namun menghasilkan kode dengan SVR 100% secara konsisten di semua kondisi eksperimen. Untuk keperluan integrasi ke dalam sistem otomatis, Qwen2.5-Coder direkomendasikan sebagai model utama dengan catatan bahwa mekanisme ekstraksi kode perlu disesuaikan agar tidak bergantung pada kepatuhan format *output*. Temuan ini menunjukkan bahwa SVR adalah metrik evaluasi yang lebih sahih dibandingkan FCR maupun *confidence score self-reported* untuk sistem berbasis LLM lokal berukuran kecil hingga menengah.

5.2 Saran

Berdasarkan keterbatasan yang teridentifikasi selama penelitian, berikut beberapa arah pengembangan yang dapat dilakukan pada penelitian selanjutnya.

Pertama, evaluasi semantik terhadap saran perbaikan AI perlu dikembangkan. Validasi menggunakan `php -l` hanya memeriksa kebenaran sintaksis, bukan kebenaran logika perbaikan. Penelitian selanjutnya dapat membangun *test suite* otomatis atau memanfaatkan eksekusi kode terisolasi untuk memverifikasi bahwa kode yang dihasilkan model benar-benar memperbaiki kerentanan yang ditargetkan, bukan sekadar menghasilkan kode yang dapat dikompilasi.

Kedua, dataset eksperimen LLM perlu diperluas dengan keragaman kerentanan

yang lebih tinggi. Pada penelitian ini, 10 dari 11 temuan Semgrep berasal dari satu pola SSRF yang berulang pada satu *file*. Evaluasi yang lebih komprehensif membutuhkan dataset yang mencakup berbagai jenis kerentanan dari banyak *file* berbeda, sehingga kesimpulan tentang perbandingan model dapat digeneralisasi lebih luas.

Ketiga, penanganan *false positive* PHPStan pada basis kode CodeIgniter 3.x perlu ditingkatkan. Penelitian selanjutnya dapat mengeksplorasi penggunaan *custom stubs* PHPStan untuk mendefinisikan *magic property* dan fungsi *helper* CI3, atau menjalankan PHPStan dengan konfigurasi *baseline* sehingga hanya temuan baru yang muncul akibat proses konversi yang dilaporkan. Pendekatan ini akan meningkatkan akurasi laporan kepatuhan ISO pada aplikasi berbasis CodeIgniter.

Keempat, integrasi *pipeline* ke dalam alur kerja CI/CD dapat diujicobakan. Saat ini *pipeline* dijalankan secara manual. Integrasi ke GitHub Actions atau GitLab CI akan memungkinkan pemeriksaan keamanan dan kepatuhan ISO dijalankan secara otomatis pada setiap *commit*, sehingga *pipeline* ini terintegrasi secara permanen dalam siklus pengembangan perangkat lunak yang berkelanjutan.

Kelima, perbandingan dengan alat analisis keamanan komersial perlu dilakukan untuk memvalidasi temuan secara eksternal. Penelitian ini menggunakan alat *open source* sepenuhnya. Perbandingan hasil Semgrep dan PHPStan dengan alat seperti SonarQube atau Snyk pada dataset yang sama akan memberikan gambaran yang lebih komprehensif tentang cakupan dan akurasi deteksi kerentanan yang dicapai oleh *pipeline* ini.

Keenam, validasi pemetaan ISO/IEC 27001:2022 oleh pakar domain perlu dilakukan. Pemetaan dalam *iso_mapper.py* dibangun berdasarkan interpretasi peneliti terhadap dokumen standar. Keterlibatan auditor atau praktisi bersertifikat ISO/IEC 27001 dalam mengevaluasi kesesuaian setiap pemetaan akan meningkatkan validitas dan kredibilitas laporan kepatuhan yang dihasilkan.

Ketujuh, eksplorasi *fine-tuning* model LLM pada dataset kerentanan kode PHP dapat dilakukan sebagai kelanjutan penelitian ini. Penelitian ini menyediakan *baseline* evaluasi berbasis *prompt engineering* yang dapat dijadikan titik pembandingan apabila pendekatan *fine-tuning* diterapkan di masa depan. Teknik *parameter-efficient fine-tuning* seperti LoRA dan QLoRA membuka kemungkinan adaptasi model pada perangkat keras kelas menengah dengan tetap menjaga privasi data kode sumber institusi.

Kedelapan, perluasan cakupan bahasa pemrograman dan *framework* dapat diujicobakan. Arsitektur modular *pipeline* yang dibangun memungkinkan penggantian komponen Rector dan Semgrep dengan alat setara untuk bahasa lain, sehingga pendekatan yang sama berpotensi diterapkan pada migrasi aplikasi berbasis Python, JavaScript, atau bahasa lain yang menghadapi tantangan serupa.

Kesembilan, pengujian *pipeline* terhadap versi PHP yang lebih baru seperti PHP

8.4 dan PHP 8.5 dapat dilakukan sebagai arah pengembangan lebih lanjut. Eksperimen awal pada PHP 8.5 menunjukkan bahwa *ruleset* Rector untuk versi tersebut masih bersifat eksperimental dan belum stabil untuk basis kode CodeIgniter 3.x. PHP 8.4 diprediksi lebih *feasible* karena *ruleset*-nya sudah lebih matang, namun tetap memerlukan validasi empiris. Untuk target PHP 8.5 dan di atasnya, migrasi *framework* ke CodeIgniter 4 atau *framework* modern lainnya perlu dipertimbangkan sebagai prasyarat sebelum konversi otomatis dapat dilakukan.

DAFTAR PUSTAKA

- [1] The PHP Group, “PHP: History of PHP,” php.net, 2024, [Online]. Available: <https://www.php.net/manual/en/history.php>. [Accessed: Apr. 2026].
- [2] W3Techs, “Usage statistics and market share of PHP for websites,” W3Techs Web Technology Surveys, 2026, [Online]. Available: <https://w3techs.com/technologies/details/pl-php>. [Accessed: Apr. 8, 2026].
- [3] The PHP Group, “PHP: Supported versions,” php.net, 2025, [Online]. Available: <https://www.php.net/supported-versions.php>. [Accessed: Apr. 2026].
- [4] National Institute of Standards and Technology, “National vulnerability database (NVD),” NIST, 2024, [Online]. Available: <https://nvd.nist.gov/>. [Accessed: Apr. 2026].
- [5] OWASP Foundation, “OWASP top 10:2021 — the ten most critical web application security risks,” OWASP Foundation, 2021, [Online]. Available: <https://owasp.org/Top10/>. [Accessed: Apr. 2026].
- [6] E. Merlo, D. Letarte, and G. Antoniol, “Automated protection of PHP applications against SQL-injection attacks,” in *Proc. 11th European Conf. on Software Maintenance and Reengineering (CSMR)*, Amsterdam, Netherlands, 2007, pp. 191–202.
- [7] Rector, “Rector — instant upgrades and automated refactoring,” getrector.com, 2024, [Online]. Available: <https://getrector.com>. [Accessed: Apr. 2026].
- [8] D. Chen, D. Lawler, Y. Zhang, P. Kuchhal, D. Westcott, and G. Yang, “AST-based source code migration through symbols replacement,” in *Proc. 2022 IEEE Asia-Pacific Conf. on Computer Science and Data Engineering (CSDE)*, Brisbane, Australia, 2022, pp. 1–6.
- [9] Semgrep, “Semgrep — lightweight static analysis for many languages,” semgrep.dev, 2024, [Online]. Available: <https://semgrep.dev>. [Accessed: Apr. 2026].
- [10] PHPStan, “PHPStan — php static analysis tool,” phpstan.org, 2024, [Online]. Available: <https://phpstan.org>. [Accessed: Apr. 2026].
- [11] S. Strobl, C. Zoffi, C. Haselmann, M. Bernhart, and T. Grechenig, “Automated code transformations: Dealing with the aftermath,” in *Proc. 2020 IEEE 27th Int. Conf. on Software Analysis, Evolution and Reengineering (SANER)*, London, Canada, 2020, pp. 627–631.
- [12] International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 27001:2022 information security, cybersecurity and privacy protection — information security management systems: Requirements, 3rd ed.” ISO/IEC, Geneva, 2022.

- [13] V. Akuthota, R. Kasula, S. T. Sumona, M. Mohiuddin, M. T. Reza, and M. M. Rahman, “Vulnerability detection and monitoring using LLM,” in *Proc. 2023 IEEE 9th Int. Women in Engineering (WIE) Conf. on Electrical and Computer Engineering (WIECON-ECE)*, Thiruvananthapuram, India, 2023, pp. 309–314.
- [14] C. Li, B. Guan, Q. Zheng, B. Liu, and Z. Zhang, “Software vulnerability detection based on LLM,” in *Proc. 2025 IEEE 7th Advanced Information Management, Communications, Electronic and Automation Control Conf. (IMCEC)*, Chongqing, China, 2025, pp. 1534–1539.
- [15] Z. Li, S. Dutta, and M. Naik, “IRIS: LLM-assisted static analysis for detecting security vulnerabilities,” in *Proc. 13th Int. Conf. on Learning Representations (ICLR)*, Singapore, 2025, [Online]. Available: <https://arxiv.org/abs/2405.17238>.
- [16] J. Stümpfle, D. Atray, N. Jazdi, and M. Weyrich, “Large language model assisted transformation of software variants into a software product line,” in *Proc. 2025 IEEE/ACM 22nd Int. Conf. on Software and Systems Reuse (ICSR)*, Ottawa, Canada, 2025, pp. 12–20.
- [17] DeepSeek-AI, “DeepSeek-Coder: When the large language model meets programming — the rise of code intelligence,” *arXiv preprint arXiv:2401.14196*, 2024, [Online]. Available: <https://arxiv.org/abs/2401.14196>.
- [18] B. Hui *et al.*, “Qwen2.5-Coder technical report,” *arXiv preprint arXiv:2409.12186*, 2024, [Online]. Available: <https://arxiv.org/abs/2409.12186>.
- [19] B. Rozière *et al.*, “Code Llama: Open foundation models for code,” *arXiv preprint arXiv:2308.12950*, 2024, [Online]. Available: <https://arxiv.org/abs/2308.12950>.
- [20] A. Q. Jiang *et al.*, “Mistral 7B,” *arXiv preprint arXiv:2310.06825*, 2023, [Online]. Available: <https://arxiv.org/abs/2310.06825>.
- [21] A. Dubey *et al.*, “The Llama 3 herd of models,” *arXiv preprint arXiv:2407.21783*, 2024, [Online]. Available: <https://arxiv.org/abs/2407.21783>.
- [22] Ollama, “Ollama — get up and running with large language models locally,” ollama.com, 2024, [Online]. Available: <https://ollama.com>. [Accessed: Apr. 2026].
- [23] Z. Cai, L. Zhao, X. Wang, X. Yang, J. Qin, and K. Yin, “A pattern-based code transformation approach for cloud application migration,” in *Proc. 2015 IEEE 8th Int. Conf. on Cloud Computing (CLOUD)*, New York, USA, 2015, pp. 33–40.
- [24] R. S. Pressman and B. R. Maxim, *Software Engineering: A Practitioner’s Approach, 9th ed.* New York: McGraw-Hill Education, 2019.
- [25] J. Zhou, T. Lu, S. Mishra, S. Brahma, S. Basu, Y. Luan, D. Zhou, and L. Hou, “Instruction-following eval for large language models,” *arXiv preprint arXiv:2311.07911*, 2023, [Online]. Available: <https://arxiv.org/abs/2311.07911>.
- [26] K. Yan, H. Guo, X. Shi, S. Cao, D. Di, and Z. Li, “CodeIF: Benchmarking the instruction-following capabilities of large language models for code generation,” *arXiv preprint arXiv:2502.19166*, 2025, [Online]. Available: <https://arxiv.org/abs/2502.19166>.

- [27] Element Labs Inc., “LM Studio: Discover, download, and run local LLMs,” lmstudio.ai, 2024, [Online]. Available: <https://lmstudio.ai>. [Accessed: Apr. 2026].
- [28] G. Gerganov *et al.*, “llama.cpp: LLM inference in C/C++,” GitHub, 2023, [Online]. Available: <https://github.com/ggml-org/llama.cpp>. [Accessed: Apr. 2026].

Catatan: Daftar pustaka adalah apa yang dirujuk atau disitasi, bukan apa yang telah dibaca, jika tidak ada dalam sitasi maka tidak perlu dituliskan dalam daftar pustaka.

LAMPIRAN

Berikut teks lengkap *prompt* Kondisi B untuk masing-masing model, diambil dari metode `_build_optimized_chat_messages()` di `ai_engine.py`. Variabel `{vuln_type}`, `{controls_str}`, `{context_block}`, dan `{code}` diisi secara dinamis saat *runtime* berdasarkan temuan Semgrep yang sedang diproses.

A.1 Qwen2.5-Coder 7b

Strategi: format diperlunak — CONFIDENCE tidak diwajibkan, fokus pada kualitas kode.

System message:

```
1 You are a PHP security expert specializing in PHP 7.x to PHP 8.x
2 migration. Your primary goal is to produce clean, secure, and
3 syntactically correct PHP 8.x code. Apply ISO/IEC 27001:2022
4 secure coding principles (A.8.28, A.8.29).
```

User message:

```
1 Analyze this PHP code for a [{vuln_type}] vulnerability and
2 provide a secure fix.
3 ISO/IEC 27001:2022 Controls: {controls_str}
4 {context_block}
5 VULNERABLE CODE:
6 ```php
7 {code}
8 ```
9 Please:
10 1. Briefly explain the security issue.
11 2. Provide the corrected PHP 8.x code in a ```php code block.
12
13 If you wish, rate your confidence (0-100) at the end as:
14 CONFIDENCE: [number]
```

A.2 DeepSeek Coder 6.7b

Strategi: instruksi pendek dan langsung, satu format *requirement*.

System message:

```
1 You are a PHP security expert. Fix PHP vulnerabilities with
2 secure PHP 8.x code. ISO/IEC 27001:2022 A.8.28 applies.
```

User message:

```
1 Fix this [{vuln_type}] in PHP 8.x.  
2 ISO controls: {controls_str}  
3 {context_block}  
4 CODE:  
5 {code}  
6  
7 Write:  
8 - Why it is vulnerable.  
9 - Fixed PHP 8.x code in a ```php block.  
10 - Last line: CONFIDENCE: [0-100]
```

A.3 Mistral 7b

Strategi: satu contoh *few-shot* konkret untuk mengajarkan struktur keluaran.

System message:

```
1 You are a PHP security expert and migration specialist. Analyze  
2 PHP vulnerabilities and provide secure PHP 8.x replacements.  
3 Follow ISO/IEC 27001:2022 controls A.8.28 (Secure Coding) and  
4 A.8.29 (Security Testing in Development).
```

User message:

```
1 TASK: Fix a [{vuln_type}] vulnerability.  
2 ISO controls: {controls_str}  
3 {context_block}  
4 === EXAMPLE ===  
5 VULNERABLE CODE:  
6 $id = $_GET['id'];  
7 $result = mysql_query('SELECT * FROM users WHERE id=' . $id);  
8  
9 EXPECTED OUTPUT:  
10 The code uses deprecated mysql_query() with direct user-input  
11 concatenation, enabling SQL injection (ISO/IEC 27001:2022 A.8.28).  
12  
13 $stmt = $pdo->prepare('SELECT * FROM users WHERE id = ?');  
14 $stmt->execute([$GET['id']]);  
15 $result = $stmt->fetchAll();  
16  
17 CONFIDENCE: 90  
18 === END EXAMPLE ===
```

19
20 Now fix this code using the same format:
21 VULNERABLE CODE:
22 {code}
23
24 Provide: explanation, then ```php fix block,
25 then CONFIDENCE: [0-100].

A.4 Llama 3.1 8b

Strategi: *role-play* persona kuat dengan empat langkah prosedural eksplisit.

System message:

1 You are an expert PHP security auditor with 10 years of
2 experience in web application security and PHP migration.
3 Your role is to identify vulnerabilities and write secure
4 PHP 8.x code. You strictly follow ISO/IEC 27001:2022 Annex A
5 controls for secure software development. You always respond
6 in exactly the format requested, without deviation.

User message:

1 Act as a PHP security expert and follow these steps exactly:
2
3 Step 1: Read the vulnerable PHP code below.
4 Step 2: Identify why it is a [{vuln_type}] security risk
5 (ISO/IEC 27001:2022: {controls_str}).
6 Step 3: Write a secure PHP 8.x replacement that fully fixes
7 the vulnerability.
8 Step 4: End your response with this exact line:
9 CONFIDENCE: [number 0-100]
10 {context_block}
11 VULNERABLE CODE:
12 {code}
13
14 Your response must follow this exact order:
15 1. Explanation of the vulnerability.
16 2. Secure PHP 8.x code fix.
17 3. CONFIDENCE: [number]

A.5 CodeLlama 7b

Strategi: format identik dengan Kondisi A dengan tambahan instruksi validitas sintaks `php -l` secara eksplisit.

System message:

```
1 You are a PHP security expert and migration specialist. You
2 analyze PHP code for security vulnerabilities and provide secure
3 PHP 8.x replacements. Follow ISO/IEC 27001:2022 secure coding
4 standards (A.8.28, A.8.29). CRITICAL: Every PHP code block you
5 generate must be syntactically valid and pass php -l
6 (lint check). Mentally verify your code compiles without
7 errors before writing it. Never output PHP with syntax errors.
```

User message:

```
1 TASK: Analyze the following PHP code for a [{vuln_type}]
2 vulnerability and provide a secure PHP 8.x replacement.
3 ISO/IEC 27001:2022 Controls: {controls_str}
4 {context_block}
5 VULNERABLE CODE:
6 {code}
7
8 Respond in English:
9 1. Explain the vulnerability and its security risk.
10 2. Provide the corrected PHP 8.x code in a ```php code block.
11 IMPORTANT: Before writing the code, verify it is syntactically
12 correct (as if running php -l). No syntax errors are allowed.
13
14 After your explanation and code fix, write exactly this on the
15 last line:
16 CONFIDENCE: [number between 0 and 100]
17 Example last line: CONFIDENCE: 85
```


LAMPIRAN

L.1 Pseudocode Pipeline Migrasi PHP

Lampiran ini menyajikan pseudocode setiap modul pada pipeline migrasi PHP yang dikembangkan. Pseudocode merupakan representasi logika program dalam bahasa semi-formal yang lebih mudah dibaca dibandingkan kode program sesungguhnya, tanpa terikat pada sintaks bahasa pemrograman tertentu.

Panduan Membaca Pseudocode

Berikut keterangan notasi yang digunakan pada seluruh pseudocode di lampiran ini.

Notasi	Keterangan
PROGRAM: NamaProgram	Nama modul/program yang didefinisikan.
FUNCTION nama(param) : ...END FUNCTION	Definisi fungsi beserta parameternya. Kode di dalam blok ini dijalankan saat fungsi dipanggil.
param <- nilai	Penugasan nilai ke variabel (dibaca: <i>param diisi dengan nilai</i>).
IF kondisi THEN ...ELSE...END IF	Percabangan: blok dalam THEN dijalankan jika kondisi benar, blok ELSE jika salah.
FOR each item in daftar DO ...END FOR	Perulangan: blok dijalankan satu kali untuk setiap elemen dalam daftar.
RETURN nilai	Mengembalikan hasil fungsi ke pemanggil.
DATA STRUCTURE Nama:	Definisi struktur data (kumpulan atribut yang membentuk satu entitas).
CONSTANT NAMA: nilai	Nilai tetap yang tidak berubah selama program berjalan.
// komentar	Keterangan tambahan, tidak dieksekusi oleh program.
NULL	Tidak ada nilai / kosong.
A -> B	Menunjukkan keluaran atau pemetaan: <i>A menghasilkan B</i> .
A <- B (di luar penugasan)	Menunjukkan asal data: <i>A berasal dari B</i> .

B.1 Modul `main.py` — Orkestrator Pipeline Utama

Modul ini adalah titik masuk (*entry point*) program. Ketika pengguna menjalankan pipeline dari *command line*, modul inilah yang pertama kali dieksekusi. Tugasnya adalah membaca argumen yang diberikan pengguna (seperti lokasi folder PHP yang akan dimigrasi, model AI yang dipakai, dan opsi lainnya), kemudian memanggil fungsi `run_pipeline()` yang mengorkestrasi seluruh tahapan migrasi secara berurutan. Di akhir proses, program keluar dengan kode 0 jika sistem dinyatakan patuh ISO, atau kode 1 jika belum.

```
1 PROGRAM: MigrationPipeline
2
3 FUNCTION main():
4     args <- parse_command_line_arguments()
5     // argumen: --input, --output, --reports, --skip-ai, --model,
6     //           --compare-all, --target-php, --php-version, dll.
7
8     IF output_dir is NOT empty THEN
9         prompt user "Hapus isi output/? [Y/n]"
10        IF user confirms THEN
11            delete contents of output_dir
12        ELSE
13            exit program
14        END IF
15    END IF
16
17    result <- run_pipeline(args)
18
19    IF result.iso_status == COMPLIANT THEN
20        exit with code 0    // sistem dinyatakan patuh ISO
21    ELSE
22        exit with code 1    // masih terdapat temuan keamanan
23    END IF
24 END FUNCTION
25
26
27 FUNCTION run_pipeline(input_dir, output_dir, reports_dir, options):
28     record start_time
29
30     // Step 1: Pindai keamanan kode SEBELUM konversi (kondisi awal)
31     pre_scan <- run_scan(input_dir)
32
33     // Step 2: Konversi sintaks PHP lama ke PHP 8.x menggunakan Rector
34     conversion <- run_conversion(input_dir, output_dir, target_version)
35
36     // Step 2b: Analisis dependensi library di composer.json
37     composer_analysis <- run_composer_analysis(input_dir,
```

```

38     target_version)
39
40     // Step 3: Pindai keamanan kode SESUDAH konversi (kondisi akhir)
41     IF conversion succeeded THEN
42         post_scan <- run_scan(output_dir)
43     END IF
44
45     // Step 4: Analisis statis PHPStan untuk mendeteksi kesalahan tipe
46     //         dan referensi kode yang tidak valid
47     IF conversion succeeded THEN
48         analysis <- run_analysis(output_dir, phpstan_level,
49                                 php_version)
50     END IF
51
52     // Step 5: Analisis AI untuk rekomendasi perbaikan kerentanan
53     IF skip_ai == FALSE THEN
54         IF compare_all == TRUE THEN
55             // Mode perbandingan: uji semua model LLM,
56             // 3 kali per temuan
57             run_llm_comparison(pre_scan.findings, all_models,
58                               3_runs_each)
59         ELSE
60             // Mode normal: gunakan satu model terpilih
61             ai_recs <- run_ai_analysis(pre_scan.findings,
62                                       selected_model)
63         END IF
64     END IF
65
66     // Step 6: Petakan semua temuan ke kontrol ISO/IEC 27001:2022
67     iso_report <- run_iso_mapping(
68         pre_scan, analysis, ai_recs, output_path)
69
70     total_duration <- now() - start_time
71
72     print_summary_table(pre_scan, post_scan, conversion, analysis,
73                        iso_report)
74     save_pipeline_result_json(reports_dir, timestamp)
75
76     RETURN PipelineResult(pre_scan, conversion, post_scan, analysis,
77                          ai_recs, iso_report, composer_analysis,
78                          duration)
79 END FUNCTION

```

B.2 Modul `scanner.py` — Pemindaian Keamanan (Semgrep)

Modul ini bertanggung jawab menjalankan *tool* Semgrep untuk memindai seluruh file PHP dalam sebuah direktori dan mendeteksi potensi kerentanan keamanan. Semgrep adalah alat analisis kode statis berbasis pola (*pattern matching*): ia mencocokkan kode sumber dengan aturan-aturan yang mendefinisikan pola kode berbahaya. Setiap temuan kemudian diklasifikasikan ke dalam jenis kerentanan (misalnya SQL Injection atau XSS), diberi tingkat prioritas dari 1 (kritis) hingga 6 (rendah), dan dipetakan ke kontrol ISO/IEC 27001:2022 yang relevan.

```
1 PROGRAM: SemgrepScanner
2
3 DATA STRUCTURE ScanFinding:
4     // Satu temuan kerentanan dari hasil Semgrep
5     rule_id, file_path, line_start, line_end
6     message, severity // ERROR | WARNING | INFO
7     code_snippet // potongan kode yang bermasalah
8     vuln_type      // SQL Injection | XSS | Deprecated Function | ...
9     iso_controls   // kontrol ISO terkait, e.g. ["A.8.28", "A.8.26"]
10    priority       // 1..6 (1 = tertinggi / paling kritis)
11
12 DATA STRUCTURE ScanResult:
13     findings      : list of ScanFinding // diurutkan berdasarkan prioritas
14     summary       : ScanSummary         // jumlah total per jenis/severity
15     raw_output    : JSON dict           // keluaran mentah dari Semgrep
16
17 CONSTANT VULNERABILITY_RULES:
18     // Pemetaan jenis kerentanan ke prioritas dan kontrol ISO
19     priority 1: SQL Injection            -> ISO [A.8.28, A.8.26]
20     priority 2: XSS                     -> ISO [A.8.28, A.8.26]
21     priority 3: Deprecated Function     -> ISO [A.8.25, A.8.28]
22     priority 4: Hardcoded Credentials   -> ISO [A.5.17, A.8.28]
23     priority 5: SSRF / Path Traversal    -> ISO [A.8.28, A.8.29]
24     priority 6: Weak Cryptography        -> ISO [A.8.24, A.8.28]
25
26
27 FUNCTION run_scan(target_path):
28     // Pilih ruleset Semgrep: lokal (reproducible) atau registry online
29     IF local rules/ directory exists THEN
30         rulesets <- local rules/ directory
31     ELSE
32         rulesets <- ["p/php", "p/owasp-top-ten"]
33     END IF
34
35     cmd <- build_semgrep_command(target_path, rulesets, "--json")
36     raw_json <- invoke_subprocess(cmd, timeout=300s)
37
```

```

38     findings <- []
39     FOR each result in raw_json["results"] DO
40         rule_id <- result.check_id
41         severity <- result.extra.severity
42         message <- result.extra.message
43         snippet <- result.extra.lines
44
45         // Klasifikasi ke jenis kerentanan, kontrol ISO, dan prioritas
46         (vuln_type, iso_controls, priority) <- classify(rule_id, message)
47
48         findings.append(ScanFinding(...))
49     END FOR
50
51     // Urutkan dari yang paling kritis
52     findings.sort(by priority ASC, then severity, then file_path)
53
54     summary <- aggregate(findings)
55     print_summary_table(summary)
56
57     RETURN ScanResult(findings, summary, raw_json)
58 END FUNCTION
59
60
61 FUNCTION classify(rule_id, message):
62 // Cocokkan ID aturan dan pesan ke dalam VULNERABILITY_RULES
63     haystack <- lowercase(rule_id + message[:100])
64
65     FOR each (keywords, label, controls, priority) in
66         VULNERABILITY_RULES DO
67         IF any keyword in haystack THEN
68             RETURN (label, controls, priority)
69         END IF
70     END FOR
71
72     RETURN ("Other", ["A.8.28"], priority=99)
73     // kategori tidak dikenal
74 END FUNCTION

```

B.3 Modul `converter.py` — Konversi PHP (Rector)

Modul ini melakukan konversi otomatis kode PHP lama ke PHP 8.x menggunakan *tool* Rector. Rector adalah *tool* refaktorisasi PHP berbasis aturan (*rule-based*): ia membaca kode sumber, membangun representasi pohon sintaks (*Abstract Syntax Tree*), menerapkan aturan transformasi yang sesuai, lalu menuliskan kode yang sudah diperbarui. Modul ini terlebih dahulu mendeteksi versi PHP tiap file (PHP 5 atau PHP

7), memilih rantai aturan migrasi yang tepat, kemudian memverifikasi file mana yang benar-benar berubah menggunakan sidik jari SHA-256.

```
1 PROGRAM: RectorConverter
2
3 DATA STRUCTURE ConversionFile:
4     source_path, output_path
5     php_version      // PHP5 | PHP7 | UNKNOWN
6     status           // CONVERTED | SKIPPED | FAILED
7     changes_count    // jumlah perubahan yang diterapkan
8     applied_rectors  // daftar nama aturan Rector yang aktif
9     iso_controls      // ["A.8.25"] - Secure Development Lifecycle
10
11 DATA STRUCTURE ConversionResult:
12     files            : list of ConversionFile
13     summary          : ConversionSummary
14     rector_raw_output : string (JSON) // keluaran mentah Rector
15
16 CONSTANT LEVEL_SETS_PHP5:
17     // Rantai migrasi penuh untuk kode PHP 5 (setiap versi minor)
18     UP_TO_PHP_53, UP_TO_PHP_54, ..., UP_TO_PHP_85
19
20 CONSTANT LEVEL_SETS_PHP7:
21     // Rantai lebih pendek untuk kode PHP 7
22     UP_TO_PHP_70, ..., UP_TO_PHP_85
23
24 CONSTANT QUALITY_SETS:
25     // Aturan peningkatan kualitas kode (selalu diterapkan)
26     CODE_QUALITY, DEAD_CODE, EARLY_RETURN, TYPE_DECLARATION
27
28
29 FUNCTION run_conversion(input_path, output_path, target_version):
30     php_files <- collect_all_php_files(input_path)
31
32     // Step 1: Deteksi versi PHP per file dari pola kode yang digunakan
33     version_map <- {}
34     FOR each file in php_files DO
35         version_map[file] <- detect_php_version(file)
36     END FOR
37
38     // Step 2: Pilih rantai aturan Rector sesuai versi PHP yang
39     ditemukan
40     IF PHP5 in version_map.values() THEN
41         level_sets <- LEVEL_SETS_PHP5 truncated at target_version
42     ELSE
43         level_sets <- LEVEL_SETS_PHP7 truncated at target_version
44     END IF
45     all_sets <- level_sets + QUALITY_SETS
```

```

46
47 // Step 3: Salin input/ ke output/ agar input asli tidak pernah
48 diubah
49 copy_tree(input_path, output_path)
50
51 // Step 4: Catat hash SHA-256 semua file SEBELUM Rector dijalankan
52 pre_hashes <- snapshot_sha256(output_path)
53
54 // Step 5: Tulis konfigurasi Rector sementara ke direktori temp
55 sistem
56 config_path <- write_rector_config(output_path, all_sets)
57
58 // Step 6: Jalankan Rector sebagai subprocess
59 (exit_code, stdout, stderr) <- invoke_rector(config_path,
60 timeout=600s)
61
62 // Step 7: Catat hash SHA-256 semua file SESUDAH Rector
63 post_hashes <- snapshot_sha256(output_path)
64
65 // Step 8: Hapus konfigurasi sementara
66 delete(config_path)
67
68 // Step 9: Tentukan status tiap file dengan membandingkan hash
69 rector_data <- parse_rector_json(stdout)
70 FOR each source_file in php_files DO
71   pre <- pre_hashes[output_copy_of(source_file)]
72   post <- post_hashes[output_copy_of(source_file)]
73
74   IF file is in rector error list THEN
75     status <- FAILED // Rector gagal memproses file ini
76   ELSE IF pre != post THEN
77     status <- CONVERTED // file berhasil dikonversi
78   ELSE
79     status <- SKIPPED // tidak ada perubahan yang perlu
80     diterapkan
81   END IF
82
83   files.append(ConversionFile(source_file, status, ...))
84 END FOR
85
86 summary <- aggregate(files, elapsed_time)
87 print_summary_table(summary)
88
89 RETURN ConversionResult(files, summary, stdout)
90 END FUNCTION
91
92

```

```

93 FUNCTION detect_php_version(file_path):
94     // Baca 8KB pertama file untuk efisiensi
95     content <- read first 8KB of file
96
97     // Cek pola fungsi/sintaks yang hanya ada di PHP 5
98     IF any PHP5 pattern matches (mysql_connect, ereg, split) THEN
99         RETURN PHP5
100     END IF
101
102     // Cek pola yang diperkenalkan di PHP 7
103     IF any PHP7 pattern matches (fn =>, ??, intdiv) THEN
104         RETURN PHP7
105     END IF
106
107     RETURN UNKNOWN
108 END FUNCTION

```

B.4 Modul **analyzer.py** — Analisis Statis (PHPStan)

Modul ini menjalankan PHPStan, sebuah alat analisis statis untuk PHP yang memeriksa kode tanpa mengeksekusinya. PHPStan mendeteksi kesalahan seperti pemanggilan fungsi yang tidak ada, ketidakcocokan tipe data, kode yang tidak pernah dieksekusi (*dead code*), dan referensi variabel yang tidak valid. Karena proyek target menggunakan kerangka kerja CodeIgniter 3 (CI3) yang mengandalkan konvensi *magic method* dan konstanta global yang tidak dikenali PHPStan, modul ini secara khusus menyaring pesan *false positive* dari CI3 sebelum hasilnya dilaporkan.

```

1 PROGRAM: PHPStanAnalyzer
2
3 DATA STRUCTURE AnalysisError:
4     file_path, line
5     message, severity    // ERROR | WARNING
6     iso_controls         // kontrol ISO yang relevan
7
8 DATA STRUCTURE AnalysisResult:
9     errors      : list of AnalysisError // diurutkan per file lalu
10                  per baris
11     summary     : AnalysisSummary
12     raw_output  : JSON dict
13
14 CONSTANT CI3_FRAMEWORK_NOISE:
15     // False positive khas arsitektur CodeIgniter 3 -- diabaikan:
16     "extends unknown class CI_*"
17     "Constant ENVIRONMENT/FCPATH/APPPATH not found"
18     "$this->db, $this->input, $this->session, ..."
19     "Function base_url/redirect/form_open not found"

```



```

20
21
22 FUNCTION run_analysis(target_path, level, php_version):
23     // Cari binary PHPStan (vendor/bin/ atau PATH global)
24     phpstan_exe <- find_phpstan(vendor/bin/ OR global PATH)
25
26     cmd <- build_phpstan_command(target_path, level, php_version,
27                                   "--error-format=json", "--no-progress")
28     (exit_code, stdout, stderr) <- invoke_subprocess(cmd, timeout=300s)
29
30     raw_json <- parse_phpstan_json(stdout)
31
32     errors <- []
33     noise_count <- 0
34     FOR each (file_path, file_data) in raw_json["files"] DO
35         FOR each msg_entry in file_data["messages"] DO
36             message <- msg_entry.message
37             line <- msg_entry.line
38
39             // Lewati pesan yang merupakan false positive CI3
40             IF message matches CI3_FRAMEWORK_NOISE THEN
41                 noise_count <- noise_count + 1
42                 CONTINUE
43             END IF
44
45             (severity, iso_controls) <- classify_error(message)
46             errors.append(AnalysisError(file_path, line, message,
47                                         severity, iso_controls))
48         END FOR
49     END FOR
50
51     errors.sort(by file_path, then line)
52
53     summary <- aggregate(errors, noise_count, elapsed_time)
54     print_results_table(errors, summary)
55
56     RETURN AnalysisResult(errors, summary, raw_json)
57 END FUNCTION
58
59
60 FUNCTION classify_error(message):
61     lower_msg <- lowercase(message)
62
63     // Kode mati atau jalur eksekusi yang tidak dapat dicapai
64     IF "dead code" OR "unreachable" OR "never returns"
65         in lower_msg THEN
66         RETURN ("WARNING", ["A.8.25"])

```

```

67     END IF
68
69     // Referensi ke fungsi, kelas, atau konstanta yang tidak ada
70     IF "undefined" OR "not found" OR "unknown class" in lower_msg THEN
71         RETURN ("ERROR", ["A.8.28", "A.8.25"])
72     END IF
73
74     // Ketidakcocokan tipe data atau nilai null yang tidak ditangani
75     IF "type" OR "null" OR "incompatible" OR "expects" in lower_msg THEN
76         RETURN ("ERROR", ["A.8.28"])
77     END IF
78
79     RETURN ("ERROR", ["A.8.28"])
80     // fallback untuk pesan yang tidak dikenal
81 END FUNCTION

```

B.5 Modul `ai_engine.py` — Analisis AI (LLM via Ollama)

Modul ini mengintegrasikan model bahasa besar (*Large Language Model* / LLM) lokal yang berjalan melalui Ollama untuk memberikan rekomendasi perbaikan kode terhadap setiap kerentanan yang ditemukan Semgrep. Modul mendukung dua mode: mode normal (satu model) dan mode perbandingan (lima model, tiga kali pengujian per temuan). Setiap potongan kode rentan dikirim ke LLM beserta konteks jenis kerentanan dan kontrol ISO yang berlaku, kemudian respons LLM diurai untuk mengekstrak penjelasan, kode perbaikan, dan skor kepercayaan (*confidence score*).

```

1 PROGRAM: PHPAEngine
2
3 DATA STRUCTURE AIRecommendation:
4     original_code, suggested_fix, explanation
5     confidence      // skor kepercayaan LLM: 0.0 - 1.0
6     iso_controls, vuln_type
7     file_path, line_start
8     model_used, fim_used // apakah menggunakan Fill-in-Middle
9
10 CONSTANT COMPARISON_MODELS:
11     ["deepseek-coder:6.7b", "qwen2.5-coder:7b",
12      "codellama:7b", "mistral:7b", "llama3.1:8b"]
13
14 // Hanya proses temuan dengan prioritas 1-5 (abaikan kategori "Other")
15 CONSTANT PRIORITY_THRESHOLD: 5
16 // Batasi panjang kode yang dikirim ke LLM (karakter)
17 CONSTANT MAX_CODE_CHARS: 2000
18
19
20 FUNCTION run_ai_analysis(findings, model):

```

```

21 // Saring hanya temuan yang cukup kritis untuk dianalisis AI
22 eligible <- [f for f in findings WHERE f.priority <=
23 PRIORITY_THRESHOLD]
24
25 // Pastikan server Ollama lokal sedang berjalan
26 IF Ollama NOT reachable at localhost:11434 THEN
27     print warning "Ollama offline -- tahapan AI dilewati"
28     RETURN []
29 END IF
30
31 recommendations <- []
32 FOR each finding in eligible DO
33     rec <- analyze_snippet(finding.code_snippet, finding.vuln_type,
34                             finding.iso_controls, finding.file_path,
35                             finding.line_start, model)
36     recommendations.append(rec)
37 END FOR
38
39 print_batch_summary(recommendations)
40 RETURN recommendations
41 END FUNCTION
42
43
44 FUNCTION analyze_snippet(code, vuln_type, iso_controls,
45                             file_path, line_start, model):
46     truncated <- code[:MAX_CODE_CHARS]
47
48     // Kode pendek (<= 3 baris): gunakan Fill-in-Middle (FIM) prompt
49     // Kode lebih panjang: gunakan chat biasa
50     IF lines(truncated) <= 3 THEN
51         prompt <- build_fim_prompt(truncated, vuln_type, iso_controls)
52         fim_used <- TRUE
53     ELSE
54         messages <- build_chat_messages(truncated, vuln_type, iso_controls)
55         fim_used <- FALSE
56     END IF
57
58     // temperature=0.1: output deterministik, minim variasi acak
59     raw_text <- call_ollama_chat(messages, model, temperature=0.1)
60
61     RETURN parse_response(raw_text, truncated, iso_controls,
62                             vuln_type, file_path, line_start, fim_used)
63 END FUNCTION
64
65
66 FUNCTION build_chat_messages(code, vuln_type, iso_controls):
67     // Kondisi A (standar): prompt identik untuk semua model

```

```

68 system_msg <- "You are a PHP security and migration expert
69     controls [{iso_controls}]."
70 user_msg <- "TASK: Analyze [{vuln_type}] vulnerability...
71     VULNERABLE CODE: (kode PHP disisipkan di sini)
72     1. Explain the vulnerability.
73     2. Provide corrected PHP 8.x code.
74     Last line: CONFIDENCE: [0-100]"
75 RETURN [system_msg, user_msg]
76 END FUNCTION
77
78
79 FUNCTION build_optimized_chat_messages(code, vuln_type, iso_controls,
80 model):
81     // Kondisi B: prompt dioptimalkan khusus per model
82     IF model == "qwen2.5-coder:7b" THEN
83         // format diperlunak; CONFIDENCE tidak diwajibkan
84     ELSE IF model == "deepseek-coder:6.7b" THEN
85         // instruksi pendek dan langsung
86     ELSE IF model == "mistral:7b" THEN
87         // satu contoh few-shot untuk mengajarkan format keluaran
88     ELSE IF model == "llama3.1:8b" THEN
89         // role-play persona kuat + 4 langkah prosedural
90     ELSE IF model == "codellama:7b" THEN
91         // sama dengan Kondisi A + instruksi validitas sintaks php -l
92     ELSE
93         // fallback ke Kondisi A standar
94     END IF
95     RETURN [system_msg, user_msg]
96 END FUNCTION
97
98
99 FUNCTION parse_response(raw_text, original_code, iso_controls, ...):
100     IF raw_text is empty THEN
101         RETURN placeholder_recommendation(confidence=0.0)
102     END IF
103
104     // --- Ekstraksi penjelasan ---
105     // Coba tag XML <explanation>, lalu "1. EXPLANATION:", lalu
106     teks bebas
107
108     // --- Ekstraksi kode perbaikan ---
109     // Coba tag XML <fix>,
110     // lalu "2. FIXED CODE:", lalu blok ```php ... ```
111
112     // --- Ekstraksi skor kepercayaan (confidence) ---
113     // Coba tag <confidence>N</confidence>
114     // Coba kata kunci "CONFIDENCE: N" (integer 0-100)

```

```

115 // Coba desimal 0.x di dekat kata "confidence"
116 // Coba persentase di dekat kata "confidence"
117 // Coba bahasa natural: "not sure"->0.30, "confident"->0.75
118 // Jika tidak ditemukan -> kembalikan 0.0
119
120 RETURN AIRecommendation(original_code, suggested_fix, explanation,
121                           confidence, iso_controls, ...)
122 END FUNCTION
123
124
125 FUNCTION run_llm_comparison(findings, models, runs_per_finding,
126                             prompt_mode, reports_dir):
127     // Saring temuan yang memenuhi ambang prioritas
128     eligible <- [f for f in findings WHERE
129                  f.priority <= PRIORITY_THRESHOLD]
130
131     report <- {models_compared, runs_per_finding, prompt_mode,
132               findings: []}
133
134     FOR each model in models DO
135         IF Ollama NOT reachable THEN
136             mark model as unavailable
137             CONTINUE
138         END IF
139
140         FOR each finding in eligible DO
141             IF prompt_mode == "standard" THEN
142                 // Kondisi A: prompt identik untuk semua model
143                 messages <- build_chat_messages(finding)
144             ELSE
145                 // Kondisi B: prompt dioptimalkan per model
146                 messages <- build_optimized_chat_messages
147                             (finding, model)
148             END IF
149
150             confidences <- []
151             times <- []
152             FOR run_index = 1 to runs_per_finding DO
153                 (raw_text, elapsed) <- call_ollama_chat_timed
154                                     (messages, model)
155                 confidence <- extract_confidence(raw_text)
156                 format_ok <- check_format_valid(raw_text)
157                 confidences.append(confidence)
158                 times.append(elapsed)
159             END FOR
160
161             // Statistik agregat per temuan per model

```

```

162         finding_result <- {
163             confidence_mean      : mean(confidences),
164             confidence_variance  : variance(confidences),
165             confidence_stdev     : stdev(confidences),
166             format_compliance_rate: count(format_ok)/runs_per_finding,
167             mean_inference_time_sec: mean(times)
168         }
169         report.append(finding_result)
170     END FOR
171 END FOR

172
173 save_json(report, reports_dir / "llm_comparison_{timestamp}.json")
174 print_comparison_table(report)
175 RETURN report
176 END FUNCTION

```

B.6 Modul `iso_mapper.py` — Pemetaan ISO/IEC 27001:2022

Modul ini adalah "hakim akhir" pipeline yang mengumpulkan seluruh temuan dari Semgrep, PHPStan, dan rekomendasi AI, kemudian memetakannya ke enam kontrol keamanan ISO/IEC 27001:2022 Annex A yang relevan. Setiap kontrol diberi status: *COMPLIANT* (tidak ada temuan), *PARTIAL* (hanya peringatan), atau *NON_COMPLIANT* (terdapat kesalahan kritis). Status terburuk di antara semua kontrol menjadi status keseluruhan sistem. Rekomendasi AI dicatat sebagai bukti (*evidence*) namun **tidak** memengaruhi penentuan status kepatuhan.

```

1 PROGRAM: ISOMapper
2
3 DATA STRUCTURE ISOControl:
4     control_id      // e.g. "A.8.28"
5     title, description
6     status          // COMPLIANT | PARTIAL | NON_COMPLIANT
7     findings_count
8     evidence        // daftar string bukti temuan (maks. 30 entri)
9
10 DATA STRUCTURE ISOReport:
11     controls          : dict of ISOControl (kunci: control_id)
12     overall_status    : status terburuk dari semua kontrol
13     total_findings    : total temuan (Semgrep + PHPStan)
14     critical_findings : jumlah temuan ERROR-severity
15     generated_at      : waktu laporan dibuat
16
17 CONSTANT CONTROL_REGISTRY:
18     A.5.17 Authentication Information (pengelolaan kredensial)
19     A.8.24 Use of Cryptography (penggunaan enkripsi)
20     A.8.25 Secure Development Lifecycle (siklus pengembangan aman)

```

```

21 A.8.26 Application Security Requirements
22     (persyaratan keamanan aplikasi)
23 A.8.28 Secure Coding (praktik penulisan kode aman)
24 A.8.29 Security Testing in Development (pengujian keamanan)
25
26 STATUS RULES:
27     NON_COMPLIANT : terdapat >= 1 temuan ERROR pada kontrol ini
28     PARTIAL       : hanya temuan WARNING, tidak ada ERROR
29     COMPLIANT     : tidak ada temuan sama sekali pada kontrol ini
30
31
32 FUNCTION run_iso_mapping(scan_result, analysis_result, ai_recs,
33                          output_path):
34     // Step 1: Inisialisasi wadah temuan untuk setiap kontrol
35     findings_map <- {}
36     FOR each control in CONTROL_REGISTRY DO
37         findings_map[control] <- []
38     END FOR
39
40     // Step 2: Masukkan temuan Semgrep ke peta kontrol
41     IF scan_result != NULL THEN
42         FOR each finding in scan_result.findings DO
43             // INFO dinaikkan ke WARNING agar tidak ada status
44             // COMPLIANT palsu
45             severity <- normalize(finding.severity)
46             evidence <- "[Semgrep][vuln_type] file:baris -- pesan"
47             FOR each ctrl in finding.iso_controls DO
48                 findings_map[ctrl].append((severity, evidence))
49             END FOR
50         END FOR
51     END IF
52
53     // Step 3: Masukkan kesalahan PHPStan ke peta kontrol
54     IF analysis_result != NULL THEN
55         FOR each error in analysis_result.errors DO
56             IF error.file_path == "<phpstan>" THEN CONTINUE END IF
57             evidence <- "[PHPStan] file:baris -- pesan"
58             FOR each ctrl in error.iso_controls DO
59                 findings_map[ctrl].append((severity, evidence))
60             END FOR
61         END FOR
62     END IF
63
64     // Step 4: Kumpulkan bukti rekomendasi AI (hanya informatif)
65     ai_evidence_map <- {}
66     FOR each rec in ai_recs DO
67         evidence <- "[AI/model][vuln_type] file:baris -- fix

```

```

68         (confidence) "
69     FOR each ctrl in rec.iso_controls DO
70         ai_evidence_map[ctrl].append(evidence)
71     END FOR
72 END FOR
73
74 // Step 5: Bangun objek ISOControl untuk setiap kontrol
75 controls <- {}
76 FOR each (ctrl_id, title, description) in CONTROL_REGISTRY DO
77     entries <- findings_map[ctrl_id]
78     ai_evs <- ai_evidence_map[ctrl_id]
79     status <- determine_status(entries)
80     // Gabungkan bukti ERROR + WARNING + AI, batasi 30 entri
81     evidence <- (ERROR entries + WARNING entries + ai_evs)[:30]
82     controls[ctrl_id] <- ISOControl(ctrl_id, title, description,
83                                     status, count(entries), evidence)
84 END FOR
85
86 // Step 6: Status keseluruhan = status terburuk di
87 // antara semua kontrol
88 overall_status <- max(ctrl.status for ctrl in controls)
89
90 report <- ISOReport(controls, overall_status,
91                    total_findings, critical_findings, now())
92
93 print_control_table(report)
94 save_json(report, output_path)
95 RETURN report
96 END FUNCTION
97
98
99 FUNCTION determine_status(entries):
100     severities <- {sev for (sev, _) in entries}
101     IF "ERROR" in severities THEN RETURN NON_COMPLIANT END IF
102     IF "WARNING" in severities THEN RETURN PARTIAL END IF
103     RETURN COMPLIANT
104 END FUNCTION

```

B.7 Modul `composer_analyzer.py` — Analisis Dependensi

Composer adalah manajer dependensi standar PHP. File `composer.json` mendaftarkan semua *library* pihak ketiga yang digunakan proyek. Modul ini membaca file tersebut dan mengevaluasi kompatibilitas setiap *library* terhadap PHP 8.x menggunakan basis data paket yang sudah diketahui. Hasilnya berupa rekomendasi: apakah *library* aman digunakan (*safe*), perlu diperbarui versinya (*upgrade*), perlu diganti

dengan alternatif yang didukung (*replace*), atau perlu diperiksa secara manual karena datanya belum tersedia (*manual_review*).

```
1 PROGRAM: ComposerAnalyzer
2
3 DATA STRUCTURE DependencyRecommendation:
4     package                // nama library, e.g. "guzzlehttp/guzzle"
5     current_version_constraint // versi yang digunakan, e.g. "^6.0"
6     status                 // "safe" | "upgrade" | "replace" | "manual_review"
7     suggestion             // teks rekomendasi aksi yang harus dilakukan
8     iso_control             // "A.8.25" - Secure Development Lifecycle
9
10 DATA STRUCTURE ComposerAnalysisResult:
11     composer_found         : bool
12     php_constraint          // e.g. ">=7.4" dari composer.json
13     recommendations        : list of DependencyRecommendation
14     issues_count           // jumlah library yang berstatus bukan "safe"
15
16 CONSTANT KNOWN_PACKAGES:
17     // Basis data kompatibilitas library terhadap PHP 8.x
18     phpooffice/phpexcel    -> replace    ke phpooffice/phpspreadsheet
19     dompdf/dompdf          -> upgrade    ke versi >=2.0
20     swiftmailer/swiftmailer -> replace    ke symfony/mailer
21     codeigniter/framework  -> replace    ke codeigniter4/framework
22     guzzlehttp/guzzle      -> upgrade    ke versi >=7.0
23     monolog/monolog        -> safe       (>=2.0 mendukung PHP 8.x)
24     firebase/php-jwt       -> safe       (>=6.0 mendukung PHP 8.x)
25     ... (dan lainnya)
26
27
28 FUNCTION run_composer_analysis(input_dir, target_php):
29     composer_path <- input_dir / "composer.json"
30
31     // Jika proyek tidak menggunakan Composer, lewati tahapan ini
32     IF composer_path does NOT exist THEN
33         RETURN ComposerAnalysisResult(composer_found=FALSE)
34     END IF
35
36     data <- parse_json(composer_path)
37     php_constraint <- data["require"]["php"] // e.g. ">=7.4 <8.0"
38
39     // Kumpulkan semua dependensi (runtime + development),
40     // kecuali entri meta "php" dan "ext-*"
41     deps <- merge(data["require"], data["require-dev"])
42     deps <- filter(deps, exclude php and ext-*)
43
44     recommendations <- []
45     FOR each (package, version) in deps DO
```

```

46         rec <- evaluate_package(package, version, target_php)
47         recommendations.append(rec)
48     END FOR
49
50     print_dependency_table(recommendations)
51     RETURN ComposerAnalysisResult(composer_found=TRUE,
52                                   php_constraint, recommendations)
53 END FUNCTION
54
55
56 FUNCTION evaluate_package(package, version, target_php):
57     IF package in KNOWN_PACKAGES THEN
58         (action, suggestion, php8_safe) <- KNOWN_PACKAGES[package]
59         status <- "safe" IF php8_safe ELSE action
60     ELSE
61         // Library tidak ada dalam basis data: minta pemeriksaan manual
62         status <- "manual_review"
63         suggestion <- "Tidak ada data PHP 8.x untuk paket ini. "
64                     + "Periksa secara manual."
65     END IF
66
67     RETURN DependencyRecommendation(package, version, status, suggestion)
68 END FUNCTION

```

B.8 Ringkasan Alur Pipeline

Berikut adalah gambaran keseluruhan alur eksekusi pipeline dari awal hingga akhir. Setiap langkah menghasilkan sebuah objek hasil (*result object*) yang digunakan oleh langkah berikutnya. Kode keluar (*exit code*) 0 berarti sistem dinyatakan patuh ISO, sedangkan 1 berarti masih terdapat temuan yang perlu ditangani.

```

1 INPUT: File PHP sumber (PHP 5.x / 7.x) di direktori input/
2
3 Tahap 1  run_scan(input/)
4          -> ScanResult  [Semgrep, kondisi SEBELUM konversi]
5
6 Tahap 2  run_conversion(input/, output/)
7          -> ConversionResult  [Rector: PHP lama ke PHP 8.x]
8
9 Tahap 2b run_composer_analysis(input/)
10         -> ComposerAnalysisResult  [kompatibilitas library]
11
12 Tahap 3  run_scan(output/)
13         -> ScanResult  [Semgrep, kondisi SESUDAH konversi]
14
15 Tahap 4  run_analysis(output/)
16         -> AnalysisResult  [PHPStan: analisis tipe & referensi]

```

```

17
18 Tahap 5  run_ai_analysis(pre_scan.findings)
19          -> list[AIRecommendation]  [Ollama LLM: rekomendasi perbaikan]
20      ATAU  run_llm_comparison(pre_scan.findings, 5_models, 3_runs)
21          -> LLMComparisonReport  [perbandingan antar model]
22
23 Tahap 6  run_iso_mapping(pre_scan, analysis, ai_recs)
24          -> ISOReport  [pemetaan ke 6 kontrol ISO/IEC 27001:2022]
25
26 OUTPUT:
27  output/  -- file PHP 8.x hasil konversi
28  reports/
29      iso_report_{timestamp}.json          // laporan kepatuhan ISO
30      pipeline_result_{timestamp}.json     // ringkasan seluruh pipeline
31      llm_comparison_{timestamp}.json      // (jika mode --compare-all)
32
33 KODE KELUAR:
34  0 -> ISO overall_status == COMPLIANT    (semua kontrol terpenuhi)
35  1 -> NON_COMPLIANT / PARTIAL / ada tahapan yang gagal

```